CEH v13 AI (312-50) Study Guide - Module 03: Scanning Networks

EC-Council Certified Ethical Hacker v13 AI

Exam 312-50 Preparation Guide

Table of Contents

Table of Contents

1. Module at a Glance
2. Big Picture Map
3. Topic-by-Topic Guide
   3.1 Learning Objectives of Module 03
   3.2 Overview of Network Scanning
   3.3 TCP Communication Flags
   3.4 TCP/IP Communication: Handshake and Termination
   3.5 Host Discovery Techniques
   3.6 Port Scanning Techniques (Overview and Tree)
   3.7 TCP Connect / Full Open Scan (-sT)
   3.8 Stealth Scan: Half-open Scan (-sS)
   3.9 Inverse TCP Flag Scans: Xmas, FIN, NULL, and Maimon
   3.10 ACK Flag Probe Scan (-sA), TTL-based Scan, and Window Scan
   3.11 IDLE / IPID Header Scan (-sI): Third-party and Spoofed Scan
   3.12 UDP Scanning (-sU)
   3.13 SCTP Scanning: INIT (-sY) and COOKIE ECHO (-sZ)
   3.14 SSDP Scanning
   3.15 IPv6 Scanning (-6)
   3.16 Service Version Discovery (-sV)
   3.17 How to Identify the Target System OS (TTL and TCP Window Size)
   3.18 Packet Fragmentation
   3.19 Source Port Manipulation
   3.20 IP Address Spoofing
   3.21 Creating Custom Packets
   3.22 OS Discovery and Banner Grabbing
   3.23 Scanning Beyond IDS and Firewall (Overview of Evasion Techniques)
   3.24 Source Routing
   3.25 IP Address Decoy
   3.26 MAC Address Spoofing
   3.27 Randomizing Host Order and Sending Bad Checksums
   3.28 Proxy Servers and Anonymizers
   3.29 Port Scanning Countermeasures
   3.30 IP Spoofing Countermeasures

4. Tool Encyclopedia
  4.1 Scanners and Packet Tools
  4.2 Ping Sweep and Host Discovery Tools
  4.3 Packet Crafting and Fragmentation Tools
  4.4 Sniffers and OS Fingerprinting Tools
  4.5 Banner Grabbing Tools
  4.6 Spoofing, Proxy, and Anonymizer Tools
  4.7 Defensive Tools
5. Command Sheet
  5.1 Anatomy of an Nmap Command
  5.2 Host Discovery: nmap -sn with -PE, -PP, -PM, -PR, -PU, -PS, -PA, -PO
  5.3 TCP Connect and SYN Scans: -sT and -sS
  5.4 Inverse TCP Flag Scans: -sX, -sF, -sN, -sM
  5.5 ACK, Window, and TTL-based Scans: -sA and -sW
  5.6 Idle (IPID) Scan: -sI
  5.7 UDP, SCTP, and IPv6 Scans: -sU, -sY, -sZ, -6
  5.8 Service Version and OS Detection: -sV, -O, -A
  5.9 Evasion Switches: -f, -g, -D, -S, --spoof-mac, --badsum
  5.10 Hping3 and IP Spoofing: hping3 TARGET -a SPOOFED-IP
  5.11 Supporting Commands: Wireshark Filters, Banner Grabbing, and ShellGPT
6. Ports, Protocols, Standards and Acronyms
  6.1 Ports Seen in Your Screenshots
  6.2 Other Ports Often Asked (ADDED CONTEXT)
  6.3 Protocols and the Layer They Work At
  6.4 ICMP Types to Know (ADDED CONTEXT)
  6.5 TCP Flags and Reply Patterns
  6.6 OS Fingerprint Table from the Notes
  6.7 Standards, Specifications, and Concepts
  6.8 Acronyms Used in This Module
7. Attack vs Countermeasure and Look-alike Comparisons
  7.1 Attack or Technique vs Countermeasure
  7.2 Look-alike Pairs
8. Exam Cheat Sheet
  8.1 Keyword -> Answer Pairs
  8.2 Must-memorize Lists
  8.3 Numbers and Defaults
  8.4 Pick-the-BEST-option Rules
  8.5 Last-minute Traps

9. Practice Questions
10. Flashcards
11. Glossary
12. Coverage Report
    12.1 Page to Section Map
    12.2 [UNCLEAR] Items
    12.3 Items to Double Check (marked "verify" in the text)
    12.4 Confirmation

CEH v13 AI (312-50) Study Guide - Module 03: Scanning Networks

Source: 10 pages of screenshots from the official Module 03 theory videos (20 screenshots, slides 2 to 42). Content marked "ADDED CONTEXT" comes from outside the screenshots. Items marked "verify" should be checked against current official sources. Items marked [UNCLEAR on page N] were too small or blurry to read with full confidence.

1. Module at a Glance

Module: 03 - Scanning Networks (EC-Council CEH v13 AI).

What this module is (5 lines):

1. Scanning is phase 2 of the five hacking phases. Reconnaissance (Module 02) found the target. Scanning now finds live hosts, open ports, running services, and the operating system.
2. It starts with TCP/IP basics: the six TCP flags and the three-way handshake, because every scan is built from these.
3. It covers host discovery (ping scans), port scanning (TCP, UDP, SCTP, SSDP, IPv6), service version discovery, and OS discovery or banner grabbing.
4. It shows ten ways to scan beyond an IDS or firewall: fragmentation, source routing, source port manipulation, decoys, IP spoofing, MAC spoofing, custom packets, random host order, bad checksums, proxies, and anonymizers.
5. It ends with countermeasures against port scanning and IP spoofing.

Why it matters: Scanning builds the list of doors an attacker can try. Nmap alone fills a large share of the questions, so knowing each flag and what it sends is worth many exam marks.

What the exam usually asks from it:

- Which Nmap switch performs which scan or ping type (-sn, -PE, -PP, -PM, -PR, -PU, -PS, -PA, -PO, -sT, -sS, -sX, -sF, -sN, -sM, -sA, -sW, -sI, -sU, -sY, -sZ, -sV, -6).
- What a scan sends and how an open, closed, or filtered port answers.
- Which scans fail against Windows (FIN, NULL, Xmas).
- Which tool fits a job: Nmap, Hping3, Metasploit, NetScanTools Pro, Colasoft Packet Builder, Wireshark, Angry IP Scanner.
- How to guess the OS from TTL and TCP window size.
- Which evasion technique matches a scenario (decoy, fragmentation, spoofing, source port, source routing).
- Which countermeasure stops a given scan or spoof (ingress and egress filtering, ICMP filtering, random initial sequence numbers).

The 10 things to remember most:

1. Scanning = phase 2. Goals: live hosts, open ports, services, OS, and vulnerabilities.
2. The six TCP flags are URG, ACK, PSH, RST, SYN, FIN. The handshake is SYN, then SYN/ACK, then ACK.
3. Host discovery uses nmap -sn plus a probe switch: -PE echo, -PP timestamp, -PM address mask, -PR ARP, -PU UDP, -PS TCP SYN, -PA TCP ACK, -PO IP protocol.
4. Port scan switches: -sT connect, -sS half-open (stealth), -sX Xmas, -sF FIN, -sN NULL, -sM Maimon, -sA ACK, -sW window, -sI idle (zombie), -sU UDP, -sY SCTP INIT, -sZ SCTP COOKIE ECHO, -6 IPv6, -sV version.
5. SYN scan sends SYN, gets SYN/ACK, and replies RST. It never finishes the handshake. Connect scan finishes it.
6. Xmas = FIN + PSH + URG. NULL = no flags. FIN = FIN only. A closed port answers RST. An open port stays silent. These three do not work on Windows.
7. OS clue from the first reply packet: TTL 64 = Linux or FreeBSD, TTL 128 = Windows, TTL 255 = Cisco, Solaris, AIX, OpenBSD.
8. Evasion switches: -f (fragment), -g (source port), -D (decoy), --spoof-mac, --randomize-hosts, --badsum. Hping3 -a spoofs the source IP.
9. Banner grabbing has two types. Active sends crafted packets. Passive reads error messages, sniffed traffic, and page extensions such as .aspx.
10. Spoofing defenses: ingress filtering, egress filtering, random initial sequence numbers, no IP-based authentication, encryption (IPsec, TLS, SSH, HTTPS).

2. Big Picture Map

The module follows one flow. First learn the packet basics (flags and handshake). Then find live hosts. Then probe ports. Then identify services and the OS. Then learn how an attacker hides these scans from an IDS or firewall. Last, learn how a defender blocks them.

```
RECON (Module 02)
      |
      v
+-------------------------------------------------------------+
| SCANNING (Module 03) = find the doors                       |
|                                                             |
|  1 Host discovery  -> which hosts are alive   (-sn -P*)     |
|  2 Port scanning   -> which ports are open    (-sT -sS ...)|
|  3 Service version -> what software listens   (-sV)         |
|  4 OS discovery    -> which OS runs           (TTL, banner)|
|  5 Evade IDS/FW    -> do 1 to 4 without alarms              |
+-------------------------------------------------------------+
      |
      v
ENUMERATION (Module 04) -> VULNERABILITY ANALYSIS (Module 05)
```

The same idea as a table. Read it as "question the attacker asks" -> "technique".

Question	Technique	Main switch family	Section
Who is alive?	Host discovery	-sn with -P*	3.5
Which ports are open?	Port scanning	-sT -sS -sX -sF -sN	3.6 to 3.15
What runs on the port?	Service version	-sV	3.16
Which OS is it?	OS discovery	TTL, window, -O	3.17, 3.22
How do I avoid alarms?	IDS and firewall evasion	-f -g -D --badsum	3.18 to 3.28
How does the defender stop me?	Countermeasures	Rules and filters	3.29, 3.30

> **REMEMBER:** The notes do not follow the logical order exactly. The overview of evasion techniques (slide 25) appears after the banner grabbing slide. This guide keeps the order of your screenshots so you can match it with the videos. Use the table above as the logical map.

The five hacking phases (the exam asks these in order):

1. Reconnaissance
2. Scanning (this module)
3. Gaining access
4. Maintaining access
5. Clearing tracks

How to attack any scanning question in four steps:

1. Decide what is being found: a live host, an open port, a service, or an OS.
2. Decide the protocol: ICMP, ARP, TCP, UDP, or SCTP.
3. Decide whether a firewall or IDS is in the way. If yes, think evasion.
4. Match the exact switch or tool name to the keyword in the question.

3. Topic-by-Topic Guide

The topics below follow the order of the screenshots. Where one slide holds a tree of techniques (host discovery, port scanning), each technique gets its own sub-section.

3.1 Learning Objectives of Module 03

What it is: The opening slide lists six goals for the module. They are also the skeleton of this guide.

1. Explain network scanning concepts.
2. Demonstrate various scanning techniques for host discovery.
3. Demonstrate various techniques for port and service discovery.

4. Demonstrate various techniques for OS discovery.
5. Demonstrate various techniques for scanning beyond IDS and firewall.
6. Explain network scanning countermeasures.

The video caption on this screenshot reads "we're gonna start with just what scanning is." This is the instructor starting with the concept before the techniques.

EXAM FOCUS: The objectives show the question pools: concepts, host discovery, port and service discovery, OS discovery, IDS and firewall evasion, and countermeasures. Expect questions from every pool.

Memory trick: "Can Hackers Pick Operating-system Bypass Codes" -> Concepts, Host discovery, Port and service discovery, OS discovery, Bypass IDS/firewall, Countermeasures.

3.2 Overview of Network Scanning

What it is (simple words): Network scanning is a set of procedures for identifying hosts, ports, and services in a network. It is one part of information gathering. The attacker uses it to build a profile of the target organization.

Define the words first:

- **Host:** any device on a network that has an IP address (a PC, server, router, printer, camera).
- **Port:** a numbered door on a host (0 to 65535). A program listens behind a door. Port 80 is usually a web server.
- **Service:** the program that listens on a port (for example a web server or an FTP server).
- **Probe:** a packet the scanner sends to see how the target reacts.
- **Packet:** a small chunk of data sent over a network. It has a header (addresses and control fields) and a payload (the data).

Analogy: You stand outside a large office building at night. You walk around it. Which windows have lights on? (live hosts). Which doors are unlocked? (open ports). What kind of lock is on each door? (service versions). Which company built the building? (operating system). That walk is scanning.

How it works (numbered steps):

1. The attacker takes the target range from the reconnaissance phase.
2. The attacker sends TCP/IP probes to the target network (the process diagram on the slide).
3. The target network sends replies, or stays silent. Both are information.
4. The attacker reads the replies and builds a list of live hosts, open ports, services, and OS.
5. The list feeds the next phases: enumeration and vulnerability analysis.

The four objectives of network scanning (from the slide):

1. Discover live hosts, IP addresses, and open ports of live hosts.
2. Discover operating systems and system architecture.
3. Discover services running on hosts.
4. Discover vulnerabilities in live hosts.

Real-world use: A penetration tester has written approval to test a company that owns 10.10.1.0/24. She scans the range. Six hosts answer. One host shows ports 21, 80, 135, 139, 445, and 3389 open. She now knows it is probably a Windows machine with FTP, a web server, file sharing, and remote desktop. She reports which of these should not be exposed.

Tools and commands used here: The slide names four tools.

- **Nmap** (Network Mapper): the standard free, open-source scanner. Its GUI is Zenmap.
- **Hping3:** a command-line tool that builds custom TCP/IP packets.
- **Metasploit:** an exploitation framework that also has scanner modules.
- **NetScanTools Pro:** a Windows toolkit with ping, port scan, and packet tools.

> **ADDED CONTEXT:** Scanning has three common types. Network scanning (host discovery) lists live hosts. Port scanning lists open ports. Vulnerability scanning checks hosts for known weaknesses (Module 05). A typical CEH scanning methodology runs in this order (verify the exact order in your courseware): check live systems, scan ports, scan beyond IDS and firewall, banner grabbing, vulnerability scanning, draw a network diagram, and prepare proxies.
>
> **ADDED CONTEXT:** Scanning a network you do not own, or do not have written permission to test, is illegal in many countries. A real engagement has a signed scope document and rules of engagement.

AI angle (ADDED CONTEXT): AI helps the attacker and the tester write scan commands and read results. The v13 course teaches AI tools such as ShellGPT for host and OS discovery (see the course description at https://www.skillsoft.com/course/ceh-v13-scanning-e0c777b7-f351-4518-8a1d-235b7bb2230c). Example prompt: "Give me the Nmap command to find live hosts in 10.10.1.0/24 without scanning ports, for an authorized test." Expected answer: nmap -sn 10.10.1.0/24. The defender uses AI-based monitoring to spot scan patterns. Risk: the AI can invent a wrong flag, and pasting client scan data into a public AI tool leaks sensitive information. Always check the command and keep client data out of public tools.

Countermeasures and defense: See 3.29. In short: firewall and IDS rules, closed unused ports, and monitoring.

> **EXAM TIP:** "Identify hosts, ports, and services" is the definition. "Profile of the target organization" ties scanning to information gathering.

EXAM FOCUS:

- How it is asked: "Which of the following is an objective of network scanning?" or "Which tool is used for network scanning?"
- Keywords: live hosts, open ports, services, OS, architecture, vulnerabilities.
- Common trap: Vulnerability discovery is the fourth objective, but the full vulnerability assessment is Module 05.
- Look-alike: Scanning vs Enumeration. Scanning finds hosts, ports, and services. Enumeration (Module 04) pulls detailed data such as user names and shares from those services.

Memory trick: "Scanning finds H-P-S-O-V": Hosts, Ports, Services, OS, Vulnerabilities.

3.3 TCP Communication Flags

What it is (simple words): TCP is the transport protocol that gives reliable, ordered delivery (TCP = Transmission Control Protocol). Inside every TCP packet header there is a small set of one-bit switches called flags. The flags tell the receiver what the packet is for. The slide says: standard TCP communications are controlled by flags in the TCP packet header.

Analogy: Flags are the words used on a walkie-talkie. "Over" (ACK) means "I heard you". "Out" (FIN) means "I am finished". "Say again" (RST) means "forget it, start over". "Urgent" (URG) means "listen now". Scanners send strange word combinations to see how the other side replies.

The six flags on the slide:

Flag	Full name	Meaning (from the notes)	Seen in
URG	Urgent	Data in the packet should be processed immediately	Xmas scan
ACK	Acknowledgement	Acknowledges receipt of a packet	Handshake, ACK scan
PSH	Push	Sends all buffered data immediately	Xmas scan
RST	Reset	Resets a connection	Closed-port reply
SYN	Synchronize	Initiates a connection between hosts	Handshake, SYN scan
FIN	Finish	There will be no further transmissions	Closing, FIN scan

The TCP header on the slide. Each row is 32 bits wide (bit 0 to bit 31).

```
 0                             15 16                             31
+-------------------------------+-------------------------------+
| Source Port                    | Destination Port              |
+-------------------------------+-------------------------------+
| Sequence Number                                                |
+----------------------------------------------------------------+
| Acknowledgement Number                                         |
+--------+-------+---------------+-------------------------------+
| Offset | Res   | TCP Flags     | Window                        |
+--------+-------+---------------+-------------------------------+
| TCP Checksum                   | Urgent Pointer                |
+-------------------------------+-------------------------------+
| Options                                                        |
+----------------------------------------------------------------+
```

Field	Size	Job
Source Port	16 bits	Port the sender uses
Destination Port	16 bits	Port the sender wants
Sequence Number	32 bits	Position of the first data byte
Acknowledgement Number	32 bits	Next byte the receiver expects
Offset	4 bits	Header length (where data starts)
Res	3 bits	Reserved for future use
TCP Flags	9 bits	Control switches (URG, ACK, ...)
Window	16 bits	How much data the receiver can accept
TCP Checksum	16 bits	Detects damaged packets
Urgent Pointer	16 bits	Where urgent data ends (used with URG)
Options	Variable	Extras such as window scaling

The sizes come from the TCP standard, not the slide (ADDED CONTEXT). The minimum header is 20 bytes.

How the flags are used in scanning: A scanner sets the flags in unusual ways and watches the reply. The rules of TCP say what a normal host should answer. Differences show which ports are open.

Pattern	Flags set	Used by
Normal start	SYN	SYN (half-open) and connect scans
FIN scan	FIN	nmap -sF
NULL scan	none	nmap -sN
Xmas scan	FIN + PSH + URG	nmap -sX

Pattern	Flags set	Used by
ACK scan	ACK	nmap -sA and -sW
Maimon scan	FIN + ACK	nmap -sM

> **ADDED CONTEXT:** Modern TCP has three more flag bits: NS, CWR, and ECE. They manage network congestion and rarely matter for scanning. The exam uses the six flags on the slide.

Real-world use: An analyst reads a firewall log that shows packets with FIN, PSH, and URG all set. That pattern is not normal traffic. It is the signature of an Xmas scan.

Tools and commands used here: Wireshark (shows flags in a packet), Nmap (sets flags), Hping3 (sets flags by hand: -S, -A, -F, -P, -U, -R).

Countermeasures and defense: A stateful firewall drops packets whose flags do not fit a known connection. An IDS signature flags invalid flag combinations.

EXAM FOCUS:

- How it is asked: "Which flag initiates a connection?" (SYN). "Which flag resets a connection?" (RST). "Which flags are set in an Xmas scan?" (FIN, PSH, URG).
- Keywords: "no further transmissions" -> FIN. "Processed immediately" -> URG. "Buffered data" -> PSH. "Initiates a connection" -> SYN.
- Common trap: PSH and URG both sound like "hurry". PSH sends buffered data now. URG marks data as high priority.
- Look-alike: RST vs FIN. FIN closes politely. RST ends the connection at once, often because the port is closed.

Memory trick: "Unskilled Attackers Pester Real Security Folks" -> URG, ACK, PSH, RST, SYN, FIN. For Xmas: the tree lights up with "FPU" (FIN, PSH, URG).

3.4 TCP/IP Communication: Handshake and Termination

What it is (simple words): Before two hosts exchange data over TCP, they agree to talk. This is the three-way handshake. When they are done, they close the session in a four-step termination. The slide shows both, with a client called Bill (10.0.0.2) and a server called Sheela (10.0.0.3). The slide labels both ends with port 21 (FTP). In real life the client uses a random high port (called an ephemeral port).

Analogy: A phone call. Bill: "Hello Sheela, can you hear me?" (SYN). Sheela: "Yes, I hear you. Can you hear me?" (SYN/ACK). Bill: "Yes, I hear you too." (ACK). At the end each side says "I am done" (FIN) and the other says "OK" (ACK).

Three-way handshake (session establishment):

```
Client (Bill)                                    Server (Sheela)
10.0.0.2                                         10.0.0.3
    |                                                 |
    |---- SYN, SEQ=10 ------------------------------->|
    |<--- SYN+ACK, ACK=11, SEQ=142 -------------------|
    |---- ACK, ACK=143, SEQ=11 --------------------->|
    |                                                 |
    |============ connection open, data flows =======|
```

1. Bill sends SYN with sequence number 10: "I would like to talk with you on port 21. Are you open?"
2. Sheela sends SYN + ACK with ACK number 11 and her own sequence number 142: "OK, let's talk. I am open on port 21."
3. Bill sends ACK with ACK number 143 and sequence number 11: "OK, thanks."

The number rule: The ACK number is the other side's sequence number plus 1. Bill sent 10, so Sheela acknowledges 11. Sheela sent 142, so Bill acknowledges 143. A SYN or FIN uses up one sequence number even though it carries no data.

Termination (session close):

```
Client (Bill)                                    Server (Sheela)
    |                                                 |
    |---- FIN, SEQ=50 ------------------------------->|
    |<--- ACK, ACK=51, SEQ=170 ----------------------|
    |<--- FIN, SEQ=171 -----------------------------|
    |---- ACK, ACK=172, SEQ=51 --------------------->|
```

1. Bill sends FIN, SEQ 50: "I am done with the data transfer."
2. Sheela sends ACK, ACK 51, SEQ 170: "OK, I received your termination request."
3. Sheela sends FIN, SEQ 171: "I have received all the data sent."
4. Bill sends ACK, ACK 172, SEQ 51: "OK, thanks."

[UNCLEAR on page 2]: the numbers are small on the screenshot. The best reading is above. They follow the +1 rule, which supports this reading.

Why this matters for scanning: Scanners break or skip steps of this conversation and read the reply.

Target answer to a SYN	Meaning
SYN/ACK	Port is open
RST (or RST/ACK)	Port is closed
Nothing, or ICMP unreachable	Port is filtered (a firewall blocks it)

- Connect scan finishes all three steps, then closes.
- SYN (half-open) scan stops after step 2 and sends RST.
- FIN, NULL, and Xmas scans skip the handshake and send odd flags.
- Idle scan and IP spoofing hide who started the handshake.

Real-world use: A tester sees in Wireshark that her scan sends SYN and receives SYN/ACK, then her machine sends RST. This confirms the half-open behavior and explains why some applications never log the visit.

Tools and commands used here: Wireshark (watch the exchange), Nmap -sT and -sS (the two ways of using the handshake), Hping3 -S (send a single SYN).

Countermeasures and defense: SYN cookies and rate limits against SYN floods; stateful firewalls that track the handshake; IDS rules for many half-open connections.

> **EXAM TIP:** If a question gives you the sequence number of a packet, the reply's ACK number is that number plus 1.
>
> **TRAP:** The second packet is SYN + ACK (both flags in one packet), not two separate packets.

EXAM FOCUS:

- How it is asked: "What is the third step of the TCP handshake?" (ACK). "What does the server send in reply to SYN?" (SYN/ACK). "A closed port answers a SYN with what?" (RST).
- Keywords: "three-way", "SYN, SYN/ACK, ACK", "four-way termination", "FIN".
- Common trap: Termination takes four steps (FIN, ACK, FIN, ACK). The handshake takes three.
- Look-alike: RST vs FIN termination. RST is abrupt. FIN is graceful.

Memory trick: Start: "SYN, SYN-ACK, ACK" = "Sally Says Aloud: hi, hi-back, OK". End: "FIN, ACK, FIN, ACK" = "Finish, Acknowledge, Finish, Acknowledge".

3.5 Host Discovery Techniques

What it is (simple words): Host discovery finds the active (live) systems in a network. It answers one question: "Which IP addresses have a machine that is switched on and reachable?" This happens before port scanning, because there is no point scanning ports on a dead address. It is also called a ping scan or network sweep.

Analogy: You shout "Is anyone there?" down a long corridor of rooms. Rooms that answer are occupied. Different ways of shouting (a knock, a phone call, a note under the door) work on different rooms, because some rooms ignore some shouts.

The technique tree on the slide:

```
HOST DISCOVERY TECHNIQUES
 |
 +-- ICMP Ping Scan
 |     +-- ICMP ECHO Ping ........ nmap -sn -PE TARGET
 |     +-- ICMP Timestamp Ping ... nmap -sn -PP TARGET
 |     +-- ICMP Address Mask Ping  nmap -sn -PM TARGET
 |     +-- ICMP ECHO Ping Sweep .. nmap -sn -PE IP-RANGE
 +-- ARP Ping Scan ............. nmap -sn -PR TARGET
 +-- UDP Ping Scan ............. nmap -sn -PU TARGET
 +-- TCP Ping Scan
 |     +-- TCP SYN Ping ........ nmap -sn -PS TARGET
 |     +-- TCP ACK Ping ........ nmap -sn -PA TARGET
 +-- IP Protocol Ping Scan ..... nmap -sn -PO TARGET
```

How it works (numbered steps):

1. The attacker picks a target IP, a range, or a subnet.
2. Nmap sends one or more probe packets of the chosen type to each address.
3. A live host answers (any answer counts, even an error) or its presence is revealed by a reply.
4. Nmap marks the address "Host is up" and prints its latency (and its MAC address if the host is on the same LAN).
5. Addresses with no answer are marked down and skipped in later port scans.

The core switches:

Switch	Meaning	Notes
-sn	Ping scan: discover hosts, no port scan	Older name: -sP
-Pn	Skip discovery: treat every host as up	Older name: -PN. Use when ICMP is blocked
-n	Never do DNS lookups	Faster, quieter
-P* probes	Choose the probe type (see below)	Used with -sn

> **ADDED CONTEXT:** If you give -sn and no probe switch, Nmap picks defaults (verify for your version). On a local Ethernet LAN as root, it uses ARP. Against remote targets it sends an ICMP echo request, a TCP SYN to port 443, a TCP ACK to port 80, and an ICMP timestamp request. On a LAN, Nmap keeps using ARP even when you ask for other -P probes, unless you add --send-ip.
>
> **TRAP:** -sn means "no port scan". It does not mean "stealth", and it is not -sS. -Pn is the opposite idea: skip the ping and go straight to port scanning.

Real-world use: A tester has the range 10.10.1.0/24. A full port scan of 254 addresses would take a long time. She runs a ping sweep first, finds 11 live hosts, and scans only those.

Tools and commands used here: Nmap, Zenmap, and the ping sweep tools in 3.5.7 (Angry IP Scanner, SolarWinds Engineer's Toolset, NetScanTools Pro, Colasoft Ping Tool, Advanced IP Scanner, OpUtils).

AI angle (ADDED CONTEXT): An AI assistant turns plain English into the right switch. Example prompt: "Write an Nmap command that checks if 10.10.1.0/24 hosts are alive using ARP only, no DNS lookups." Answer: nmap -sn -PR -n 10.10.1.0/24. The tester still reads the command before running it.

Countermeasures and defense: Block inbound ICMP echo at the edge. Use a host firewall. Use IDS rules that alert on one source pinging many addresses. Note that an internal LAN cannot hide from ARP.

Memory trick for the -P letters: "Every Pirate Must Rob Under Starry Ancient Oceans" -> PE Echo, PP timestamP, PM Mask, PR aRp, PU Udp, PS Syn, PA Ack, PO prOtocol.

3.5.1 ICMP Ping Scan (Echo, Timestamp, Address Mask, Sweep)

What it is: ICMP (Internet Control Message Protocol) is the network "error and test" protocol. The ping command uses it. An ICMP ping scan sends ICMP request messages and waits for replies. The slide lists three request types and the sweep.

Probe	Switch	ICMP type sent	Reply type
ICMP ECHO Ping	-sn -PE	8 (echo request)	0 (echo reply)
ICMP Timestamp Ping	-sn -PP	13 (timestamp request)	14 (timestamp reply)
ICMP Address Mask Ping	-sn -PM	17 (mask request)	18 (mask reply)
ICMP ECHO Ping Sweep	-sn -PE with a range	8	0

The ICMP type numbers are ADDED CONTEXT (verify against RFC 792).

Analogy: Echo ping is "Can you hear me?". Timestamp ping is "What time is it on your clock?". Address mask ping is "What is your subnet mask?". A host that answers any of them is alive.

How it works:

1. Nmap sends the ICMP request to the target.
2. If the host is alive and allows the message, it sends the matching reply.
3. Nmap prints "Host is up".

Why use timestamp or address mask: Many firewalls block ICMP echo (type 8) but forget the other types. The attacker tries -PP or -PM to find hosts that the echo ping missed. Many modern hosts ignore the address mask request, so -PM works less often (ADDED CONTEXT).

ICMP echo ping sweep: A ping sweep sends echo requests to a whole range of addresses. The slide shows "nmap -sn -PE" with an IP range, and a screenshot where several hosts answer. Each live host shows "Host is up" and its MAC address.

Real-world use: An attacker pings a company range and finds the web server answers echo. The firewall blocks echo to the database server, but the same server answers timestamp requests. The attacker adds it to the list.

Countermeasures: Filter ICMP types 8, 13, and 17 inbound at the firewall. Allow only the ICMP your network needs. Alert on one host sending ICMP to many addresses.

> **EXAM TIP:** "Which scan sends ICMP type 8?" -> echo (-PE). "Find hosts when echo is blocked" -> timestamp (-PP) or address mask (-PM).

EXAM FOCUS: Keywords: "ping sweep", "range of IP addresses", "ICMP ECHO". Trap: a ping sweep tells you only that a host is alive, not which ports are open. Look-alike: -PE (ping) vs -sS (port scan).

Memory trick: "Echo, Time, Mask" = E, P (timestamP), M.

3.5.2 ARP Ping Scan

What it is: ARP (Address Resolution Protocol) finds the MAC address (hardware address) that belongs to an IP address on a local network. An ARP ping scan sends ARP requests ("Who has 10.10.1.11? Tell me your MAC.") and treats any reply as proof that the host is alive. Switch: nmap -sn -PR.

Analogy: In a school hall you shout a name: "Who is Priya?" Only Priya answers. She cannot pretend she did not hear, because the hall is one room.

How it works:

1. The scanner broadcasts an ARP request on the local network for each target IP.
2. A live host replies with its MAC address.
3. Nmap marks the host up and prints the MAC address and the hardware vendor (for example "Microsoft").

Key facts:

- ARP works only on the same local network (same subnet, Layer 2). It cannot cross a router.
- A host firewall that blocks ICMP or TCP usually still answers ARP, because the host needs ARP to communicate. So it is the most reliable discovery on a LAN.
- It is fast, and it is hard to block.

Real-world use: An insider with a laptop plugged into the office switch runs an ARP ping sweep on the local subnet. Every device shows up, even those that ignore ping.

Tools: Nmap -PR, arp-scan and Netdiscover (ADDED CONTEXT).

Countermeasures: Network segmentation (VLANs), port security on switches, and monitoring for ARP storms and ARP spoofing (Module 08).

EXAM FOCUS: Keywords: "same subnet", "local network", "MAC address", "cannot be blocked by a host firewall". Trap: ARP scans do not work across the internet or across routers. Look-alike: ARP ping (-PR, discovery) vs ARP poisoning (an attack in Module 08).

Memory trick: "ARP = Address Resolution = Right here on the LAN".

3.5.3 UDP Ping Scan

What it is: A UDP ping scan sends a UDP packet to a port on the target. UDP (User Datagram Protocol) is a connectionless transport protocol with no handshake. Switch: nmap -sn -PU.

Analogy: You drop a postcard in a mailbox. If nobody lives at the address and the building is empty, the postal service returns a "no such address" notice. That notice proves the building exists.

How it works:

1. Nmap sends an empty UDP packet to a port that is probably closed (the default is 40125, ADDED CONTEXT, verify).
2. A live host with the port closed sends back an ICMP "port unreachable" message (type 3, code 3).
3. That reply proves the host is alive.
4. If the host drops UDP or ICMP at a firewall, no reply comes and the host looks down.

Real-world use: TCP and ICMP are blocked at a firewall, but UDP packets pass. The attacker uses -PU to find hosts.

Countermeasures: Drop unneeded UDP at the edge. Block outbound ICMP type 3 (this is also on the countermeasure slide in 3.29).

EXAM FOCUS: Keywords: "UDP", "ICMP port unreachable". Trap: A UDP port that is open may not reply at all, so a UDP ping targets a closed port on purpose. Look-alike: -PU (host discovery) vs -sU (UDP port scan).

Memory trick: "U for UDP: Unreachable message comes back."

3.5.4 TCP Ping Scan (SYN Ping and ACK Ping)

What it is: A TCP ping scan uses TCP packets instead of ICMP to test if a host is alive. The slide shows two kinds.

Kind	Switch	Packet sent	A live host answers with
TCP SYN Ping	-sn -PS	SYN (default port 80)	SYN/ACK (open) or RST (closed)
TCP ACK Ping	-sn -PA	ACK (default port 80)	RST

Analogy: SYN ping is knocking on the door to start a conversation. Even if the person says "no, go away" (RST), you know someone is home. ACK ping is saying "Thanks for your message" to someone who never sent one. A confused person replies "I did not send you anything" (RST). Again, someone is home.

How it works (SYN ping):

1. Nmap sends an empty SYN to port 80 (or the ports you list, for example -PS22,80,443).
2. Open port: the host replies SYN/ACK. Closed port: the host replies RST.
3. Either reply shows the host is alive.
4. Nmap does not complete the handshake.

How it works (ACK ping):

1. Nmap sends a bare ACK packet.
2. A live host that has no matching connection replies RST.
3. Any RST proves life.
4. Stateless packet filters often let ACK packets through because they look like part of an existing conversation. A stateful firewall drops them.

Real-world use: A firewall drops ICMP but allows web traffic to port 80. The tester uses -PS80 and finds the live web servers. When SYN is blocked by a simple filter, -PA gets through.

Reading the TCP SYN ping screenshot (page 2): The sample shows "nmap -sn -PS" against one target, the line "Host is up (0.00078s latency)", a MAC address line with the vendor "Microsoft", and the summary "1 IP address (1 host up) scanned in 0.13 seconds". [UNCLEAR on page 2]: the exact date, latency, and scan time are small. A normal output of this kind looks like this:

```
Starting Nmap 7.94 ( https://nmap.org ) at 2024-03-04 03:43 EST
Nmap scan report for 10.10.1.11
Host is up (0.00078s latency).
MAC Address: 00:15:5D:01:80:00 (Microsoft)
Nmap done: 1 IP address (1 host up) scanned in 0.13 seconds
```

Line by line: line 1 is the Nmap version and the time. Line 2 names the target. Line 3 says it answered and how fast. Line 4 is the MAC address and the vendor from the first three bytes (the OUI). Line 5 is the summary. No port list appears, because -sn disables the port scan.

Countermeasures: Use a stateful firewall. Drop unsolicited ACK packets. Log many SYN probes from one source.

EXAM FOCUS: Keywords: "ICMP is blocked", "half-open", "port 80". Trap: A RST reply does not mean the target is dead. RST means a host is alive and the port is closed. Look-alike: -PS (ping) vs -sS (port scan).

Memory trick: "PS = Please Syn, PA = Please Ack". A reply of RST still means "I am here".

3.5.5 IP Protocol Ping Scan

What it is: An IP protocol ping scan sends raw IP packets with different protocol numbers in the IP header and watches for any reply. Switch: nmap -sn -PO. Protocol numbers are the values in the IP header that say what rides inside (1 = ICMP, 2 = IGMP, 6 = TCP, 17 = UDP, 4 = IP-in-IP).

Analogy: You try several types of envelope at one address: a letter, a parcel, a telegram. If the address answers any of them, or the postal service says "we do not take that type here", you know the address exists.

How it works:

1. By default Nmap sends packets for protocols 1 (ICMP), 2 (IGMP), and 4 (IP-in-IP). You can choose others, for example -PO1,6,17 (ADDED CONTEXT, verify defaults).
2. A live host answers in some way, or an ICMP "protocol unreachable" message returns.
3. Any answer marks the host up.

Real-world use: A firewall blocks the common ping types. The attacker tries protocol-level probes that the rule set does not cover.

Countermeasures: Block IP protocols the network does not use. Use a default-deny firewall policy.

EXAM FOCUS: Keywords: "IP protocol numbers", "-PO". Look-alike: -PO (capital letter O, protocol) vs -P0 (zero, an old way to write skip discovery). Use the letter O for protocol ping.

Memory trick: "PO = Protocol Ping, O for prOtocol".

3.5.6 Quick Comparison of Host Discovery Methods

Method	Switch	Layer / protocol	Best when
ICMP echo	-PE	Network / ICMP	Ping is allowed
ICMP timestamp	-PP	Network / ICMP	Echo is blocked
ICMP address mask	-PM	Network / ICMP	Echo is blocked

Method	Switch	Layer / protocol	Best when
ARP	-PR	Data link / ARP	Same LAN
UDP	-PU	Transport / UDP	TCP and ICMP blocked
TCP SYN	-PS	Transport / TCP	Web ports are open
TCP ACK	-PA	Transport / TCP	SYN is filtered
IP protocol	-PO	Network / IP	Other probes fail

3.5.7 Ping Sweep Tools

What it is: A ping sweep tool pings a range of addresses and lists the live ones, usually with a graphic screen. The slide lists six.

Tool	What it does (simple)	Platform
Angry IP Scanner	Fast, free IP and port scanner with simple GUI	Windows, Linux, macOS
SolarWinds Engineer's Toolset	Commercial set of network tools including a ping sweep	Windows
NetScanTools Pro	Commercial toolkit: ping, port scan, packet tools	Windows
Colasoft Ping Tool	Pings many hosts at once and shows results	Windows
Advanced IP Scanner	Free LAN scanner; finds hosts and shared folders	Windows
OpUtils	ManageEngine toolset for IP and switch port management	Windows, Linux

Real-world use: A junior admin uses Advanced IP Scanner to list all devices on a branch office network. An attacker uses the same tool after getting onto the Wi-Fi.

> **ADDED CONTEXT:** Alternatives the exam may place next to these: fping (command-line ping sweep), Nmap -sn, Masscan (very fast port scanner), and Zmap (internet-wide scanner).

EXAM FOCUS: Keywords: "ping sweep tool", "GUI". Trap: Nmap is the answer for command-line scanning, but the slide's "Ping Sweep Tools" list does not include Nmap. If the list is shown, pick from it.

Memory trick: "A Smart Network Can Always Observe" -> Angry IP, SolarWinds, NetScanTools, Colasoft, Advanced IP, OpUtils.

3.6 Port Scanning Techniques (Overview and Tree)

What it is (simple words): Port scanning finds which ports on a live host are open, closed, or filtered. The slide says the techniques are categorized according to the type of protocol used for communication. So the first split is by protocol: TCP, UDP, SCTP, SSDP, and IPv6.

Analogy: A hotel has 65,535 room doors. You walk the corridor and try each handle. Some doors open (open port), some are locked with nobody inside (closed), and some have a guard who gives no answer at all (filtered).

The tree on the slide:

```
PORT AND SERVICE DISCOVERY TECHNIQUES
 |
 +-- TCP Scanning
 |     +-- Open TCP Scanning Methods
 |     |     +-- TCP Connect / Full Open Scan ... -sT
 |     +-- Stealth TCP Scanning Methods
 |     |     +-- Half-open Scan ................. -sS
 |     |     +-- Inverse TCP Flag Scan
 |     |     |     +-- Xmas -sX, FIN -sF, NULL -sN, Maimon -sM
 |     |     +-- ACK Flag Probe Scan ............ -sA
 |     |           +-- TTL-based Scan, Window Scan
 |     +-- Third Party and Spoofed TCP Scanning
 |           +-- IDLE / IPID Header Scan ........ -sI
 +-- UDP Scanning ............................... -sU
 +-- SCTP Scanning: INIT -sY, COOKIE ECHO -sZ
 +-- SSDP Scanning
 +-- IPv6 Scanning ............................. -6
```

The six port states Nmap reports:

State	Meaning	Typical cause
open	A program accepts connections here	A service is running
closed	Reachable, but nothing listens	Host answered with RST
filtered	Nmap cannot tell; probes are blocked	Firewall drops packets
unfiltered	Reachable, but open or closed is unknown	Result of an ACK scan
open or filtered	No reply, so cannot tell	UDP, FIN, NULL, Xmas scans
closed or filtered	Cannot tell (idle scan only)	Rare

In Nmap's own output the combined states are written with a vertical bar (open|filtered). Tables here use words so the table stays valid.

Port number ranges (ADDED CONTEXT): Well-known ports 0 to 1023 (HTTP 80, HTTPS 443, SSH 22). Registered ports 1024 to 49151. Dynamic or private ports 49152 to 65535. By default Nmap scans the 1000 most common ports, not all 65,535. That is

why a result says "Not shown: 994 closed tcp ports" when six ports are listed (994 + 6 = 1000).

Summary of all scans (read this table before the detail sections):

Scan	Switch	Probe sent	Open port answer	Closed port answer
TCP Connect	-sT	SYN (full handshake)	SYN/ACK, then ACK	RST
Half-open (SYN)	-sS	SYN	SYN/ACK, then RST	RST
Xmas	-sX	FIN+PSH+URG	No reply	RST
FIN	-sF	FIN	No reply	RST
NULL	-sN	No flags	No reply	RST
Maimon	-sM	FIN+ACK	No reply (BSD type)	RST
ACK	-sA	ACK	RST (unfiltered)	RST (unfiltered)
Window	-sW	ACK	RST, window not zero	RST, window zero
Idle (IPID)	-sI	Spoofed SYN	Zombie IPID up by 2	Zombie IPID up by 1
UDP	-sU	UDP packet	UDP reply or none	ICMP port unreachable
SCTP INIT	-sY	INIT chunk	INIT-ACK	ABORT
SCTP COOKIE ECHO	-sZ	COOKIE-ECHO chunk	No reply	ABORT

How a scan works in general (numbered steps):

1. Nmap picks the ports (default: the top 1000; change with -p).
2. It sends the chosen probe to each port, many in parallel.
3. It matches each reply, or the lack of one, to a state.
4. It retries ports that gave no reply (to rule out packet loss).
5. It prints the open ports and a count of the others.

Real-world use: A tester sees a host with 21, 80, 135, 139, 445, and 3389 open. FTP, SMB, and RDP on one machine are risky. She notes each one for the vulnerability phase.

Tools and commands used here: Nmap (all switches), Zenmap, Hping3, Metasploit scanner modules, NetScanTools Pro. Commands are in section 5.

AI angle (ADDED CONTEXT): An AI assistant can pick the scan type. Example prompt: "I need a port scan that never completes the TCP handshake and covers all

65535 ports on 10.10.1.11. Give me the Nmap command." Answer: nmap -sS -p- 10.10.1.11. The AI can also summarize large results: "Group these Nmap results by risk and list the three ports to test first." Check every AI answer. A wrong switch (for example -sT instead of -sS) changes how visible the scan is.

Countermeasures and defense: See 3.29. Close unused ports, use a default-deny firewall, and add IDS rules for scanning.

> **EXAM TIP:** Questions describe the packet ("sends a SYN, then RST"). Convert the description into a scan name, then into a switch.

EXAM FOCUS:

- How it is asked: "Which scan never completes the three-way handshake?" (half-open). "Which scan finds firewall rules rather than open ports?" (ACK).
- Keywords: "full open", "stealth", "half-open", "inverse", "zombie", "no response means open".
- Common trap: Many students mix up "stealth" (-sS) with "silent". It is only stealthier than connect scan. Modern IDS still see it.
- Look-alike: Open TCP scanning (connect) vs Stealth TCP scanning (half-open, inverse, ACK) vs Third-party scanning (idle).

Memory trick: The TCP tree has three branches: "Open, Stealth, Third-party" = "O-S-T". Inside Stealth: "Half, Inverse, ACK" = "H-I-A".

3.7 TCP Connect / Full Open Scan (-sT)

What it is: The scanner completes the full three-way handshake with each port, then closes the connection. It uses the operating system's own connect() function, so it needs no special rights. Switch: nmap -sT -v TARGET. The -v makes the output verbose (more detail).

Analogy: You knock, the door opens, you say hello, shake hands, and then leave. Everyone in the house remembers you came.

How it works (numbered steps):

1. Nmap asks the OS to connect to port N.
2. The OS sends SYN.
3. Open port: the target sends SYN/ACK. The OS sends ACK. The connection is made, and Nmap closes it.
4. Closed port: the target sends RST. Nmap records "closed".
5. No answer or an ICMP error: the port is "filtered".

Key facts:

- Works without administrator or root rights. It is the default scan when the user is not privileged.
- Slowest and noisiest TCP scan. The target application often logs the connection.
- It cannot use raw packet tricks. Options such as --spoof-mac, decoys (-D), and fragmentation (-f) do not apply to it.

Real-world use: A tester on a locked-down workstation without admin rights runs -sT to get a quick list of open ports on a server. The server's log shows many short connections from her IP.

Tools: Nmap -sT, Metasploit auxiliary/scanner/portscan/tcp (ADDED CONTEXT, verify), NetScanTools Pro.

Countermeasures: Connection logging with alerts on many short connections. Rate limits. Firewall rules that drop unwanted ports.

EXAM FOCUS: Keywords: "full open scan", "completes the handshake", "no root", "OS connect call", "easily logged". Trap: the screenshot on page 8 shows -sT used with --spoof-mac. Nmap says those options are not honored for TCP connect scan (see 3.26). Look-alike: -sT (connect, full) vs -sS (half-open).

Memory trick: "T = Total handshake. S = Stops short."

3.8 Stealth Scan: Half-open Scan (-sS)

What it is: The scanner sends SYN but never finishes the handshake. After SYN/ACK it sends RST, so the connection is never fully made. Switch: nmap -sS -v TARGET. It is also called the SYN scan or SYN stealth scan.

Analogy: You ring the doorbell. When someone says "Yes?" you run away before they open the door. They may not even write it down in the visitor book.

How it works (numbered steps):

1. Nmap crafts a raw SYN packet.
2. Open port: the target replies SYN/ACK. Nmap sends RST and marks "open". The handshake never completes.
3. Closed port: the target replies RST. Nmap marks "closed".
4. No reply, or an ICMP unreachable error: "filtered".

Key facts:

- Needs raw sockets, so it needs administrator or root rights. This is Nmap's default scan when it has those rights.

- Faster than connect scan. Applications often do not log it because the connection never reaches them. Firewalls and IDS can still see it (the SYN packets are in their logs).
- It is called stealth because older systems logged only completed connections.

Real-world use: A red team runs -sS across a /24 at the start of a test. The web server logs show nothing. The firewall log shows many SYN packets with no data, which the SOC (security operations center) notices on review.

Tools: Nmap -sS, Hping3 -S (one probe at a time), Masscan (very fast SYN scanner, ADDED CONTEXT).

Countermeasures: IDS rules for many SYN packets without ACK follow-up. SYN flood protection. Port knocking (ADDED CONTEXT). Close unneeded ports.

EXAM FOCUS: Keywords: "half-open", "does not complete the three-way handshake", "SYN, SYN/ACK, RST", "stealth", "raw packets". Trap: stealth does not mean undetectable. Look-alike: half-open scan vs SYN flood (a DoS attack that never finishes handshakes to fill the target's table).

Memory trick: "Half-open = Hello, Hello-back, Ha-ha-gone (RST)".

3.9 Inverse TCP Flag Scans: Xmas, FIN, NULL, and Maimon

What it is: Inverse TCP flag scanning sends probes with odd flag settings (or no flags). The rule is "inverse": an open port gives no reply, a closed port gives RST. This is the opposite of a normal handshake, where the open port speaks. The slide lists four scans under this heading.

Analogy: You send a letter to a house with a strange envelope. If the house is empty (closed), the post office sends back "return to sender" (RST). If someone lives there (open), they ignore the odd letter and say nothing.

Why it works (ADDED CONTEXT): The original TCP standard (RFC 793) says that a packet without SYN, RST, or ACK arriving at an open port should be dropped, and arriving at a closed port should get RST. Hosts that follow this rule leak the port state. Windows and some others do not follow it, and send RST for every port.

3.9.1 Xmas Scan (-sX)

What it is: Sends a packet with FIN, PSH, and URG all set. The packet is "lit up like a Christmas tree". Switch: nmap -sX -v TARGET.

How it works:

1. Nmap sends a TCP packet with FIN + PSH + URG.
2. Closed port: the target replies RST.

3. Open port: no reply (state "open or filtered").
4. ICMP unreachable: "filtered".

3.9.2 FIN Scan (-sF)

What it is: Sends a packet with only the FIN flag set, on a connection that does not exist. Switch: nmap -sF -v TARGET.

How it works: Same reply pattern. Closed port: RST. Open port: silence.

3.9.3 NULL Scan (-sN)

What it is: Sends a packet with no flags set at all (all flag bits are 0). Switch: nmap -sN -v TARGET.

How it works: Same reply pattern. Closed port: RST. Open port: silence.

3.9.4 Maimon Scan (-sM)

What it is: Sends a packet with FIN and ACK set. It is named after Uriel Maimon, who described the technique. Switch: nmap -sM -v TARGET.

How it works: On some BSD-derived systems, an open port drops the packet (silence) and a closed port replies RST. Most modern systems reply RST for both, so Maimon rarely works today (ADDED CONTEXT, verify).

Comparison table:

Scan	Flags set	Switch	Open port	Closed port
Xmas	FIN, PSH, URG	-sX	No reply	RST
FIN	FIN	-sF	No reply	RST
NULL	None	-sN	No reply	RST
Maimon	FIN, ACK	-sM	No reply (BSD)	RST

Real-world use: A tester scans a Linux web server behind a simple stateless packet filter. A SYN scan is blocked, but -sF passes. The result shows port 80 as "open or filtered" and the rest as closed.

Tools: Nmap -sX, -sF, -sN, -sM. Hping3 can send the same flags by hand (-F, -P, -U, and so on).

Limits:

- **Do not work on Windows.** Windows answers RST on every port, so everything looks closed. The same is true for some Cisco devices (ADDED CONTEXT).
- Cannot tell "open" from "filtered", because both give silence.
- A stateful firewall drops these packets, so they pass only simple filters.

- Need root or administrator rights (raw packets).

Countermeasures: Use a stateful firewall that drops packets which do not belong to a known connection. Add IDS signatures for Xmas, FIN, and NULL patterns.

> **EXAM TIP:** "The scan returned that all ports were closed on a Windows host" -> the tester used an inverse flag scan (Xmas, FIN, or NULL) against Windows. Those scans cannot work there.
>
> **TRAP:** In these scans silence means open (or filtered). In a SYN scan, silence means filtered. Read the question carefully.

EXAM FOCUS:

- How it is asked: "Which scan sets the FIN, URG, and PSH flags?" (Xmas). "Which scan sends a packet with no flags?" (NULL). "Which scan does not work against Windows?" (FIN, NULL, Xmas).
- Keywords: "Christmas tree", "all flags off", "RFC 793 compliant", "UNIX/Linux target", "inverse".
- Common trap: The slide's command text shows the three as a group, "-(-sF, -sN, -sX)". This means one of the three switches. Maimon is -sM.
- Look-alike: NULL (no flags) vs FIN (one flag) vs Xmas (three flags). Maimon is FIN + ACK.

Memory trick: "X is the crossed-out tree: Xmas = FPU (FIN, PSH, URG). N = Nothing (NULL). F = Finish (FIN). M = Maimon has a Mix (FIN + ACK)." And "Closed answers RST, open keeps quiet".

3.10 ACK Flag Probe Scan (-sA), TTL-based Scan, and Window Scan

What it is: The ACK flag probe scan sends TCP packets with only the ACK flag set. It does not find open ports. It finds out how the firewall treats a port: blocked (filtered) or allowed through (unfiltered). Switch: nmap -sA -v TARGET. The slide shows two variants below it: the TTL-based scan and the window scan.

Analogy: You do not try to enter the building. You hand a note to the guard that says "this is a reply to your earlier question". If the guard says "I never asked you anything" (RST), the guard is there and the road to him is open. If you get no answer at all, something in the middle (a firewall) swallowed the note.

How it works (plain ACK scan):

1. Nmap sends a TCP packet with the ACK flag set to a port.
2. A reply of RST means the packet reached the host. The port is "unfiltered" (open or closed is still unknown).

3. No reply, or an ICMP unreachable error, means a firewall blocks it. The port is "filtered".
4. Nmap uses the result to map the firewall rule set. It also shows whether the firewall is stateful.

TTL-based scan (slide command: nmap -sA -ttl 100 -v TARGET):

- The attacker sends ACK probes and studies the TTL (Time To Live) field of the RST replies.
- EC-Council's rule of thumb: if the TTL of the RST reply is lower than the boundary value 64, the port is open (verify against your courseware; it is a heuristic, not a guarantee).
- [UNCLEAR on page 3]: The slide writes the switch as -ttl 100. The real Nmap option is --ttl (with two dashes). Learn the slide wording for the exam, and use --ttl in a real tool.

Window scan (slide command: nmap -sA -sW -v TARGET):

- The attacker sends ACK probes and studies the TCP window field of the RST replies.
- EC-Council's rule of thumb: a non-zero window value means the port is open; a zero window means closed (verify).
- [UNCLEAR on page 3]: On a real system the window scan is the single switch -sW. The slide shows it written after -sA. Remember "-sW = window scan".

Real-world use: A tester wants to know if a firewall blocks port 22 or just the host has no SSH. An ACK scan returns "filtered" for 22 and "unfiltered" for 80. The conclusion: the firewall drops traffic to 22 and passes traffic to 80.

Tools: Nmap -sA and -sW, Hping3 -A (ACK packet).

Countermeasures: Use a stateful firewall. A stateful firewall drops an ACK that is not part of a known connection. A stateless filter lets it through, which gives the attacker a map.

EXAM FOCUS:

- How it is asked: "Which scan determines firewall rules and whether ports are filtered?" (ACK). "Which scan analyzes the TTL or window of the RST packet?" (ACK-based variants).
- Keywords: "firewall rule set", "stateful or stateless", "unfiltered", "RST received".
- Common trap: An ACK scan cannot say a port is open in the strict sense. It only says unfiltered or filtered.
- Look-alike: ACK scan (-sA, maps firewall) vs ACK ping (-PA, host discovery) vs window scan (-sW).

Memory trick: "A for Allowed? ACK asks if the path is Allowed". TTL under 64 and non-zero window both point to "open" in the EC-Council rule.

3.11 IDLE / IPID Header Scan (-sI): Third-party and Spoofed Scan

What it is: The idle scan lets the attacker scan a target without sending one packet from his own IP address. The scan "bounces" off a third machine, called the zombie (or idle host). The target sees the zombie as the scanner. The slide places it under "Third Party and Spoofed TCP Scanning Methods". Command on the slide: nmap -Pn -p- -sI ZOMBIE TARGET.

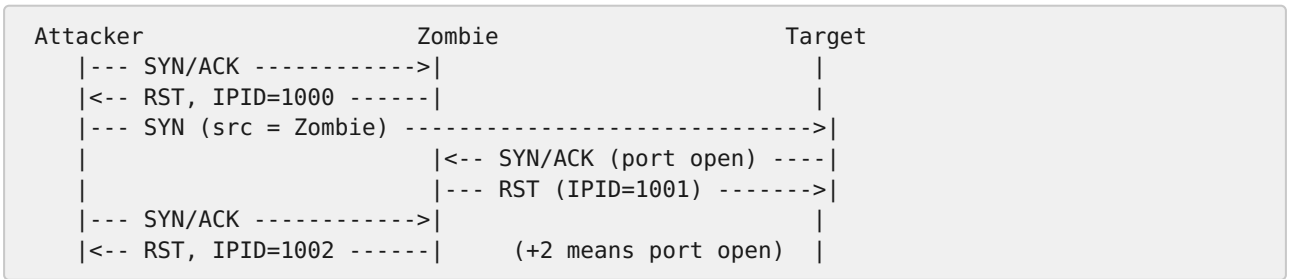
Analogy: You want to know if a house is occupied without being seen. You ask a friend (the zombie) to stand outside and count how many times the neighbor's dog barks. You send a fake letter to the house in your friend's name. If the dog barks twice instead of once, someone lived there.

Key terms:

- **IP ID (IPID):** a 16-bit number in the IP header that identifies a packet. Many systems raise it by one for every packet they send.
- **Zombie:** an idle machine with a predictable (incrementing) IPID that the attacker uses as a blind relay. It must be quiet (idle), or the counts become unreliable.

How it works (numbered steps):

1. The attacker sends an unsolicited SYN/ACK to the zombie. The zombie replies RST. The attacker reads the IPID, for example 1000.
2. The attacker sends a SYN to the target port, with the source address forged as the zombie.
3. If the target port is open, the target sends SYN/ACK to the zombie. The zombie did not start this, so it sends RST. This uses one more IPID.
4. If the target port is closed, the target sends RST to the zombie. The zombie does not reply to a RST. The IPID does not change.
5. The attacker probes the zombie again and reads the IPID.
6. IPID rose by 2 (1000 to 1002): the target port is open. IPID rose by 1 (1000 to 1001): the port is closed or filtered.



The switch parts: -Pn skips host discovery (the zombie scan needs no ping), -p- means all 65,535 ports, -sI names the zombie.

Real-world use: An attacker wants to scan a bank's server without his own IP appearing in its logs. He finds an old network printer with an incrementing IPID and uses it as a zombie. The bank's logs show the printer as the scanner.

Why it is "stealthy": The attacker's IP never reaches the target (only the spoofed zombie IP does). It can also bypass IP-based trust, because the target may accept traffic from the zombie's address (ADDED CONTEXT).

Tools: Nmap -sI. Hping3 can do it manually. Metasploit has an IPID sequence scanner to find zombie candidates (module name ADDED CONTEXT, verify: auxiliary/scanner/ip/ipidseq). The Nmap script ipidseq also tests IPID behavior (verify).

Countermeasures: Ingress filtering and egress filtering to block spoofed packets. Use operating systems with random or per-destination IPIDs (many modern systems do this, ADDED CONTEXT). Keep idle devices patched and firewalled.

> **EXAM TIP:** "Scan without revealing the attacker's IP address", "zombie", or "IPID increment" -> idle scan.

EXAM FOCUS:

- How it is asked: "Which scan uses a third-party host with a predictable IP ID?" (idle scan).
- Keywords: "zombie", "IPID", "spoofed", "blind scan", "-sI".
- Common trap: The answer is not "decoy scan". In a decoy scan the attacker's real IP is still in the mix. In an idle scan it is hidden.
- Look-alike: idle scan (-sI) vs decoy scan (-D) vs IP spoofing with hping3 (-a).

Memory trick: "Idle = I use someone Else. IPID +2 = Is open, +1 = it is shut."

3.12 UDP Scanning (-sU)

What it is: UDP scanning checks which UDP ports are open. UDP (User Datagram Protocol) has no handshake. The sender just fires a datagram and hopes. Switch on the slide: nmap -sU -v TARGET.

Analogy: You post a card with no reply envelope. If the address does not exist, the mail service may send "no such address" back (ICMP port unreachable). If the house exists and wants the card, it may never write back at all. Silence is not proof either way.

How it works (numbered steps):

1. Nmap sends a UDP packet to a port.
2. Closed port: the target sends back ICMP port unreachable (type 3, code 3).
3. Open port: the target usually sends nothing, or sends a UDP reply if the packet is a real request for that service.

4. Other ICMP unreachable codes mean "filtered".
5. No reply at all gives "open or filtered".

Key facts:

- Slow. Hosts limit how many ICMP errors they send (Linux sends about one per second), so scanning 65,535 UDP ports can take hours.
- Often combined with -sV, so the service answers a real request and the port can be confirmed open (ADDED CONTEXT).
- Often forgotten by defenders, which makes UDP services attractive targets.

Common UDP ports (ADDED CONTEXT): 53 DNS, 67 and 68 DHCP, 69 TFTP, 123 NTP, 137 and 138 NetBIOS, 161 and 162 SNMP, 500 IKE (IPsec), 514 syslog, 1900 SSDP, 5353 mDNS.

Real-world use: A tester finds nothing odd in the TCP scan. A UDP scan reveals SNMP on port 161 with a default community string. That leads to a full device configuration dump in the enumeration phase (Module 04).

Tools: Nmap -sU, Hping3 -2 (UDP mode), Netcat -u (ADDED CONTEXT), NetScanTools Pro.

Countermeasures: Block unused UDP at the firewall. Disable unneeded UDP services (SNMP v1 and v2, TFTP). Change default SNMP community strings.

EXAM FOCUS: Keywords: "ICMP port unreachable", "connectionless", "no handshake", "SNMP, DNS, TFTP". Trap: A lack of reply on UDP does not prove a port is open or closed. Look-alike: -sU (UDP port scan) vs -PU (UDP ping).

Memory trick: "UDP: U-nreachable means closed. Quiet means maybe."

3.13 SCTP Scanning: INIT (-sY) and COOKIE ECHO (-sZ)

What it is: SCTP (Stream Control Transmission Protocol) is a transport protocol like TCP and UDP. It keeps messages in order, can use several network paths (multi-homing), and carries several streams in one connection. Phone networks use it for signaling (telecom and 4G and 5G control traffic, ADDED CONTEXT). The slide lists two SCTP scans.

Analogy: SCTP is a courier company that sends several parcels in parallel lanes and has a backup route. Its handshake has four steps, not three: INIT, INIT-ACK, COOKIE-ECHO, and COOKIE-ACK. The "cookie" is a token that proves the sender is real and prevents SYN-flood style attacks.

SCTP INIT scan (nmap -sY -v TARGET):

1. Nmap sends an INIT chunk to the port.
2. INIT-ACK reply: the port is open.

3. ABORT reply: the port is closed.
4. No reply, or an ICMP unreachable error: filtered.
5. The scan never finishes the four-way handshake. It is the SCTP version of the half-open SYN scan.

SCTP COOKIE ECHO scan (nmap -sZ -v TARGET):

1. Nmap sends a COOKIE-ECHO chunk to the port without doing the first steps.
2. Closed port: the target replies ABORT.
3. Open port: the target says nothing (the packet is dropped).
4. Silence means "open or filtered". Some firewalls and IDS only watch INIT chunks, so this scan can be quieter, but it cannot separate open from filtered.

Real-world use: A telecom operator tests the core network that uses SCTP between nodes. An INIT scan finds an SCTP service exposed to the wrong network segment.

Tools: Nmap -sY and -sZ.

Countermeasures: Filter SCTP at the edge if not used. Restrict SCTP ports to known peers.

EXAM FOCUS: Keywords: "SCTP", "INIT chunk", "COOKIE ECHO", "four-way handshake". Trap: -sY is SCTP INIT, -sZ is SCTP COOKIE ECHO. Look-alike: -sY (SCTP INIT) vs -sS (TCP SYN) vs -sZ.

Memory trick: "Y comes before Z. INIT comes before COOKIE ECHO." Or: "sY = start (INIT), sZ = Zip (the last cookie)".

3.14 SSDP Scanning

What it is: SSDP (Simple Service Discovery Protocol) is how Universal Plug and Play (UPnP) devices announce themselves and are found on a network. It uses UDP port 1900 and the multicast address 239.255.255.250 (ADDED CONTEXT). The slide lists SSDP scanning as a port and service discovery technique but gives no command. SSDP scanning finds UPnP devices such as routers, smart TVs, printers, cameras, and media boxes.

Analogy: A new device joins a building and shouts "I am a printer, here is my address" to everyone. SSDP scanning is like standing in the lobby and listening to all these announcements, or shouting "Who is here?" and collecting replies.

How it works:

1. The scanner sends an SSDP M-SEARCH message to UDP 1900 (multicast or direct).
2. UPnP devices answer with a short description (device type and a URL for more details).

3. The scanner reads the description files to learn the device model, firmware, and services.

Why attackers care (ADDED CONTEXT):

- UPnP can let a program open ports on the router without a password, which an attacker can abuse.
- Old UPnP stacks have many known vulnerabilities.
- Open SSDP servers can be used for reflection and amplification DDoS attacks (Module 10).

Tools (ADDED CONTEXT, verify): Nmap scripts upnp-info and broadcast-upnp-info, Metasploit auxiliary/scanner/upnp/ssdp_msearch, gssdp-discover.

Countermeasures: Turn off UPnP on routers when not needed. Block UDP 1900 from the internet. Keep firmware updated.

EXAM FOCUS: Keywords: "UPnP", "UDP 1900", "M-SEARCH", "multicast 239.255.255.250". Trap: SSDP is not a port scan type like SYN. It is a protocol-specific discovery. Look-alike: SSDP (UPnP discovery) vs SNMP (device management, UDP 161) vs SMTP.

Memory trick: "SSDP = Simple Service Discovery, port 1900 (19-00: nineteen hundred)".

3.15 IPv6 Scanning (-6)

What it is: IPv6 is the newer addressing system (128-bit addresses written in hex, for example 2001:db8::1). Many hosts have it enabled whether or not the admin knows. Nmap scans IPv6 targets with the -6 switch. Slide command: nmap -6 TARGET-IP-OR-DOMAIN.

Analogy: A building has a new back entrance that the security staff forgot. IPv6 is often that entrance: the front door (IPv4) has guards, but the back door (IPv6) has no rules.

How it works:

1. The attacker finds the IPv6 address of a host (from DNS AAAA records, or by listening on the local network).
2. Nmap runs with -6 and any normal scan type (for example nmap -6 -sS TARGET).
3. Results are read like normal IPv4 results.

Key facts (ADDED CONTEXT):

- A single IPv6 subnet (/64) has 2^64 addresses, so a blind ping sweep is not practical.

- Attackers use DNS records (AAAA), neighbor discovery, and multicast. The all-nodes multicast address ff02::1 can reveal local hosts.
- IPv6 does not use ARP. It uses Neighbor Discovery Protocol (NDP) inside ICMPv6.
- Firewalls are often configured only for IPv4, leaving IPv6 services exposed.
- Tools: Nmap -6, THC-IPv6 toolkit (alive6, verify), Nmap script targets-ipv6-multicast-echo (verify).

Real-world use: A company firewalls its IPv4 address but not the IPv6 address of the same web server. An IPv6 scan shows SSH and a database port open.

Countermeasures: Apply the same firewall rules to IPv6 as to IPv4, or disable IPv6 where it is unused. Monitor IPv6 traffic.

EXAM FOCUS: Keywords: "-6", "128-bit", "AAAA record". Trap: Writing -6 does not change the scan type. It only enables IPv6 targets. Look-alike: -6 (IPv6) vs -n (no DNS) vs -sY.

Memory trick: "Six for IPv6."

3.16 Service Version Discovery (-sV)

What it is (simple words): After a port is found open, service version discovery finds out which program is behind it and which version it is. The slide gives three points. It helps the attacker learn which services run on a target and their versions. An accurate version number lets the attacker decide if the target is vulnerable to particular exploits. In Zenmap the -sV option detects service versions.

Analogy: Port scanning says "there is a door". Version detection says "it is a Brand X lock, model 2019". Now you can look up which keys fit that model.

How it works (numbered steps):

1. Nmap finds an open port (for example 80).
2. Nmap connects and sends probes from its service database (nmap-service-probes).
3. It reads the reply (the banner) and matches it against known patterns.
4. It prints the product name, version, and extra info (OS, device type, CPE).
5. The attacker searches exploit databases for that exact version.

The Zenmap window (page 3 screenshot): Zenmap is the Nmap graphical interface.

Part of the window	Meaning
Target	The host or range to scan
Profile	A saved set of options (for example intense scan)

Part of the window	Meaning
Command	The exact Nmap command Zenmap runs
Scan and Cancel	Start or stop the scan
Hosts and Services buttons	Left panel: list by host or by service
Nmap Output tab	Raw text result
Ports/Hosts tab	Table of ports for the selected host
Topology tab	Picture of the network path
Host Details tab	Summary of one host
Scans tab	History of past scans
Filter Hosts	Search the host list

Reading the sample result (command: nmap -sV 10.10.1.11):

```
PORT     STATE SERVICE       VERSION
21/tcp   open  ftp           Microsoft ftpd
80/tcp   open  http          Microsoft IIS httpd 10.0
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds  Microsoft Windows 7 - 10 microsoft-ds
3389/tcp open  ms-wbt-server Microsoft Terminal Services
MAC Address: 00:15:5D:01:80:00 (Microsoft)
Service Info: Host: WINDOWS11; OS: Windows
CPE: cpe:/o:microsoft:windows
```

[UNCLEAR on page 3]: The exact version text of ports 445 and 3389, the Service Info host name, and the scan time are small on the screenshot. The reading above is the best fit. The slide also shows "Not shown: 994 closed tcp ports (reset)".

How to read it: PORT is the port number and protocol. STATE is open. SERVICE is Nmap's guess from the port number. VERSION is the verified product and version. "Microsoft IIS httpd 10.0" tells the attacker the web server is IIS 10, which belongs to Windows Server 2016 or later (ADDED CONTEXT). "Service Info: OS: Windows" and the CPE give the platform in a standard format (CPE = Common Platform Enumeration, a naming scheme used by vulnerability databases). "(reset)" in "closed tcp ports (reset)" means closed ports answered with RST, which is what a SYN scan or connect-type probe sees.

Useful related options (ADDED CONTEXT, verify): --version-intensity 0 to 9 (how hard to try), --version-light, --version-all, and -A (aggressive scan: version, OS detection, default scripts, and traceroute).

Real-world use: The scan shows port 80 runs "Apache httpd 2.4.49". The tester knows that exact version has a known path traversal flaw (CVE-2021-41773, verify). He reports it as critical.

Tools: Nmap -sV, Zenmap, Netcat and Telnet (banner grabbing by hand), Metasploit scanners.

AI angle (ADDED CONTEXT): Paste the -sV output into an AI assistant and ask: "List the known risks for each service and version in this scan. Mark which versions are end of life." The AI speeds up triage. It can be wrong or out of date, so confirm each CVE (Common Vulnerabilities and Exposures number) in an official database.

Countermeasures and defense: Hide or change service banners. Remove version strings from web servers. Patch services so a known version no longer matters. Use a WAF or proxy to hide the real server.

EXAM FOCUS:

- How it is asked: "Which Nmap option detects service versions?" (-sV). "Why does an attacker need an exact version?" (to match exploits).
- Keywords: "service version", "determine the vulnerability", "banner", "-sV".
- Common trap: -sV is not -O. -O guesses the OS. -sV identifies the service product and version. Both together are in -A.
- Look-alike: -sV (version) vs -sS (SYN scan) vs -sU (UDP).

Memory trick: "V for Version". "sV = See Version."

3.17 How to Identify the Target System OS (TTL and TCP Window Size)

What it is (simple words): Every operating system sets certain header values in a slightly different way. The slide says attackers can identify the OS by looking at two values in the first packet of a TCP session: the Time To Live (TTL) and the TCP window size. The attacker captures the reply from the target with a packet sniffer such as Wireshark and reads these two fields.

- **TTL (Time To Live):** a number in the IP header that starts at a value chosen by the OS and goes down by 1 at every router. When it reaches 0 the packet is dropped. It stops packets from circling forever.
- **TCP window size:** a number in the TCP header that tells the other side how much data can be sent before waiting for an acknowledgement.
- **Sniffer:** a tool that records packets on a network (Wireshark is the example on the slide).

Analogy: Every country puts a different style of stamp on its mail. You do not need to open the letter. You look at the stamp and guess the country.

The table on the slide (learn it):

Operating system	Time To Live	TCP window size
Linux	64	5840
FreeBSD	64	65535
OpenBSD	255	16384
Windows	128	65,535 bytes to 1 gigabyte
Cisco routers	255	4128
Solaris	255	8760
AIX	255	16384

How it works (numbered steps):

1. The attacker makes the target send a packet (for example by starting a connection to an open port).
2. The attacker captures the reply with Wireshark. The first reply in a TCP session is the SYN/ACK.
3. The attacker opens the IP header and reads the TTL. He opens the TCP header and reads the window size.
4. The attacker compares both values with the table.
5. The match gives the likely OS. The slide screenshots show "Possible OS is Windows" for a packet with TTL 128 and "Possible OS is Linux" for a packet with TTL 64.

Reading a TTL that has dropped on the way (ADDED CONTEXT): The TTL you see is the starting value minus the number of routers crossed. Round up to the nearest standard start value: 64, 128, or 255. A TTL of 117 means start 128 (Windows) about 11 hops away. A TTL of 52 means start 64 (Linux or FreeBSD) about 12 hops away.

A packet in Wireshark looks like this (representative sample):

```
Internet Protocol Version 4, Src: 10.10.1.11, Dst: 10.10.1.9
    Time to Live: 128
    Protocol: TCP (6)
Transmission Control Protocol, Src Port: 80, Dst Port: 51234
    Flags: 0x012 (SYN, ACK)
    Window: 65535
```

Line 2 is the TTL (128 -> Windows). The Flags line shows SYN, ACK, so this is the first reply of the session. The Window line gives the second clue.

Wireshark display filters you may need (ADDED CONTEXT): ip.ttl == 128 shows packets with that TTL. tcp.flags.syn == 1 and tcp.flags.ack == 1 shows SYN/ACK packets. ip.src == 10.10.1.11 limits the view to one host.

Limits (ADDED CONTEXT): The table is a guide, not proof. Admins can change the TTL. Newer systems use other window sizes (verify for modern Linux and Windows).

Firewalls and proxies can rewrite packets. Use Nmap -O or banner grabbing for a stronger answer.

Real-world use: A tester captures the traffic to a mystery host. TTL is 255 and window is 4128. By the table it is a Cisco router, not a server. She plans a router test, not a web server test.

Tools: Wireshark (passive reading), p0f (automatic passive fingerprinting, ADDED CONTEXT), Nmap -O (active fingerprinting), Xprobe2 (ADDED CONTEXT).

Countermeasures and defense: Change default TTL and TCP stack settings so the OS is harder to guess. Use a firewall or reverse proxy so the attacker sees the proxy and not the real server. This slows guessing but does not stop a determined attacker.

> **EXAM TIP:** Memorize three TTL groups: 64 (Linux, FreeBSD), 128 (Windows), 255 (OpenBSD, Cisco, Solaris, AIX). Questions often give only the TTL.

EXAM FOCUS:

- How it is asked: "A captured packet has TTL 128. What OS is likely?" (Windows). "Which two fields help identify the OS?" (TTL and TCP window size).
- Keywords: "first packet in a TCP session", "Wireshark", "TTL", "window size".
- Common trap: TTL 64 is both Linux and FreeBSD. The window size separates them (5840 vs 65535 on the slide).
- Look-alike: passive fingerprinting (sniffing) vs active fingerprinting (sending probes, Nmap -O).

Memory trick: "Linux has 64 legs, Windows has 128 windows, routers shout 255." Window sizes: Linux 5840 is the odd small one; FreeBSD 65535 is the biggest "normal" one.

3.18 Packet Fragmentation

What it is (simple words): Packet fragmentation splits a probe packet into several smaller packets (fragments) while sending it to a network. The slide says it is not a new scanning method but a modification of the earlier techniques. The TCP header is split into several packets so that packet filters are not able to detect what the packets are meant to do.

Analogy: You want to smuggle a long sentence past a guard who only reads whole sentences. You cut it into single words and send each word on a different card. The guard sees harmless words. The receiver puts them back in order.

Key terms:

- **MTU (Maximum Transmission Unit):** the largest packet a link carries. Ethernet is usually 1500 bytes.

- **Fragment:** a piece of an IP packet. The receiver reassembles the pieces into the original.
- **Packet filter:** a simple firewall that checks each packet by itself (address, port, flags).

How it works (numbered steps):

1. The attacker prepares a normal probe, for example a SYN or FIN packet to port N.
2. The tool cuts the TCP header (and any data) into tiny IP fragments. The first fragment may be too short to hold the port number or flags.
3. A simple filter that inspects each fragment alone cannot read the full header. It lets the fragments through.
4. The target host reassembles the fragments into the original probe and answers it.
5. A closed port replies RST. The attacker reads the reply as in a normal scan.

```
Attacker                                          Target
   |                                                |
   |-- SYN/FIN as small IP fragments + port (n) ----->|
   |                                                |
   |<------------- RST (if port is closed) ----------|
```

The Nmap switches (ADDED CONTEXT, from the Nmap reference guide):

Switch	Meaning	Detail
-f	Fragment packets	Splits into 8 bytes or less after IP header
-f -f	Fragment more coarsely	16 bytes per fragment
--mtu N	Set your own fragment size	N must be a multiple of 8

With -f, a 20-byte TCP header becomes three fragments (8 + 8 + 4 bytes). The command in the Zenmap screenshot (page 4) is [UNCLEAR on page 4]. The best reading is nmap -f with the target 10.10.1.11. The output on the slide shows a warning line about packet fragmentation and many "Initiating" and "Completed" lines. This is what a verbose scan prints.

Limits (ADDED CONTEXT):

- Works only with raw packet scans (SYN, FIN, NULL, Xmas, ACK, UDP) and OS detection. It does not apply to -sT connect scans or version detection (-sV), which use the host's normal TCP stack.
- Firewalls that reassemble all fragments before inspection defeat it. Some systems cannot afford to do that, so they stay vulnerable.
- Some old devices crash on tiny fragments.

Real-world use: A tester finds an old router with a stateless packet filter. A normal SYN scan is dropped. The same scan with -f gets through, and port 22 is found open.

Tools: Nmap -f and --mtu, Hping3 (fragmentation options, verify), fragroute and fragrouter (ADDED CONTEXT, verify).

Countermeasures and defense: Reassemble fragments at the firewall before inspection. Drop very small fragments and overlapping fragments. Use an IDS that reassembles fragments (and so sees the whole packet). Keep firewall firmware updated (this also appears in 3.29).

> **EXAM TIP:** If the question says "splits the TCP header across multiple packets", the answer is packet fragmentation (nmap -f).
>
> **TRAP:** Fragmentation is not a separate scan type like SYN or FIN. It changes how any raw scan is sent.

EXAM FOCUS:

- How it is asked: "Which technique splits the probe so a packet filter cannot read the header?" (fragmentation). "What does nmap -f do?" (fragment packets).
- Keywords: "smaller packets", "fragments", "tiny", "evade IDS".
- Common trap: Fragmentation vs segmentation. IP fragments are Layer 3 pieces. TCP segments are Layer 4 pieces.
- Look-alike: fragmentation (-f) vs decoy (-D) vs bad checksum (--badsum).

Memory trick: "f = fragment" and "-f -f = fatter fragments (16)". Fragment size is always a multiple of 8.

3.19 Source Port Manipulation

What it is (simple words): Source port manipulation means replacing the real source port number of your probes with a common, trusted one, to get past a firewall or IDS. The slide explains the weakness. A firewall may be configured to allow packets from well-known ports such as HTTP (80), DNS (53), and FTP (21 and 20). If the attacker makes his probes come from one of these ports, the firewall lets them pass. Nmap uses the -g or --source-port option.

Analogy: A guard lets in everyone wearing a delivery company uniform. The attacker puts on the uniform. The guard checks the uniform, not the person.

How it works (numbered steps):

1. The attacker finds that the firewall blocks probes from his normal random source port (the slide example uses port 242).
2. He sets the source port to a trusted number such as 80 with nmap -g 80 TARGET.
3. The firewall sees traffic that looks like a web server reply and allows it.
4. The probe reaches the victim. The victim answers, and the attacker reads the result as usual.

```
Attacker                Firewall                    Victim
   |-- source port 242 ---->| X  (blocked)              |
   |-- source port 80  ---->|--- allowed --------------->|
```

Reading the page 5 screenshot (command nmap -g 80 10.10.1.11 in Zenmap):

```
Starting Nmap 7.94 ( https://nmap.org ) at 2024-03-12 00:53 Pacific
Nmap scan report for 10.10.1.11
Host is up (0.00042s latency).
Not shown: 994 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
80/tcp   open  http
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
MAC Address: 00:15:5D:01:80:00 (Microsoft)
Nmap done: 1 IP address (1 host up) scanned in 1.65 seconds
```

[UNCLEAR on page 5]: the latency value is small. Line "Not shown: 994 closed" plus six open ports equals the 1000 default ports. The scan finished in about 1.65 seconds, which is fast because nothing blocked it.

Limits (ADDED CONTEXT): The option works for raw scans such as SYN and UDP. It has no effect on TCP connect scans (-sT), version detection (-sV), script scanning, or OS detection, because those use normal operating system sockets or need their own ports.

Real-world use: A firewall allows DNS replies from outside, so it allows any packet with source port 53. The tester runs nmap -sS -g 53 on the internal servers behind it. Ports that were filtered before now answer, and the internal SMB and RDP ports show as open.

Tools: Nmap -g and --source-port, Hping3 -s (set the base source port, with -k to keep it fixed, verify), Netcat -p (ADDED CONTEXT).

Countermeasures and defense: Never trust traffic only because of its source port. Use a stateful firewall that tracks real sessions. Use application-layer proxies for DNS and FTP. Check that routing and filtering cannot be bypassed with a particular source port (this is item 3 in the countermeasure slide, 3.29).

> **EXAM TIP:** "Firewall allows packets from well-known ports" + "-g" = source port manipulation.

EXAM FOCUS:

- How it is asked: "Which Nmap option sets the source port?" (-g or --source-port). "What weakness does source port manipulation exploit?" (firewall rules that trust well-known source ports).
- Keywords: "manipulating actual port numbers with common port numbers", "HTTP, DNS, FTP", "-g".
- Common trap: -g sets the SOURCE port. -p sets the DESTINATION ports to scan.
- Look-alike: -g (source port) vs -p (ports to scan) vs --spoof-mac.

Memory trick: "g = Go in as a Guest on port 80 (a trusted port)". "Source = where I come from. Port 80 is a friendly place to come from."

3.20 IP Address Spoofing

What it is (simple words): IP spoofing means changing the source IP address of your packets so the attack appears to come from someone else. The slide gives three facts. When the victim replies, the reply goes back to the spoofed address, not to the attacker's real address. Attackers modify the address information in the IP packet header (the source address field) to bypass the IDS or firewall. And the slide's note: you will not be able to complete the three-way handshake and open a successful TCP connection with spoofed IP addresses.

Analogy: You write a letter and put a false return address on the envelope. The receiver's answer goes to the false address. You never read it. That is fine if you only wanted to send a message, not to hold a conversation.

The slide example: The command is shown as hping3 www.certifiedhacker.com -a 7.7.7.7. The attacker sends a packet with the spoofed address 7.7.7.7. The victim is shown as 5.5.5.5. The victim answers to 7.7.7.7, which is the real owner of that address.

```
Attacker ---- packet (src = 7.7.7.7) ----> Victim (5.5.5.5)
                                                |
Real owner of 7.7.7.7 <---- reply -----------+
(the attacker never sees the reply)
```

How it works (numbered steps):

1. The attacker chooses the address to fake (an innocent host, a trusted internal host, or a random address).
2. A crafting tool such as Hping3 writes that address into the source field of every packet.
3. The packet travels to the victim. The firewall or IDS logs the fake address.
4. The victim sends its reply to the fake address.
5. The attacker does not see the reply unless he is on the path. So the handshake cannot be completed from his machine.

Hping3 command breakdown: hping3 is the program. www.certifiedhacker.com is the target. -a 7.7.7.7 (also written --spoof) sets the fake source address.

What spoofing is good for:

- Hiding the attacker's identity in logs.
- Bypassing rules that trust certain IP addresses (IP-based authentication).
- Denial of service: floods from random fake sources, or reflection attacks where replies go to the victim (Module 10).
- Blind scans such as idle scan (3.11).
- Decoy scanning (3.25).

Blind and non-blind spoofing (ADDED CONTEXT): In blind spoofing the attacker is on a different network and cannot see replies. He may guess the TCP sequence numbers to inject data. In non-blind spoofing the attacker is on the same segment and can see the replies, so session hijacking is possible (Module 11).

Real-world use: An attacker sends SYN packets to a server with the source forged as the company's own admin PC (10.10.1.5). The firewall allows traffic from that address. The attacker uses it to probe internal ports. Ingress filtering would drop it (3.30).

Tools: Hping3 -a, Hping3 --rand-source (random source for each packet, verify), Nmap -S (spoof source address) with -e (interface) and -Pn (ADDED CONTEXT), Colasoft Packet Builder, Scapy.

Countermeasures and defense: The full list is in 3.30: encryption, multiple firewalls, no IP-based authentication, random initial sequence numbers, ingress filtering, egress filtering.

> **TRAP:** Spoofing does not give the attacker a working TCP connection. Without seeing the SYN/ACK he cannot send the final ACK. That is why it suits scans, floods, and one-way attacks.

EXAM FOCUS:

- How it is asked: "Which technique changes the source IP so the attack looks like it came from another host?" (IP spoofing). "Which tool is used to spoof an IP in the slide example?" (Hping3 -a).
- Keywords: "appears to be coming from someone else", "reply goes to spoofed address", "source address bits".
- Common trap: IP spoofing vs MAC spoofing. IP spoofing changes Layer 3. MAC spoofing changes Layer 2 (3.26).
- Look-alike: IP spoofing vs IP decoy. In a decoy scan the real IP is also in the mix. In pure spoofing it is replaced.

Memory trick: "-a = Alias address". "Spoof the Source, but the Sequel (reply) goes to the Stranger."

3.21 Creating Custom Packets

What it is (simple words): Attackers build their own TCP packets with packet crafting tools. They choose every field in the headers (flags, ports, TTL, checksum, options). The slide says attackers create custom TCP packets using tools such as Colasoft Packet Builder and NetScanTools Pro to scan a target beyond a firewall.

Analogy: A normal scanner is a ready-made key. A packet crafter is a locksmith workshop. You cut the key to the exact shape the lock needs.

How it works (numbered steps):

1. The attacker studies the firewall (for example, which flags and ports it allows).
2. In the packet builder he sets the protocol, addresses, ports, flags, TTL, and payload.
3. He sends the packet once or in a batch.
4. He reads the reply (or the silence) and adjusts the next packet.

Colasoft Packet Builder (page 6 screenshot): A Windows tool for creating and editing packets. The screenshot shows these parts:

Part	Meaning
Menu and toolbar	Import, Export, Add, Insert, Copy, Delete
Checksum, Send, Send All	Fix checksums, send one or all packets
Decode Editor	Edit each header field (Ethernet, IP, TCP, and others)
Packet List	The packets queued for sending
Hex Editor	Edit the raw bytes

The sample packet in the screenshot is a template with an Ethernet header and an ARP section. [UNCLEAR on page 6]: field values are small. You do not need them for the exam.

NetScanTools Pro: Named on this slide and on the overview slide. It includes packet generation tools as well as ping and port scanners.

A simple custom packet with Scapy (ADDED CONTEXT):

```
from scapy.all import IP, TCP, sr1

pkt = IP(dst="10.10.1.11") / TCP(dport=80, flags="F")
reply = sr1(pkt, timeout=2)
print(reply.summary() if reply else "no reply (open or filtered)")
```

Line 3 builds an IP packet to 10.10.1.11 with a TCP layer that sets only the FIN flag. Line 4 sends it and waits for one reply. Line 5 prints the reply, or says there was none. This is a hand-made FIN scan of one port.

AI angle (ADDED CONTEXT): An AI assistant can write such scripts. Example prompt: "Write a Scapy script that sends a TCP packet with only the FIN flag to port 80 of 10.10.1.11 and prints the reply. This is for an authorized lab test." The attacker side uses this to create new probe types faster. The defender side uses it to test whether the firewall drops odd packets.

Real-world use: A firewall blocks all packets with SYN but passes packets that belong to "established" connections. The tester crafts an ACK-only packet to map which ports respond.

Tools: Colasoft Packet Builder, NetScanTools Pro, Hping3, Scapy, Nping, Nemesis, and Ostinato (the last four are ADDED CONTEXT).

Countermeasures and defense: A stateful firewall drops packets that do not fit a known connection. Deep packet inspection and an IDS flag malformed or odd packets. Test your own firewall with the same tools.

EXAM FOCUS:

- How it is asked: "Which tool creates custom TCP packets to scan beyond a firewall?" (Colasoft Packet Builder).
- Keywords: "packet crafting", "custom TCP packets", "packet builder".
- Common trap: Wireshark reads packets. Colasoft Packet Builder creates packets. Hping3 and Scapy do both on the command line.
- Look-alike: Colasoft Packet Builder (create packets) vs Colasoft Ping Tool (ping many hosts).

Memory trick: "Builder builds. Wireshark watches."

3.22 OS Discovery and Banner Grabbing

What it is (simple words): Banner grabbing, also called OS fingerprinting, is the method used to find out which operating system runs on a remote target. A banner is the short text a service shows about itself when you connect (name and version). The slide says there are two types: active and passive. Knowing the OS lets the attacker figure out the vulnerabilities of the system and the exploits that might work, so he can carry out further attacks.

Analogy: Active banner grabbing is asking a stranger, "What company do you work for?" Passive banner grabbing is reading the badge on his jacket without speaking.

Active banner grabbing (slide):

1. Specially crafted packets are sent to the remote OS and the responses are noted.
2. The responses are compared with a database to determine the OS.
3. Responses from different operating systems vary because of differences in the TCP/IP stack implementation.

Passive banner grabbing (slide):

1. **Banner grabbing from error messages:** Error messages give information such as server type, type of OS, and the SSL tool used by the target remote system.
2. **Sniffing the network traffic:** Capturing and analyzing packets from the target lets the attacker determine the OS (this is the Wireshark method in 3.17).
3. **Banner grabbing from page extensions:** Looking at the extension in the URL can show the application version. Example from the slide: .aspx => IIS server and Windows platform.

The slide note says passive banner grabbing is discussed in later modules (hacking web servers, Module 13).

Comparison:

Feature	Active	Passive
Sends packets to target	Yes	No
Can be detected	Yes, by the target	Very hard to detect
Speed and accuracy	Fast, usually more accurate	Slower, depends on traffic seen
Examples	Nmap -O, Telnet, Netcat	Wireshark, p0f, error pages

Examples of banners (ADDED CONTEXT):

An error page (passive, from a normal browser visit):

```
Not Found
The requested URL /abc was not found on this server.
Apache/2.4.41 (Ubuntu) Server at example.com Port 80
```

This footer tells the attacker the web server is Apache 2.4.41 on Ubuntu Linux.

A manual connection with Netcat (active):

```
nc -v 10.10.1.11 80
HEAD / HTTP/1.0
```

```
HTTP/1.1 200 OK
Server: Microsoft-IIS/10.0
X-Powered-By: ASP.NET
```

You type the HEAD line and press Enter twice. The Server header names IIS 10.0 and the X-Powered-By header names ASP.NET, so the host is Windows.

Page extension hints: .aspx means ASP.NET on IIS (Windows). .php means PHP (often Linux). .jsp means Java. .cfm means ColdFusion.

How active OS detection works inside Nmap (ADDED CONTEXT): The switch is nmap -O. Nmap sends about a dozen special TCP, UDP, and ICMP probes. It measures the initial TTL, the window size, TCP option order, the Don't Fragment bit, and how the stack answers odd packets. It compares the results with a database of fingerprints. Related switches: --osscan-guess (guess when no perfect match), --osscan-limit (only try hosts with open and closed ports found), and -A (OS, version, scripts, traceroute).

Real-world use: A tester sees IIS 10.0 in a header and .aspx in the URLs. She concludes Windows Server and checks Windows and IIS exploits first. A different tester sees "Apache/2.4.41 (Ubuntu)" and moves to Linux checks.

Tools: Nmap -O, Telnet, Netcat, curl -I, Wireshark, p0f, Xprobe2, ID Serve (the last four are ADDED CONTEXT; verify any tool you plan to use), Netcraft for web servers (Module 02).

AI angle (ADDED CONTEXT): The v13 course shows AI tools such as ShellGPT for OS discovery. Example prompt: "Give me an Nmap command to guess the OS of 10.10.1.11 and also detect service versions." Answer: sudo nmap -O -sV 10.10.1.11 (or nmap -A). An AI assistant can also read a banner and explain what it means. The tester must still confirm the guess with a second method.

Countermeasures and defense (ADDED CONTEXT):

- Remove or change service banners (for example Apache ServerTokens Prod and ServerSignature Off; remove the X-Powered-By header on IIS).
- Use custom error pages that show no server details.
- Hide or change file extensions (use clean URLs).
- Place a reverse proxy or WAF in front of servers.
- Patch systems so a known OS and version does not matter.

> **EXAM TIP:** Both words are the same thing on the slide: "banner grabbing or OS fingerprinting". Two types: active and passive.
>
> **TRAP:** Sniffing network traffic is a passive method, even though the attacker may be actively watching.

EXAM FOCUS:

- How it is asked: "Which is an example of passive banner grabbing?" (error messages, sniffing, page extensions). "Which is active?" (sending crafted packets and comparing responses to a database).
- Keywords: ".aspx", "error messages", "crafted packets", "TCP/IP stack differences", "database".
- Common trap: Active methods can be logged by the target. Passive methods leave no trace on the target.
- Look-alike: banner grabbing (services and OS) vs service version discovery (-sV). They overlap. The slide treats banner grabbing as OS focused.

Memory trick: "Passive = Peek (errors, sniffing, extensions). Active = Ask (crafted packets)." Three passive items: "E-S-E" = Errors, Sniffing, Extensions.

3.23 Scanning Beyond IDS and Firewall (Overview of Evasion Techniques)

What it is (simple words): Firewalls and IDSs can stop malicious packets from entering a network. The slide says attackers can still manage to send their intended packets to the target by evading the IDS or firewall with ten techniques.

- **Firewall:** a device or program that allows or blocks traffic by rules (addresses, ports, protocols, connection state).
- **IDS (Intrusion Detection System):** a system that watches traffic and raises alerts when it sees an attack pattern. An IPS (Intrusion Prevention System) also blocks it. Module 12 covers both in depth.

Analogy: A building has a guard (firewall) and a camera room (IDS). The ten techniques are ten ways to fool them: wear a disguise, come in many small pieces, use a side entrance, go with a crowd, or send someone else.

The ten techniques on the slide:

No.	Technique	Core idea	Section
1	Packet Fragmentation	Split the probe into tiny pieces	3.18
2	Source Routing	Choose the packet's path yourself	3.24
3	Source Port Manipulation	Use a trusted source port	3.19
4	IP Address Decoy	Hide among fake scanners	3.25
5	IP Address Spoofing	Use a fake source IP	3.20
6	MAC Address Spoofing	Use a fake hardware address	3.26
7	Creating Custom Packets	Build packets the filter does not expect	3.21
8	Randomizing Host Order and Bad Checksums	Break patterns, test filter checks	3.27
9	Proxy Servers	Scan through an intermediary	3.28
10	Anonymizers	Hide the origin of the traffic	3.28

How the techniques map to Nmap (use this as a quick recall):

Technique	Nmap switch or tool
Fragmentation	-f or --mtu
Source routing	--ip-options (L or S)
Source port manipulation	-g or --source-port
Decoy	-D
IP spoofing	Hping3 -a, Nmap -S
MAC spoofing	--spoof-mac
Custom packets	Colasoft Packet Builder, NetScanTools Pro
Random host order	--randomize-hosts
Bad checksums	--badsum
Proxy	--proxies, proxychains

Real-world use: A tester is asked to check whether the client's IDS notices scanning. She runs a plain scan (alerts), then a fragmented scan, then a decoy scan. The IDS misses the fragmented one. The client learns to enable fragment reassembly.

Countermeasures and defense: See 3.29 and 3.30. The common idea: use a stateful firewall, reassemble fragments, block source routing, and filter spoofed addresses.

> **EXAM TIP:** If the question lists "Packet fragmentation, source routing, source port manipulation, IP address decoy, IP address spoofing, MAC address spoofing, creating custom packets, randomizing host order, proxy servers, anonymizers", the topic is "scanning beyond IDS and firewall".

EXAM FOCUS: Keywords: "evade", "bypass IDS", "intended packets". Trap: Questions often ask "which is NOT an IDS evasion technique". Banner grabbing and ping sweeps are not on this list. Look-alike: evasion (hide the scan) vs anti-forensics (hide traces after access, clearing tracks).

Memory trick: "Fred Sells Sixty Decoys, Ian Makes Cheap Rubber Pigs, Always" -> Fragmentation, Source routing, Source port, Decoy, IP spoofing, MAC spoofing, Custom packets, Randomize and bad checksum, Proxies, Anonymizers.

3.24 Source Routing

What it is (simple words): Normally, each router on the way looks at the destination IP address and chooses the next hop by itself. Source routing lets the sender fix some or all of the route inside the packet. The slide says the attacker makes some or all of these decisions that the routers would normally make. The aim is to

send the packet around the firewall or IDS-configured routers to reach the intended destination.

Analogy: A taxi driver normally picks the road. In source routing, the passenger hands the driver a written list of streets. The driver must follow it, even if it avoids the checkpoint on the main road.

The slide figure: The sender A cannot reach the destination F through the direct path, because a firewall (marked X) blocks it between A and E. So A writes the route A -> B -> C -> D -> E -> F into the packet. The packet goes around the firewall through B, C, and D, and arrives at E and then F.

```
A (sender) ---X---[ FIREWALL ]---> E ---> F (destination)
|                                  ^
v                                  |
B -------------> C -------------> D
      (route chosen by the sender)
```

How it works (numbered steps):

1. The attacker adds a source route option to the IP header with a list of router addresses.
2. Each listed router passes the packet to the next address on the list, not to the one its routing table prefers.
3. The path avoids the router or firewall that has the blocking rules.
4. The packet reaches the target. The reply may return by the reverse route.

Two kinds (ADDED CONTEXT):

Kind	IP option	Rule
Loose Source Routing (LSRR)	Option 131	Packet must visit listed hops in order, others allowed between
Strict Source Routing (SSRR)	Option 137	Packet must use exactly the listed hops

The option numbers are ADDED CONTEXT (verify against RFC 791).

In Nmap and other tools (ADDED CONTEXT): Nmap has --ip-options. The letter L followed by addresses requests loose source routing, and S requests strict. Example: nmap --ip-options "L 10.10.1.2 10.10.1.3" TARGET. On Linux, traceroute -g ADDRESS sets a gateway for loose source routing (verify). Many routers now drop source-routed packets by default.

Real-world use: A firewall blocks the attacker's address but sits only on the main route. The attacker lists an intermediate router that connects to the internal network, so the packet never crosses the filtering firewall (only works if routers honor source routing).

Countermeasures and defense: Turn off IP source routing on all routers and hosts (on Cisco devices the command is no ip source-route). Drop packets with source route options at the edge. Make sure filtering cannot be bypassed with source routing (item 3 on the port scanning countermeasure slide, 3.29).

EXAM FOCUS:

- How it is asked: "Which technique lets the sender specify the path a packet takes to avoid the firewall?" (source routing).
- Keywords: "specified route", "originator dictates the route", "next hop", "chooses".
- Common trap: Source routing is decided by the sender. Normal routing is decided by each router.
- Look-alike: source routing vs source port manipulation vs source address spoofing. All three start with "source" but differ: route (path), port (number), address (IP).

Memory trick: "Source routing = Sender is the Satnav."

3.25 IP Address Decoy

What it is (simple words): The IP address decoy technique generates or manually names the IP addresses of decoys, to evade an IDS or firewall. The slide explains the result. It appears to the target that the decoys, as well as the real host, are scanning the network. This makes it difficult for the IDS or firewall to say which IP address was truly scanning and which were decoys.

Analogy: A thief walks into a shop together with ten other people who all pick up items and walk about. The guard sees eleven suspicious people and cannot tell who the thief is.

Nmap has two ways (slide):

Command	Meaning
nmap -D RND:10 TARGET	Generate random decoys (10 of them with RND: 10)
nmap -D decoy1,decoy2,decoy3 TARGET	Name the decoy addresses by hand

The slide says the first form "generates a random number of decoys". Precisely, RND:N makes N random addresses, so RND:10 makes 10 (ADDED CONTEXT, from the Nmap reference guide).

How it works (numbered steps):

1. Nmap builds probes for the target. For each probe it also sends copies with the source address of each decoy.
2. The probes from the real address are mixed in among the decoy probes.

3. The target (and its IDS) logs scans from many addresses at once.
4. Replies to decoy probes go to the decoy hosts. Only replies to the real probes reach the attacker.
5. The log analyst cannot easily pick out the real scanner.

Extra decoy tips (ADDED CONTEXT): You can include ME in the list to choose the position of your real address, for example -D decoy1,decoy2,ME,decoy3. Decoys should be real, running hosts. If decoys are down, the target may be unintentionally SYN-flooded and your real address stands out because it is the only one that answers. Too many decoys slow the scan. Decoys do not work with connect scans (-sT) or version detection.

Reading the page 8 screenshot (nmap -D RND:10 10.10.1.11):

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-03-08 07:13 EST
Nmap scan report for 10.10.1.11
Host is up (0.00067s latency).
Not shown: 995 filtered tcp ports (no-response)
PORT     STATE SERVICE
80/tcp   open  http
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
MAC Address: 00:15:5D:01:80:00 (Microsoft)
Nmap done: 1 IP address (1 host up) scanned in 4.93 seconds
```

How to read it: Five ports are open and 995 are "filtered (no-response)", so 995 + 5 = 1000. Port 21 (FTP), which appeared in other scans of this host, is not listed here, so it is in the filtered group. This often happens when decoy traffic confuses the filter or replies are lost. The scan took 4.93 seconds, slower than the 1.65 seconds of the source-port scan, because decoy packets add traffic and Nmap waits on unanswered probes. [UNCLEAR on page 8]: the latency and port 21 status are small on the screenshot.

Real-world use: A red team member runs nmap -sS -D RND:10 against a client. The client's IDS shows eleven different addresses scanning. The SOC (security operations center) must investigate all of them. The real source is hidden for a while.

Tools: Nmap -D. Hping3 can also send packets with random sources (--rand-source).

Countermeasures and defense: Correlate scans by timing and TTL, since decoys come from different distances. Use router path tracing to find the real source. Egress and ingress filtering stop many spoofed decoy packets from crossing the internet.

> **EXAM TIP:** Nmap decoy switch is capital -D. Do not confuse it with lowercase -d (debug).

EXAM FOCUS:

- How it is asked: "Which Nmap option makes a scan appear to come from several IP addresses?" (-D).
- Keywords: "decoys as well as the host are scanning", "difficult for the IDS to determine".
- Common trap: A decoy scan does not hide the real address completely. It hides it among many.
- Look-alike: decoy (-D, your real IP is among many) vs idle scan (-sI, your real IP never reaches the target) vs IP spoofing (-S, you replace your IP).

Memory trick: "D = Decoy = Duck crowd. Hide the real duck among ten fake ducks."

3.26 MAC Address Spoofing

What it is (simple words): MAC address spoofing changes the MAC (Media Access Control) address that your packets use. A MAC address is the hardware address of a network card, six bytes written like 00:15:5D:01:80:00. The first three bytes are the vendor code (OUI, Organizationally Unique Identifier). The slide (page 8, title cropped) shows an Nmap scan that uses the --spoof-mac option with the vendor name Dell. [UNCLEAR on page 8]: the title of this slide is cut off in the screenshot. The content clearly shows a MAC spoofing demonstration, which fits slide 25's list.

Analogy: A building lets in only people who carry a company badge. The attacker prints a copy of someone else's badge and walks in.

The command in the screenshot:

```
nmap -sT -Pn --spoof-mac Dell 10.10.1.11
```

Breakdown: nmap = program. -sT = TCP connect scan. -Pn = skip host discovery. --spoof-mac Dell = use a MAC address from a Dell vendor prefix. 10.10.1.11 = the target.

--spoof-mac argument formats (ADDED CONTEXT, from the Nmap reference guide):

Argument	Result
0	A completely random MAC address
A full MAC such as 01:02:03:04:05:06	Use exactly that address
A partial hex string (prefix)	Prefix is used and the rest is random
A vendor name such as Dell or Apple	A vendor prefix plus random bytes

Reading the screenshot output:

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-03-12 04:54 EDT
Spoofing MAC address 00:00:97:A2:AE:71 (Dell EMC)
You have specified some options that require raw socket access.
These options will not be honored for TCP Connect scan.
Nmap scan report for 10.10.1.11
Host is up (0.00030s latency).
Not shown: 994 closed tcp ports (conn-refused)
PORT     STATE SERVICE
21/tcp   open  ftp
80/tcp   open  http
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
Nmap done: 1 IP address (1 host up) scanned in 1.74 seconds
```

Line 2 shows Nmap picked a Dell EMC address (the prefix 00:00:97 belongs to Dell EMC). Lines 3 and 4 are the key teaching point. Spoofing a MAC needs raw packets. A TCP connect scan (-sT) uses the OS's normal connect call, so the spoofed MAC is NOT used. Nmap prints the warning to say so. "conn-refused" in the Not shown line is the connect-scan wording for closed ports (a SYN scan says "reset"). To make the spoof work, use a raw scan such as -sS (ADDED CONTEXT). Note also that no MAC Address line appears in the result, because the connect scan does not read it.

Limits (ADDED CONTEXT): MAC addresses are only used inside one local network (Layer 2). A router replaces them at every hop, so a spoofed MAC is useless across the internet. It matters when the attacker is on the same LAN or Wi-Fi as the target.

What it helps with (ADDED CONTEXT):

- Bypass MAC filtering (Wi-Fi MAC allow lists, switch port security, DHCP reservations).
- Pretend to be a trusted device (a printer or an IP phone).
- Hide the real network card vendor.
- Avoid being tracked by MAC in logs.

Real-world use: A guest network lets in only registered device MACs. The attacker sniffs a registered laptop's MAC and sets his own card to the same address. The network accepts him.

Tools: Nmap --spoof-mac, macchanger (Linux), Technitium MAC Address Changer and SMAC (Windows) (the last three are ADDED CONTEXT; verify).

Countermeasures and defense (ADDED CONTEXT): Do not rely on MAC filtering as the only control. Use 802.1X (port-based authentication), switch port security with sticky MACs, Dynamic ARP Inspection, DHCP snooping, and alerts when a MAC appears on two ports.

EXAM FOCUS:

- How it is asked: "Which Nmap option spoofs the MAC address?" (--spoof-mac). "At which layer does MAC spoofing work?" (Data link, Layer 2).
- Keywords: "hardware address", "vendor name", "raw socket", "local network".
- Common trap: MAC spoofing and IP spoofing are different layers. A question about "bypass MAC filtering" is MAC spoofing.
- Look-alike: --spoof-mac vs -S (spoof source IP) vs -g (source port).

Memory trick: "MAC = Machine's Address Card. --spoof-mac Dell = wear a Dell badge."

3.27 Randomizing Host Order and Sending Bad Checksums

3.27.1 Randomizing Host Order (--randomize-hosts)

What it is: Attackers scan the hosts of a target network in random order, so that a target behind a firewall is not hit in a clear pattern. Nmap switch: nmap --randomize-hosts TARGET. Normally Nmap walks through addresses in order (10.10.1.1, .2, .3, and so on). That orderly pattern is easy for an IDS to spot.

Analogy: A burglar who tries door 1, door 2, door 3 in a row is easy to catch on camera. A burglar who tries doors in random order, with pauses, looks like normal visitors.

How it works (numbered steps):

1. The attacker gives a list or range of targets.
2. Nmap shuffles the order of the hosts (in groups of up to 16,384 hosts, ADDED CONTEXT).
3. Probes reach hosts out of order, so there is no clear sequence for the IDS to match.
4. The attacker also uses slow timing to spread probes in time (ADDED CONTEXT: -T0 paranoid and -T1 sneaky are the slowest).

The screenshot (page 9): It runs nmap --randomize-hosts 10.10.1.11. The output is the normal list of 21, 80, 135, 139, 445, and 3389 open, with 994 closed (reset), done in about 1.63 seconds. With a single host, no visible shuffling can happen. The point of the demonstration is the command.

Countermeasures: Use IDS rules that count probes from one source over a longer time window, not just in sequence. Correlate logs.

3.27.2 Sending Bad Checksums (--badsum)

What it is: A checksum is a small number computed from the packet. The receiver recalculates it to check that the packet is not damaged. Attackers send packets with

bad or bogus TCP or UDP checksums to the intended target, to avoid certain firewall rulesets. The slide text says "TCP/UPD", which is a typo for TCP/UDP. Nmap switch: nmap --badsum TARGET.

Analogy: You send a parcel with a wrong seal number. A proper recipient throws it away. But a lazy mail sorter who does not check seals may stamp it and reply.

How it works (numbered steps):

1. Nmap sends probes with an invalid checksum.
2. A real host's TCP/IP stack checks the checksum, finds it wrong, and silently drops the packet. No reply.
3. A firewall or IDS that does not verify checksums may process the packet and reply (or log it) anyway.
4. So any reply to a bad-checksum probe is likely to have come from a firewall or IDS, not from the real host.
5. The attacker learns that a filtering device is present and where it is.

The screenshot (page 9): It runs nmap --badsum on the target. The output says "All 1000 scanned ports ... are in ignored states" and "Not shown: 1000 filtered tcp ports (no-response)". It took about 23 seconds (slow, because Nmap retried and waited for replies that never came). [UNCLEAR on page 9]: the host address and the exact time are small. Reading it: no port answered. The real host dropped every bad packet, and no firewall answered in its place. That is the expected result when there is no device that fails to verify checksums.

Real-world use: A tester runs --badsum and receives RST packets from some ports. Normal hosts would never answer. So a firewall in front is generating those replies. She has found the firewall and can now try to bypass it.

Tools: Nmap --badsum. Hping3 can set a bad checksum by hand (verify the option for your version).

Countermeasures: Firewalls and IDS should verify checksums and drop bad packets, just as hosts do.

EXAM FOCUS (both parts):

- How it is asked: "Which Nmap option sends packets with an invalid checksum?" (--badsum). "Which option shuffles the order of scanned hosts?" (--randomize-hosts).
- Keywords: "random order", "bogus checksums", "avoid certain firewall rulesets".
- Common trap: A response to --badsum does NOT come from the target host. It comes from a firewall or IDS.
- Look-alike: --randomize-hosts (order of hosts) vs -r (do not randomize ports; verify) vs -T (timing).

Memory trick: "Random host order = Roulette. Bad sum = Bad homework. The honest host rejects it; a sloppy firewall marks it."

3.28 Proxy Servers and Anonymizers

What it is (simple words): The overview slide (3.23) names proxy servers and anonymizers as the last two evasion techniques, but the notes have no detail slide for them. The following is ADDED CONTEXT.

- **Proxy server:** a computer that sits between you and the target and sends requests for you. The target sees the proxy's IP address, not yours.
- **Proxy chaining:** sending traffic through several proxies in a row, so no single proxy knows both the source and the destination.
- **Anonymizer:** a tool or service that hides your identity and location from the sites you visit. Examples are Tor, VPN services, and web-based anonymizer sites.

Analogy: A proxy is a go-between who buys the goods for you, so the shop never sees your face. A chain of proxies is a line of go-betweens. An anonymizer is a mask for your whole identity.

How it works (numbered steps):

1. The attacker sets his scanner or browser to use a proxy (or a chain of proxies).
2. The scanner sends its request to the first proxy.
3. The proxy forwards it to the next proxy, or to the target.
4. The target logs the address of the last proxy.
5. The reply returns along the same path.

Types and tools (ADDED CONTEXT, verify names before use):

Item	What it is	Notes
HTTP proxy	Forwards web requests	Weak anonymity
SOCKS4 and SOCKS5 proxy	Forwards any TCP traffic (SOCKS5 adds UDP)	Used by scanners
ProxyChains	Linux tool that forces a program through proxies	Connect scans only
Proxifier	Windows tool that routes apps through proxies	Commercial
Proxy Switcher	Windows tool to rotate through proxy lists	Older tool
Tor	Onion routing network with three relays	Strong anonymity, slow
Psiphon, VPN services	Tunnel traffic through other servers	Anonymizer type

Item	What it is	Notes
Tails	Live operating system that sends all traffic through Tor	Leaves no trace on disk

Scanning through a proxy (ADDED CONTEXT):

```
proxychains4 nmap -sT -Pn -n -p 80,443 10.10.1.11
```

Breakdown: proxychains4 starts Nmap inside the proxy chain. -sT is a TCP connect scan (the only type that fits, because proxies pass normal TCP connections, not hand-made raw packets). -Pn skips ping, which does not travel through TCP proxies. -n stops DNS lookups that could leak your real address. The proxies are listed in the ProxyChains config file (for Tor the usual entry is socks5 127.0.0.1 9050, verify the path on your system).

Nmap also has --proxies (HTTP or SOCKS4 URLs). The Nmap guide warns it only helps NSE scripts and version scans and may disclose your true address in other phases (verify).

Real-world use: An attacker scans a target through three proxies in three countries. The target's logs show a foreign address. The investigator must ask each proxy owner for logs, which may take weeks or be impossible.

Limits: Proxies add delay. Free proxies may log or tamper with traffic. A raw SYN scan cannot go through a proxy. Many proxies and Tor exit nodes are public lists that defenders block.

Countermeasures and defense: Block traffic from known Tor exit nodes and open proxies if the business does not need them. Use threat intelligence feeds of anonymizer IPs. Apply egress filtering so internal users cannot tunnel out. Log and alert on connections to proxy ports (3128, 8080, 1080, verify).

EXAM FOCUS:

- How it is asked: "Which technique hides the true source of a scan by using an intermediate server?" (proxy). "Which network routes traffic through multiple relays to hide the origin?" (Tor).
- Keywords: "intermediary", "proxy chain", "hide identity", "anonymizer".
- Common trap: A proxy hides the IP address but is not encryption. A VPN or Tor adds encryption between hops.
- Look-alike: proxy server vs anonymizer vs VPN. A proxy forwards. An anonymizer hides identity. A VPN encrypts the full tunnel.

Memory trick: "Proxy = Pass-it-on. Anonymizer = Aliases and masks."

3.29 Port Scanning Countermeasures

What it is (simple words): The slide lists eight actions that help detect and stop port scanning. Use them as a checklist.

No.	Countermeasure (from the slide)	Why it works
1	Configure firewall and IDS rules to block probes	Stops or alerts on scans
2	Scan your own hosts to test firewall detection	Proves detection works
3	Block bypass via source port or source routing	Closes the 3.19, 3.24 tricks
4	Keep firmware at the latest version	Removes known bugs
5	Use a custom rule set, block unwanted ports	Fewer exposed doors
6	Filter inbound and outbound ICMP type 3	Hides hosts, closed UDP ports
7	Run TCP, UDP, ICMP scans on your own IP space	Finds your own exposed ports
8	Configure anti-scanning and anti-spoofing rules	Blocks scans and fake sources

Analogy: A building owner walks around his own building at night, tries every door, checks that the alarm rings, and replaces broken locks.

How to apply them (numbered steps):

1. Decide which ports must be reachable. Block everything else (default deny).
2. Write firewall and IDS rules for scans (for example many SYNs to many ports from one source).
3. Test with Nmap from outside and inside. Check that the alerts fire.
4. Patch and update the firmware.
5. Filter ICMP carefully and repeat the tests regularly.

Why filter outbound ICMP type 3 (explained): ICMP type 3 means "destination unreachable". For UDP, a closed port makes the host send type 3, code 3 (port unreachable). Scanners use that message to tell closed from open. Blocking these messages hides the difference (the scanner sees silence on every port). Inbound ICMP filtering stops echo, timestamp, and address mask pings used in host discovery (3.5.1).

> **ADDED CONTEXT:** Blocking all ICMP can break useful features, such as Path MTU Discovery (type 3, code 4, "fragmentation needed"). Allow what the network needs and filter the rest.

More defenses (ADDED CONTEXT): Close and uninstall unused services. Use host-based firewalls. Use rate limiting. Use port knocking (ports open only after a secret knock sequence). Deploy honeypots to catch scanners (Module 12). Use stateful inspection that drops FIN, NULL, and Xmas packets. Segment the network.

Tools for defenders: The same scanners (Nmap, Hping3), plus IDS tools such as Snort and Suricata, and firewall logs (ADDED CONTEXT).

AI angle (ADDED CONTEXT): Defenders use AI-based detection to spot slow, randomized scans that rules miss. Example prompt for a SOC analyst: "Here are 500 firewall log lines. Find sources that touched more than 20 different ports within 10 minutes and list them." The analyst checks the answer against the raw logs.

> **EXAM TIP:** For any "how can you prevent or detect port scanning" question, look for: firewall, IDS, close unused ports, filter ICMP, update firmware, test yourself.

EXAM FOCUS:

- How it is asked: "Which of the following is a port scanning countermeasure?" or "Which ICMP messages should be filtered?" (inbound ICMP types and outbound ICMP type 3).
- Keywords: "custom rule set", "anti-scanning", "anti-spoofing", "firmware".
- Common trap: The slide says to scan YOUR OWN network with TCP, UDP, and ICMP probes. This is a defensive step, not an attack.
- Look-alike: port scanning countermeasures (3.29) vs IP spoofing countermeasures (3.30). Spoofing defenses mention ingress filtering, egress filtering, and random sequence numbers.

Memory trick: "Block, Test, Patch, Filter". Block with firewall and IDS rules, a custom rule set, and anti-scanning and anti-spoofing rules (items 1, 5, 8). Test your own network (items 2, 7). Patch firmware (item 4). Filter ICMP (item 6). Item 3 reminds you that source port and source routing must not bypass the filters.

3.30 IP Spoofing Countermeasures

What it is (simple words): The slide lists six measures against IP spoofing.

No.	Countermeasure (from the slide)	Plain meaning
1	Encrypt all network traffic using IPsec, TLS, SSH, and HTTPS	Fake packets cannot join an encrypted session

No.	Countermeasure (from the slide)	Plain meaning
2	Use multiple firewalls for multi-layered protection	Defense in depth
3	Do not rely on IP-based authentication	An IP address is not proof of identity
4	Use a random initial sequence number	Attackers cannot guess TCP numbers
5	Ingress filtering	Drop incoming packets that claim an internal source IP
6	Egress filtering	Drop outgoing packets that carry an invalid local source IP

Analogy: A bank does not accept a phone call just because the caller ID shows the head office. It asks for a code word (encryption and strong authentication). It also checks that no outsider can enter through the staff door (ingress filtering) and that no staff member sends mail with a fake sender (egress filtering).

Ingress and egress, explained:

```
INTERNET          FIREWALL / ROUTER          INTERNAL LAN
                                              10.10.1.0/24

src=10.10.1.5  ---->  DROP (ingress rule: fake internal src)

               <---- DROP (egress rule: src=8.8.8.8 not mine)
```

- **Ingress filtering:** applies to traffic coming IN. If a packet arrives from the internet but its source address belongs to your internal range, it is fake. Drop it.
- **Egress filtering:** applies to traffic going OUT. If a packet leaves your network with a source address that is not in your range, it is spoofed (or an infected machine is sending it). Drop it. This stops your network from being used to attack others.

How to apply them (numbered steps):

1. List your internal address ranges and private ranges.
2. At the perimeter, deny incoming packets whose source is an internal or private range.
3. At the perimeter, deny outgoing packets whose source is not one of your ranges.
4. Turn on random initial sequence numbers (modern systems do this by default).
5. Replace IP-based trust (such as hosts allowed by IP only) with keys, certificates, or tokens.
6. Encrypt traffic end to end.

Why a random ISN helps: The ISN (initial sequence number) is the starting sequence number in a TCP handshake. If it is predictable, an attacker who cannot see

the replies can still guess the numbers and inject data into a spoofed session. A random ISN makes guessing hard.

> **ADDED CONTEXT:** The standard best practice for ingress/egress filtering is BCP 38 (RFC 2827). On routers, unicast Reverse Path Forwarding (uRPF) checks that the source address of a packet is reachable through the same interface it arrived on (verify details for your device).

Real-world use: An ISP turns on egress filtering. A customer's infected server tries to send packets with random fake sources in a DoS attack. The ISP's router drops them at the edge.

Tools: Firewalls, router ACLs (access control lists), uRPF, IDS (ADDED CONTEXT).

EXAM FOCUS:

- How it is asked: "Which filtering drops incoming packets that appear to come from an internal address?" (ingress). "Which drops outgoing packets with an invalid source?" (egress). "Why use a random initial sequence number?" (to stop sequence number spoofing).
- Keywords: "do not rely on IP-based authentication", "IPsec, TLS, SSH, HTTPS", "multi-layered".
- Common trap: Ingress and egress swap easily. Ingress = in, egress = exit. The direction is relative to your network.
- Look-alike: encryption protects the content. It does not stop spoofed packets from arriving, but they cannot take part in a protected session.

Memory trick: "In = Ingress, Exit = Egress." Six measures: "Every Man Should Randomize Ingress Egress" -> Encrypt, Multiple firewalls, Stop IP-based auth, Random ISN, Ingress, Egress.

4. Tool Encyclopedia

Tools marked "(notes)" appear in your screenshots. All others are ADDED CONTEXT: close alternatives the exam often places next to them. Verify versions and options before using any tool.

4.1 Scanners and Packet Tools

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
Nmap (notes)	Finds hosts, ports, services, OS	CLI, cross-platform	Scanning	"Network Mapper", most used scanner

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
Zenmap (notes)	Graphical front end for Nmap	GUI, cross-platform	Scanning	Command box, Topology tab
Hping3 (notes)	Sends hand-made TCP, UDP, ICMP packets	CLI, Linux	Scanning	-a spoof, firewall test
Metasploit (notes)	Exploit framework with scanner modules	Framework, CLI	Scan, exploit	auxiliary/scanner
NetScanTools Pro (notes)	Windows toolkit: ping, ports, packets	GUI, Windows	Scanning	Packet crafting, ping sweep
Masscan	Very fast port scanner for huge ranges	CLI	Scanning	Scans internet in minutes
ZMap	Internet-wide single-port scanner	CLI	Scanning	Whole IPv4 space
Unicornscan	Asynchronous scanner with packet control	CLI, Linux	Scanning	Stateless scanning
RustScan	Fast port finder that hands results to Nmap	CLI	Scanning	Fast, then Nmap
Nping	Nmap-suite packet generator	CLI	Scanning	Echo, TCP, UDP, ARP probes
Netcat (nc)	Reads and writes TCP and UDP connections	CLI	Scan, banner	"Swiss army knife"

Key notes on the tools from your screenshots:

- **Nmap** was written by Gordon Lyon (known as Fyodor). It is free and open source. It has a scripting engine (NSE) for extra checks (ADDED CONTEXT).
- **Hping3** is best known for crafting packets with chosen flags, spoofing the source (-a), and testing firewall rules. It can also be used for floods, which is a DoS attack (Module 10).
- **Metasploit** is mostly an exploitation framework (Module 06). It has auxiliary scanner modules and can run Nmap through db_nmap (ADDED CONTEXT).
- **NetScanTools Pro** is named twice in the notes: once as a scanning tool (3.2) and once as a packet crafting tool (3.21).

4.2 Ping Sweep and Host Discovery Tools

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
Angry IP Scanner (notes)	Fast IP and port scanner	GUI, cross-platform	Host discovery	"Angry", ping sweep
SolarWinds Engineer's Toolset (notes)	Many network tools including sweep	GUI, Windows	Host discovery	Commercial toolset
NetScanTools Pro (notes)	Ping sweep and more	GUI, Windows	Host discovery	Toolkit
Colasoft Ping Tool (notes)	Pings many hosts at once	GUI, Windows	Host discovery	Multiple ping
Advanced IP Scanner (notes)	LAN scanner, shows shared folders	GUI, Windows	Host discovery	LAN, remote control
OpUtils (notes)	IP and switch port management	GUI, ManageEngine	Host discovery	ManageEngine
fping	Pings many hosts in parallel	CLI	Host discovery	-a, -g sweep
arp-scan	ARP sweep of the local network	CLI, Linux	Host discovery	Layer 2 sweep
Netdiscover	Active and passive ARP discovery	CLI, Linux	Host discovery	ARP recon
MegaPing	Windows scanner and ping suite	GUI, Windows	Host discovery	Multi-tool

4.3 Packet Crafting and Fragmentation Tools

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
Colasoft Packet Builder (notes)	Builds and sends custom packets	GUI, Windows	Evasion	Decode editor, hex editor
Scapy	Python library to build and send packets	Python, cross-platform	Scan, evasion	Programmable crafting
Nemesis	Command-line packet injector	CLI, Unix	Evasion	Packet injection
Ostinato	Packet generator with GUI	GUI, cross-platform	Testing	Traffic generator
packETH	Ethernet packet generator	GUI, Linux	Testing	Ethernet frames

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
fragroute and fragrouter	Split traffic into fragments	CLI, Unix	Evasion	IDS fragmentation test

4.4 Sniffers and OS Fingerprinting Tools

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
Wireshark (notes)	Captures and reads packets	GUI, cross-platform	Scan, sniff	TTL and window, OS clue
tcpdump	Command-line packet capture	CLI, Unix	Scan, sniff	Capture to file
p0f	Passive OS fingerprinting	CLI	OS discovery	Passive, no packets sent
Xprobe2	Active OS fingerprint using ICMP	CLI, Linux	OS discovery	ICMP-based OS guess
Nmap -O	Active OS fingerprint	CLI	OS discovery	Active fingerprint

4.5 Banner Grabbing Tools

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
Telnet	Opens a raw connection to a port	CLI	Banner grab	Manual banner
Netcat	Same, with more options	CLI	Banner grab	nc -v host port
curl -I	Fetches only HTTP headers	CLI	Banner grab	Server header
ID Serve	Identifies web server from headers	GUI, Windows	Banner grab	Server ID
Netcraft	Shows web server and OS history	Web service	Recon, banner	Site report

4.6 Spoofing, Proxy, and Anonymizer Tools

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
Nmap --spoof-mac	Uses a chosen MAC in raw scans	Nmap option	Evasion	Vendor name, MAC
macchanger	Changes a card's MAC on Linux	CLI, Linux	Evasion	MAC spoof
Technitium MAC Address Changer	Changes MAC on Windows	GUI, Windows	Evasion	MAC spoof
SMAC	Windows MAC spoofer	GUI, Windows	Evasion	MAC spoof
ProxyChains	Forces a program through proxies	CLI, Linux	Evasion	Proxy chaining
Proxifier	Routes apps through proxies	GUI, Windows	Evasion	Proxy client
Proxy Switcher	Rotates proxies from a list	GUI, Windows	Evasion	Proxy list
Tor	Onion routing for anonymity	Network, browser	Evasion	Three relays
Psiphon	Circumvention and anonymizing tool	App	Evasion	Anonymizer
Tails	Live OS that routes all via Tor	Live OS	Evasion	No trace

4.7 Defensive Tools

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
Snort	Open-source IDS and IPS	Network IDS	Defense	Rules, scan alerts
Suricata	Open-source IDS, IPS, and monitor	Network IDS	Defense	Multi-thread IDS
Firewall (stateful)	Allows traffic that fits known sessions	Network device	Defense	Drops ACK, FIN, NULL
Honeypot	Fake system that attracts scanners	Decoy system	Defense	Module 12
Port knocking	Opens a port only after a secret sequence	Technique	Defense	Hidden ports

> **EXAM TIP:** For tool questions, match the verb. "Create or craft packets" -> Colasoft Packet Builder, Hping3, Scapy. "Sweep a range" -> Angry IP Scanner, Advanced IP Scanner, Nmap -sn. "Capture packets to read TTL" -> Wireshark. "Find open ports on a host" -> Nmap.

5. Command Sheet

How to read any command: the first word is the program. Words that start with - or -- are options (flags). A flag may take a value after it. The rest are targets. Many Nmap options need administrator or root rights because they use raw packets. Run them with sudo on Linux. The notes use a target 10.10.1.11 and a lab range 10.10.1.0/24. Flags marked "verify" depend on the tool version.

5.1 Anatomy of an Nmap Command

Purpose: Understand every part of an Nmap command so you can read any exam command.

Full syntax:

```
nmap [SCAN TYPE] [HOST DISCOVERY] [PORTS] [EVASION] [OUTPUT] TARGET
```

Breakdown: SCAN TYPE is the -s option (for example -sS). HOST DISCOVERY is the -P options and -sn. PORTS is -p, -F, or --top-ports. EVASION is -f, -g, -D, and so on. OUTPUT is -oN and similar. TARGET is an address, a name, a range, or a subnet.

Target formats:

Format	Example	Meaning
Single IP	10.10.1.11	One host
Host name	www.example.com	Resolved by DNS
Range	10.10.1.5-23	Last octet 5 to 23
CIDR	10.10.1.0/24	256 addresses
List file	-iL targets.txt	Read targets from a file
Exclude	--exclude 10.10.1.1	Skip an address

General flags used across the module:

Flag	Meaning	When to use	Example
-v	Verbose output	See progress	nmap -sT -v TARGET
-p	Ports to scan	Choose ports	-p 22,80,443

Flag	Meaning	When to use	Example
-p-	All 65,535 ports	Full scan	nmap -p- TARGET
-F	Fast: top 100 ports	Quick check	nmap -F TARGET
--top-ports N	Scan N most common ports	Shorter scan	--top-ports 20
-Pn	Skip host discovery	Ping blocked	nmap -Pn TARGET
-n	No DNS lookup	Speed, stealth	nmap -n TARGET
-T0 to -T5	Timing template	Slow is stealthy	-T1 sneaky, -T4 fast
-oN FILE	Save normal output	Keep results	-oN scan.txt
-oX FILE	Save XML	Tool import	-oX scan.xml
-oG FILE	Save greppable output	Use with grep	-oG scan.gnmap
-oA BASE	Save all three formats	Full record	-oA scan1

Timing names (ADDED CONTEXT): -T0 paranoid, -T1 sneaky, -T2 polite, -T3 normal (default), -T4 aggressive, -T5 insane.

Demo commands:

```
nmap -sS -p 1-1024 -oN web.txt 10.10.1.11
nmap -sn 10.10.1.0/24 -oG alive.gnmap
nmap -Pn -n -F 10.10.1.11
```

Common mistakes: Forgetting sudo for raw scans, which makes Nmap silently fall back to a connect scan or fail. Scanning without permission. Using -p 1-65535 when -p- is shorter. Using -sn and expecting ports.

What the exam asks: the meaning of -Pn, -sn, -p-, -F, and -T. Which output flag is for greppable output (-oG).

5.2 Host Discovery: nmap -sn with -PE, -PP, -PM, -PR, -PU, -PS, -PA, -PO

Purpose: Find which hosts are alive without scanning ports.

Full syntax:

```
nmap -sn [-PE | -PP | -PM | -PR | -PU[ports] | -PS[ports] \
  | -PA[ports] | -PO[protocols]] TARGET
```

Breakdown: nmap = program. -sn = ping scan only (no port scan). One -P option picks the probe type. TARGET is a host, range, or subnet.

Flag	Meaning	When to use	Example
-sn	Host discovery only, no ports	Build a live-host list	nmap -sn 10.10.1.0/24
-PE	ICMP echo request (type 8)	Ping is allowed	nmap -sn -PE 10.10.1.5-23
-PP	ICMP timestamp request (13)	Echo blocked	nmap -sn -PP 10.10.1.11
-PM	ICMP address mask request (17)	Echo blocked	nmap -sn -PM 10.10.1.11
-PR	ARP request	Same LAN	nmap -sn -PR 10.10.1.0/24
-PU	UDP probe (default port 40125)	TCP and ICMP blocked	nmap -sn -PU 10.10.1.11
-PS	TCP SYN probe (default port 80)	Web ports open	nmap -sn -PS22,80 TARGET
-PA	TCP ACK probe (default port 80)	SYN filtered	nmap -sn -PA80 TARGET
-PO	IP protocol probe (1, 2, 4)	Other probes fail	nmap -sn -PO TARGET
-Pn	Skip discovery, assume up	ICMP blocked everywhere	nmap -Pn TARGET

Default ports (40125 for UDP, 80 for SYN and ACK) and default protocols (1, 2, 4) are ADDED CONTEXT, verify for your version.

Demo commands:

```
nmap -sn -PE 10.10.1.5-23
nmap -sn -PR -n 10.10.1.0/24
nmap -sn -PS22,80,443 10.10.1.0/24
```

Scenario: the first command pings 19 addresses (the ICMP echo ping sweep from the slide). The second finds every host on the local LAN using ARP with no DNS lookups. The third checks three TCP ports on every address, which works when ICMP is blocked.

Sample output (representative of the ping sweep screenshot on page 2):

```
Starting Nmap 7.94 ( https://nmap.org ) at 2024-03-04 03:50 EST
Nmap scan report for 10.10.1.5
Host is up (0.00040s latency).
MAC Address: 00:15:5D:01:80:05 (Microsoft)
Nmap scan report for 10.10.1.9
Host is up (0.00021s latency).
MAC Address: 00:15:5D:01:80:09 (Microsoft)
Nmap scan report for 10.10.1.11
Host is up (0.00063s latency).
MAC Address: 00:15:5D:01:80:00 (Microsoft)
Nmap done: 19 IP addresses (3 hosts up) scanned in 1.45 seconds
```

[UNCLEAR on page 2]: The exact range, the number of live hosts, and the times in the ICMP ping sweep screenshot are small. The slide shows several "Nmap scan report" blocks, each with "Host is up" and a MAC address, and a final summary line. The sample above has the same shape.

How to read it: each "Nmap scan report for" line starts a live host. "Host is up (0.00040s latency)" says it answered and how fast. The MAC line appears only for hosts on the same LAN. The last line is the key: "19 IP addresses (3 hosts up)" means 19 were probed and 3 answered. Addresses that did not answer are not listed.

Common mistakes: Expecting open ports from -sn. Forgetting that on a LAN Nmap uses ARP even when you request -PE or -PS (use --send-ip to force IP probes, verify). Using -PU with no ICMP reply allowed. Mixing up -PS (ping) with -sS (scan).

What the exam asks: Which -P letter matches which probe. That -sn is a ping scan with no port scan. That -PR is ARP and works only on the local network.

5.3 TCP Connect and SYN Scans: -sT and -sS

Purpose: Find open TCP ports. -sT completes the handshake. -sS stops after the SYN/ACK.

Full syntax:

```
nmap -sT [-v] [-p PORTS] TARGET
sudo nmap -sS [-v] [-p PORTS] TARGET
```

Breakdown: -sT = connect scan (uses the OS connect call, no root needed). -sS = SYN scan (raw packets, root needed). -v = verbose. -p = ports.

Flag	Meaning	When to use	Example
-sT	Full TCP connect scan	No root rights	nmap -sT -v TARGET
-sS	Half-open SYN scan	Faster, less logged	sudo nmap -sS -v TARGET
-v	Verbose	Watch open ports appear	-v or -vv
-p-	All ports	Complete check	nmap -sS -p- TARGET

Demo commands:

```
nmap -sT -v 10.10.1.11
sudo nmap -sS -p 21,80,135,139,445,3389 10.10.1.11
sudo nmap -sS -p- -T4 10.10.1.11
```

Sample output (-sS -p 21,80,135,139,445,3389):

```
Nmap scan report for 10.10.1.11
Host is up (0.00030s latency).

PORT     STATE SERVICE
21/tcp   open  ftp
80/tcp   open  http
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
MAC Address: 00:15:5D:01:80:00 (Microsoft)

Nmap done: 1 IP address (1 host up) scanned in 0.25 seconds
```

How to read it: the table has one line per reported port. STATE is open for all six. The SERVICE column is Nmap's name for the standard use of that port number (it is not proof). With a full default scan you would also see "Not shown: 994 closed tcp ports (reset)" above the table. A connect scan says "conn-refused" in that line, a SYN scan says "reset" (see 3.26 and 3.19).

Common mistakes: Running -sS without root (Nmap falls back to -sT or stops). Believing SYN scans are invisible. Using -p 1-1000 and thinking it covers all ports.

What the exam asks: Which scan completes the handshake (-sT) and which does not (-sS). Which one needs raw sockets (-sS).

5.4 Inverse TCP Flag Scans: -sX, -sF, -sN, -sM

Purpose: Find open ports by sending odd flag combinations and watching for silence.

Full syntax:

```
sudo nmap -sX | -sF | -sN | -sM [-v] [-p PORTS] TARGET
```

Flag	Meaning	When to use	Example
-sX	Xmas: FIN, PSH, URG set	Target is Linux or Unix	sudo nmap -sX -v TARGET
-sF	FIN only	Simple packet filter	sudo nmap -sF -v TARGET
-sN	NULL: no flags	Simple packet filter	sudo nmap -sN -v TARGET
-sM	Maimon: FIN and ACK	BSD-type target	sudo nmap -sM -v TARGET

Demo commands:

```
sudo nmap -sX -v 10.10.1.20
sudo nmap -sF -p 22,80 10.10.1.20
sudo nmap -sN -v 10.10.1.20
```

Scenario: 10.10.1.20 is a Linux web server behind a simple packet filter. The first command sends Xmas probes, the second sends FIN probes to two ports, the third sends NULL probes.

Sample output (Xmas scan against a Linux host):

```
Nmap scan report for 10.10.1.20
Host is up (0.00031s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE         SERVICE
22/tcp open|filtered ssh
80/tcp open|filtered http
```

How to read it: 998 ports answered RST, so they are closed. Ports 22 and 80 stayed silent, so Nmap cannot tell open from filtered and reports "open|filtered". The tester must confirm with a different scan, such as -sS or -sV.

Sample output (the same Xmas scan against a Windows host):

```
Nmap scan report for 10.10.1.11
Host is up (0.00020s latency).
Not shown: 1000 closed tcp ports (reset)
```

How to read it: every port looks closed, even though ports 80 and 3389 are open. Windows sends RST for every unexpected packet, so the scan is useless there. This is the classic exam point.

Common mistakes: Treating "open|filtered" as "open". Using these scans on Windows. Forgetting sudo. Expecting -sM to work on modern systems.

What the exam asks: Which flags each scan sets. That silence means open or filtered. That they fail against Windows.

5.5 ACK, Window, and TTL-based Scans: -sA and -sW

Purpose: Map firewall rules. The ACK scan shows which ports are filtered. The window scan tries to also tell open from closed on a few systems.

Full syntax (as shown on the slides):

```
sudo nmap -sA -v TARGET
sudo nmap -sA -ttl 100 -v TARGET
sudo nmap -sA -sW -v TARGET
```

Flag	Meaning	When to use	Example
-sA	ACK scan: filtered or unfiltered	Map firewall rules	sudo nmap -sA TARGET
-ttl 100	Slide wording for TTL-based scan	Exam recall	See note below

Flag	Meaning	When to use	Example
--ttl 100	Real Nmap option: set outgoing TTL	Control hop reach	nmap --ttl 100 TARGET
-sW	Window scan (reads RST window)	Some BSD-type systems	sudo nmap -sW TARGET

[UNCLEAR on page 3]: The slide prints -ttl and puts -sW after -sA. Real Nmap uses --ttl for the time-to-live setting and -sW alone for the window scan. Learn the slide wording for the exam. Use the real options in a real tool (verify).

Demo commands:

```
sudo nmap -sA -v 10.10.1.11
sudo nmap -sW -p 22,80 10.10.1.20
sudo nmap -sA --ttl 100 10.10.1.11
```

Sample output (ACK scan behind a stateful firewall):

```
Not shown: 998 filtered tcp ports (no-response)
PORT   STATE      SERVICE
22/tcp unfiltered ssh
80/tcp unfiltered http
```

How to read it: 998 ports gave no reply, so a firewall blocks them (filtered). Ports 22 and 80 returned RST, so the firewall lets packets reach those ports (unfiltered). The scan does not say whether 22 or 80 are open. A follow-up SYN scan on those two ports would.

Common mistakes: Reading "unfiltered" as "open". Confusing -sA (scan) with -PA (ping). Using the slide spelling -ttl in a real Nmap run.

What the exam asks: That ACK scanning identifies firewall rule sets and stateful behavior. That the TTL-based variant uses the TTL of the RST (under 64 means open in EC-Council's rule) and the window variant uses a non-zero window (verify).

5.6 Idle (IPID) Scan: -sI

Purpose: Scan a target while the target sees only the zombie's address.

Full syntax:

```
sudo nmap -Pn -p- -sI ZOMBIE[:PROBEPORT] TARGET
```

Breakdown: -Pn = skip discovery. -p- = all ports. -sI = idle scan using the host ZOMBIE (optionally a port to probe on the zombie). TARGET = the real victim.

Flag	Meaning	When to use	Example
-sI	Idle scan via zombie	Hide the attacker's IP	-sI 10.10.1.50
-Pn	No ping	Zombie scans need it	-Pn
-p	Ports to test	Limit time	-p 80,443
-p-	All 65,535 ports	Full coverage	-p-

Demo commands:

```
sudo nmap -Pn -p- -sI 10.10.1.50 10.10.1.11
sudo nmap -Pn -p 80,443 -sI 10.10.1.50:445 10.10.1.11
```

Scenario: 10.10.1.50 is an idle network printer with an incrementing IPID. The first command scans every port of 10.10.1.11 through the printer. The second scans two ports and uses port 445 on the zombie for its probes.

Sample output:

```
Idle scan using zombie 10.10.1.50 (10.10.1.50:80); Class: Incremental
Nmap scan report for 10.10.1.11
Not shown: 65529 closed|filtered tcp ports (no-response)
PORT     STATE SERVICE
80/tcp   open  http
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
```

How to read it: line 1 confirms the zombie and its IPID class. "Incremental" is good: the IPID rises by one per packet, so the method works. If the class is "Random" or "All zeros", pick another zombie. The state "closed|filtered" appears because the idle scan cannot tell closed from filtered. Only open ports are listed by name.

Common mistakes: Choosing a busy host as zombie (its own traffic raises the IPID and gives wrong results). Forgetting -Pn. Expecting results if the zombie sits behind an ingress filter.

What the exam asks: That -sI is the idle scan. That the scan uses IPID changes (+2 open, +1 closed). That the attacker's IP is not seen by the target.

5.7 UDP, SCTP, and IPv6 Scans: -sU, -sY, -sZ, -6

Purpose: Scan protocols other than TCP, and scan IPv6 targets.

Full syntax:

```
sudo nmap -sU [-v] [-p PORTS] TARGET
sudo nmap -sY [-v] TARGET
sudo nmap -sZ [-v] TARGET
nmap -6 [SCAN OPTIONS] TARGET
```

Flag	Meaning	When to use	Example
-sU	UDP scan	DNS, SNMP, NTP, TFTP	sudo nmap -sU -v TARGET
-sY	SCTP INIT scan	Telecom services	sudo nmap -sY TARGET
-sZ	SCTP COOKIE ECHO scan	Quieter SCTP probe	sudo nmap -sZ TARGET
-6	Use IPv6	IPv6 address or AAAA name	nmap -6 TARGET
--top-ports N	Limit to common ports	UDP is slow	--top-ports 50

Demo commands:

```
sudo nmap -sU -p 53,69,123,161 10.10.1.30
sudo nmap -sU -sV --top-ports 20 10.10.1.30
nmap -6 -sS fe80::215:5dff:fe01:8000%eth0
```

Scenario: the first command checks four well-known UDP ports. The second scans the 20 most common UDP ports and asks for service versions. The third scans an IPv6 link-local address through the interface eth0 (%eth0 names the interface, ADDED CONTEXT).

Sample output (-sU):

```
Not shown: 996 closed udp ports (port-unreach)
PORT    STATE         SERVICE
53/udp  open          domain
123/udp open|filtered ntp
161/udp open          snmp
```

How to read it: "port-unreach" means closed ports sent back ICMP port unreachable. Port 53 and 161 answered with real UDP replies (open). Port 123 stayed silent (open|filtered).

Common mistakes: Running -sU on all 65,535 ports without a time plan. Treating silence as closed. Using -sY or -sZ against hosts that do not run SCTP and expecting a result.

What the exam asks: The letter for each protocol (U = UDP, Y = SCTP INIT, Z = SCTP COOKIE ECHO). That -6 enables IPv6.

5.8 Service Version and OS Detection: -sV, -O, -A

Purpose: Name the software and version behind open ports (-sV) and guess the operating system (-O). -A runs both plus scripts and traceroute.

Full syntax:

```
nmap -sV [--version-intensity 0-9] TARGET
sudo nmap -O [--osscan-guess] TARGET
sudo nmap -A TARGET
```

Flag	Meaning	When to use	Example
-sV	Detect service versions	Match exploits	nmap -sV 10.10.1.11
--version-intensity N	How hard to probe (0 to 9)	Faster or deeper	--version-intensity 5
--version-light	Intensity 2	Quick check	--version-light
--version-all	Intensity 9	Hard-to-name service	--version-all
-O	Detect operating system	OS discovery	sudo nmap -O TARGET
--osscan-guess	Guess when no exact match	Uncertain result	--osscan-guess
-A	Version, OS, scripts, traceroute	Full picture, noisy	sudo nmap -A TARGET

Intensity values and -A parts are ADDED CONTEXT, verify for your version.

Demo commands:

```
nmap -sV 10.10.1.11
sudo nmap -O -sV 10.10.1.11
sudo nmap -A -p 80,443 10.10.1.11
```

Sample output of -O (representative):

```
Device type: general purpose
Running: Microsoft Windows 10|11
OS CPE: cpe:/o:microsoft:windows_10 cpe:/o:microsoft:windows_11
OS details: Microsoft Windows 10 1709 - 21H2
Network Distance: 1 hop
```

How to read it: "Device type" is the class. "Running" is the OS family with a version range. "OS CPE" is the standard machine-readable name. "OS details" lists the closest fingerprint matches. "Network Distance: 1 hop" means the target is on the same LAN. For the -sV output, see the screenshot reading in 3.16.

Common mistakes: Believing -O is always right. It guesses from patterns. Forgetting that -O needs at least one open and one closed port to be accurate. Using -A on a production system without warning the owner (it is loud).

What the exam asks: -sV = versions, -O = OS, -A = aggressive (everything). The slide uses -sV in Zenmap to detect service versions.

5.9 Evasion Switches: -f, -g, -D, -S, --spoof-mac, --badsum

Purpose: Change how the scan looks to a firewall or IDS.

Full syntax:

```
sudo nmap -sS -f TARGET
sudo nmap -sS --mtu 16 TARGET
sudo nmap -sS -g 80 TARGET
sudo nmap -sS -D RND:10 TARGET
sudo nmap -sS -D decoy1,decoy2,ME TARGET
sudo nmap -sS --spoof-mac Dell TARGET
nmap --randomize-hosts TARGET-RANGE
sudo nmap --badsum TARGET
```

Flag	Meaning	When to use	Example
-f	Fragment packets (8 bytes)	Stateless packet filter	sudo nmap -f TARGET
--mtu N	Custom fragment size (multiple of 8)	Tune fragmentation	--mtu 16
-g PORT	Set source port	Firewall trusts a port	nmap -g 80 TARGET
--source-port PORT	Same as -g	Same	--source-port 53
-D RND:N	N random decoys	Hide in a crowd	-D RND:10
-D a,b,c	Named decoys	Use live hosts	-D 10.10.1.3,ME
-S IP	Spoof source address	Needs -e and -Pn	-S 10.10.1.99 -e eth0 -Pn
--spoof-mac X	Fake MAC (vendor, prefix, 0)	LAN filtering	--spoof-mac Dell
--randomize-hosts	Shuffle target order	Break patterns	--randomize-hosts
--badsum	Send bad TCP or UDP checksum	Detect firewall or IDS	--badsum
--data-length N	Add N random bytes to packets	Look less like Nmap	--data-length 25
--ip-options	Set IP options such as source route	Route around a filter	--ip-options "L IP1 IP2"
-T0 / -T1	Very slow timing	Avoid rate-based IDS	-T1

The last three rows (--data-length, --ip-options, -T0 and -T1) are ADDED CONTEXT from the Nmap reference guide.

Demo commands:

```
sudo nmap -sS -f -Pn 10.10.1.11
nmap -g 80 10.10.1.11
nmap -D RND:10 10.10.1.11
nmap -sT -Pn --spoof-mac Dell 10.10.1.11
nmap --randomize-hosts 10.10.1.11
nmap --badsum 10.10.1.11
```

The last five are the exact commands on your screenshots (pages 5, 8, and 9). Scenario for the first: a stateless packet filter hides the host, so the tester scans with tiny fragments.

Sample outputs: The decoy scan, the MAC spoof scan, and the source-port scan outputs are shown line by line in 3.25, 3.26, and 3.19. The bad checksum output looks like this:

```
Nmap scan report for 10.10.1.11
Host is up (0.0010s latency).
All 1000 scanned ports on 10.10.1.11 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Nmap done: 1 IP address (1 host up) scanned in 23.12 seconds
```

How to read it: every probe had a bad checksum and the host dropped all of them. Silence on every port means nothing replied in place of the host, so no device in front of it answered bad packets. A reply on some ports would point to a firewall or IDS.

Common mistakes: Using -f with -sT or -sV (fragmentation needs raw packets). Using --spoof-mac with -sT (not honored, see 3.26). Using decoys that are switched off. Writing -d (debug) instead of -D (decoy). Putting a value after -f (it takes none; use --mtu for a size).

What the exam asks: Which switch does which evasion. For example "-g or --source-port" for source port manipulation, "-D" for decoys, "--spoof-mac" for MAC spoofing, "--randomize-hosts" for random order, "--badsum" for bad checksums, "-f" for fragmentation.

5.10 Hping3 and IP Spoofing: hping3 TARGET -a SPOOFED-IP

Purpose: Send hand-made TCP, UDP, or ICMP packets. In the notes (page 5) it spoofs the source IP address.

Full syntax:

```
sudo hping3 [MODE] [FLAGS] [-p PORT] [-a SPOOFED-IP] [-c COUNT] TARGET
```

The slide shows the command as: Hping3 www.certifiedhacker.com -a 7.7.7.7. On Linux the program name is lowercase hping3, and it needs root.

Breakdown of the slide command: hping3 = program. www.certifiedhacker.com = target host (resolved to an IP). -a 7.7.7.7 = use 7.7.7.7 as the source address. No

mode flag means the default TCP mode, sending a packet with no flags to port 0 (ADDED CONTEXT from the man page).

Flag	Meaning	When to use	Example
-a IP (--spoof)	Fake source address	IP spoofing test	-a 7.7.7.7
--rand-source	Random source for every packet	Hide, flood tests	--rand-source
-1	ICMP mode (echo request)	Ping a host	hping3 -1 TARGET
-2	UDP mode	UDP test	hping3 -2 -p 161 TARGET
-8 (--scan)	Scan mode with a port list	Port scan	-8 1-100
-S	Set SYN flag	SYN probe	-S -p 80
-A	Set ACK flag	ACK probe, map firewall	-A -p 80
-F	Set FIN flag	FIN probe	-F -p 80
-P	Set PUSH flag	Part of Xmas-like set	-F -P -U
-U	Set URG flag	Part of Xmas-like set	-F -P -U
-R	Set RST flag	RST probe	-R -p 80
-p PORT	Destination port	Choose the target port	-p 80
-s PORT	Source (base) port	Source port tests	-s 53
-c N	Stop after N packets	Limit the test	-c 3
-V	Verbose	See more fields	-V
-T	Traceroute mode	Map the path	hping3 -T -S TARGET

The flag list is ADDED CONTEXT from the hping3 man page except -a, which is on your slide. Verify options for your version. Do not use -X: in hping3 it sets an unused flag bit (0x40) and is not the Xmas scan. Build an Xmas-like packet with -F -P -U.

Demo commands:

```
sudo hping3 www.certifiedhacker.com -a 7.7.7.7 -c 5
sudo hping3 -S 10.10.1.11 -p 80 -c 3
sudo hping3 -A 10.10.1.11 -p 80 -c 3
sudo hping3 -F -P -U 10.10.1.11 -p 80 -c 3
sudo hping3 -8 1-100 -S 10.10.1.11 -V
```

Scenario: the first command is the slide example limited to 5 packets. The second sends a SYN to port 80 three times. The third sends an ACK probe to see if a firewall lets it through. The fourth sends FIN, PSH, and URG together. The fifth scans ports 1 to 100 with SYN packets and prints details.

Sample output (SYN probe to an open port):

```
HPING 10.10.1.11 (eth0 10.10.1.11): S set, 40 headers + 0 data bytes
len=44 ip=10.10.1.11 ttl=128 DF id=1234 sport=80 flags=SA seq=0
    win=65535 rtt=0.5 ms
len=44 ip=10.10.1.11 ttl=128 DF id=1235 sport=80 flags=SA seq=1
    win=65535 rtt=0.4 ms

--- 10.10.1.11 hping statistic ---
2 packets transmitted, 2 packets received, 0% packet loss
```

How to read it: "S set" is the flag you sent. flags=SA means the reply was SYN+ACK, so port 80 is open. flags=RA (RST+ACK) would mean closed. No reply means filtered. ttl=128 and win=65535 are OS clues (Windows, see 3.17). Each reply line is wrapped here for width.

Sample output (the spoofed command from the slide):

```
HPING www.certifiedhacker.com (eth0 203.0.113.10): NO FLAGS are set,
40 headers + 0 data bytes

--- www.certifiedhacker.com hping statistic ---
5 packets transmitted, 0 packets received, 100% packet loss
```

How to read it: 5 packets went out and none came back. This is expected. The target replied to 7.7.7.7, not to the attacker. This proves the slide's note: you cannot finish a handshake with a spoofed address, and you do not see the replies. The address 203.0.113.10 is a documentation example.

Common mistakes: Running without sudo. Spoofing and then waiting for replies. Sending flood options (--flood) at systems you do not own. Using -X for Xmas. Typing the program name with a capital H on Linux.

What the exam asks: That -a spoofs the source address. That Hping3 builds custom packets and can scan, ping, trace, and test firewalls. That 100% packet loss is normal for spoofed probes.

5.11 Supporting Commands: Wireshark Filters, Banner Grabbing, and ShellGPT

Purpose: Read OS clues, grab banners, and let an AI tool write scan commands. These are ADDED CONTEXT; the notes show the Wireshark screens and the banner grabbing concept but no exact commands.

Wireshark display filters (type in the filter bar):

Filter	Meaning	When to use	Example
ip.ttl == 128	Packets with TTL 128	Spot Windows	ip.ttl == 128
ip.src == IP	Packets from one host	Focus on the target	ip.src == 10.10.1.11

Filter	Meaning	When to use	Example
tcp.flags.syn == 1	SYN packets	Find scan starts	tcp.flags.syn == 1
tcp.flags.reset == 1	RST packets	See closed ports	tcp.flags.reset == 1
tcp.window_size_value	TCP window size field	Compare with the table	tcp.window_size_value == 5840

Filter names are standard Wireshark fields (verify for your version).

Banner grabbing commands:

```
nc -v 10.10.1.11 80
curl -I http://10.10.1.11
sudo nmap -sV --script=banner -p 21,22,80 10.10.1.11
```

Breakdown: nc -v = Netcat in verbose mode, then host and port. After connecting, type HEAD / HTTP/1.0 and press Enter twice. curl -I = fetch only the HTTP response headers. The Nmap line runs the banner script on three ports.

```
HTTP/1.1 200 OK
Server: Microsoft-IIS/10.0
X-Powered-By: ASP.NET
```

How to read it: the Server header names the web server and version. X-Powered-By names the framework. Together they say Windows with IIS.

ShellGPT (AI command helper):

```
sgpt --shell "nmap command: ping sweep of 10.10.1.0/24, no ports"
sgpt --shell "nmap OS detection and versions for 10.10.1.11"
```

Typical answers: nmap -sn 10.10.1.0/24 and sudo nmap -O -sV 10.10.1.11. ShellGPT then offers [E]xecute, [D]escribe, [A]bort. Use D to read what the command does before pressing E. The flags --shell and --describe-shell are described in the Module 02 guide.

Common mistakes: Running an AI-written command without reading it. Pasting a real client address into a public AI service. Forgetting that Netcat needs the HEAD line plus two Enter presses.

What the exam asks: That banner grabbing can use Telnet, Netcat, or curl. That TTL and window can be filtered in Wireshark. That AI tools generate commands, but the human must verify them.

6. Ports, Protocols, Standards and Acronyms

6.1 Ports Seen in Your Screenshots

Every Nmap result in the notes shows the same six open ports on 10.10.1.11, a Windows host. Learn what each means.

Port	Service name in Nmap	Simple purpose	Known weakness	Related attack or tool
21/tcp	ftp	File transfer	Clear text, anonymous login	Brute force, sniffing
80/tcp	http	Web pages	Old servers have exploits	Web attacks, banner grab
135/tcp	msrpc	Windows remote procedure calls	Used for remote exploits	Enumeration, DCOM abuse
139/tcp	netbios-ssn	NetBIOS session (old file sharing)	Leaks names and shares	Enumeration (Module 04)
445/tcp	microsoft-ds	SMB file sharing over TCP	EternalBlue-type flaws	Exploits, relay attacks
3389/tcp	ms-wbt-server	Remote Desktop (RDP)	Weak passwords, BlueKeep	Brute force, RDP exploits

Demo ports in the source port slide: 242 (the real source port, blocked) and 80 (the manipulated source port, allowed). Port 242 has no special meaning here. It is just a number the firewall does not trust.

> **ADDED CONTEXT:** "ms-wbt-server" is Nmap's name for the Windows Terminal Services (Remote Desktop) service. "WBT" stands for Windows-Based Terminal. "microsoft-ds" means Microsoft Directory Services, which is SMB on port 445.

6.2 Other Ports Often Asked (ADDED CONTEXT)

Port	Service	Simple purpose	Known weakness	Related attack or tool
20 and 21	FTP	Data and control for file transfer	Clear text	Sniffing, bounce scan
22	SSH	Encrypted remote shell	Weak passwords	Brute force
23	Telnet	Old remote shell	Clear text	Sniffing, banner grab
25	SMTP	Mail sending	Open relay, user listing	Enumeration, spam

Port	Service	Simple purpose	Known weakness	Related attack or tool
53	DNS (UDP and TCP)	Name lookup	Zone transfer, spoofing	Recon, source port 53 trick
67 and 68	DHCP (UDP)	IP address leasing	Rogue server	DHCP starvation
69	TFTP (UDP)	Simple file transfer	No authentication	Config theft
110	POP3	Mail download	Clear text	Sniffing
123	NTP (UDP)	Time sync	Amplification	DDoS
137 to 139	NetBIOS	Names and sessions	Info leak	nbtstat, enumeration
143	IMAP	Mail access	Clear text	Sniffing
161 and 162	SNMP (UDP)	Device management	Default community strings	Enumeration
389	LDAP	Directory service	Anonymous bind	Enumeration
443	HTTPS	Encrypted web	Old TLS	Heartbleed-type flaws
514	Syslog (UDP)	Log transfer	Spoofable	Log forgery
1433	MS SQL Server	Database	Weak sa password	SQL attacks
1900	SSDP (UDP)	UPnP discovery	Reflection, UPnP flaws	SSDP scan, DDoS
3306	MySQL	Database	Weak passwords	Brute force
5900	VNC	Remote screen	Weak passwords	Brute force
8080	HTTP alternate	Proxies, web apps	Open proxies	Proxy abuse (3.28)

Port numbers are standard defaults and can be changed. A service on a non-standard port is why version detection (-sV) exists.

6.3 Protocols and the Layer They Work At

Protocol	Layer (OSI)	Simple purpose	Weakness	Related attack or tool
IP	3 Network	Addressing and routing	Spoofing, fragmentation	Hping3 -a, Nmap -f
ICMP	3 Network	Errors and tests (ping)	Ping sweeps, tunnels	-PE, -PP, -PM
ARP	2 Data link	Maps IP to MAC	No authentication	-PR, ARP spoofing

Protocol	Layer (OSI)	Simple purpose	Weakness	Related attack or tool
TCP	4 Transport	Reliable connection	Handshake can be probed	-sT, -sS, -sX
UDP	4 Transport	Connectionless messages	No handshake, easy spoofing	-sU, -PU
SCTP	4 Transport	Multi-stream messages	Rarely filtered	-sY, -sZ
SSDP	7 Application	UPnP discovery	Reflection, exposure	SSDP scan
IPv6	3 Network	Next-generation addressing	Forgotten firewall rules	nmap -6

OSI layer quick recall (ADDED CONTEXT): 1 Physical, 2 Data link, 3 Network, 4 Transport, 5 Session, 6 Presentation, 7 Application. Mnemonic: "Please Do Not Throw Sausage Pizza Away".

6.4 ICMP Types to Know (ADDED CONTEXT)

Verify against RFC 792 if you need an exact value. Types 0, 3, 8, and 11 are the most asked.

Type	Name	Used for	Related to this module
0	Echo reply	Answer to ping	Reply to -PE
3	Destination unreachable	Errors (code 3 = port unreachable)	UDP scan, -PU, filter outbound
5	Redirect	Tell a host to use another router	Route tampering
8	Echo request	Ping	-PE
11	Time exceeded	TTL reached 0	Traceroute
13	Timestamp request	Ask for time	-PP
14	Timestamp reply	Time answer	Reply to -PP
17	Address mask request	Ask for subnet mask	-PM
18	Address mask reply	Mask answer	Reply to -PM

Common type 3 codes: 0 network unreachable, 1 host unreachable, 2 protocol unreachable, 3 port unreachable, 4 fragmentation needed (Path MTU Discovery), 13 communication administratively prohibited (a firewall said no). Nmap treats codes 1, 2, 9, 10, and 13 as "filtered" (verify).

6.5 TCP Flags and Reply Patterns

Item	Value or pattern	Meaning
SYN then SYN/ACK	Open port	Handshake step 2
SYN then RST	Closed port	Nothing listens
SYN then no reply	Filtered	Firewall drops
FIN, NULL, Xmas then RST	Closed port	RFC 793 behavior
FIN, NULL, Xmas then silence	Open or filtered	Cannot tell
ACK then RST	Unfiltered	Packet reached host
ACK then silence	Filtered	Firewall blocks
UDP then ICMP type 3 code 3	Closed	Port unreachable
UDP then silence	Open or filtered	No error returned
INIT then INIT-ACK	SCTP open	Handshake step 2
INIT then ABORT	SCTP closed	Rejected

6.6 OS Fingerprint Table from the Notes

Operating system	TTL	TCP window size
Linux	64	5840
FreeBSD	64	65535
OpenBSD	255	16384
Windows	128	65,535 bytes to 1 gigabyte
Cisco routers	255	4128
Solaris	255	8760
AIX	255	16384

6.7 Standards, Specifications, and Concepts

Item	What it is	Why it matters here
RFC 793	The original TCP specification	Explains why FIN, NULL, Xmas work on some OSes
RFC 792	ICMP specification	Defines echo, timestamp, mask messages
RFC 791	IP specification	Defines fragmentation and source route options
RFC 4960	SCTP specification	Defines INIT, COOKIE ECHO handshake

Item	What it is	Why it matters here
RFC 2827 (BCP 38)	Network ingress filtering	Standard defense against IP spoofing
CPE	Common Platform Enumeration	Naming used in Nmap OS and service output
CVE	Common Vulnerabilities and Exposures	ID of a known vulnerability
OUI	First 3 bytes of a MAC address	Identifies the card vendor

RFC numbers are ADDED CONTEXT. Verify before quoting.

6.8 Acronyms Used in This Module

Acronym	Meaning	One-line use
ACK	Acknowledgement	TCP flag: I got it
AIX	Advanced Interactive eXecutive	IBM Unix, TTL 255
ARP	Address Resolution Protocol	IP to MAC
CIDR	Classless Inter-Domain Routing	Subnet notation such as /24
FIN	Finish	TCP flag: no more data
ICMP	Internet Control Message Protocol	Ping and errors
IDS	Intrusion Detection System	Alerts on attacks
IPID	IP Identification	Counter used in idle scan
IPS	Intrusion Prevention System	Blocks attacks
ISN	Initial Sequence Number	Start number of a TCP session
MAC	Media Access Control	Hardware address
MTU	Maximum Transmission Unit	Largest packet on a link
NSE	Nmap Scripting Engine	Extra Nmap checks
PSH	Push	TCP flag: send now
RST	Reset	TCP flag: abort
SCTP	Stream Control Transmission Protocol	TCP/UDP alternative
SSDP	Simple Service Discovery Protocol	UPnP discovery
SYN	Synchronize	TCP flag: start
TCP	Transmission Control Protocol	Reliable transport
TTL	Time To Live	Hop counter
UDP	User Datagram Protocol	Connectionless transport

Acronym	Meaning	One-line use
URG	Urgent	TCP flag: priority data
UPnP	Universal Plug and Play	Auto device setup

7. Attack vs Countermeasure and Look-alike Comparisons

7.1 Attack or Technique vs Countermeasure

Attack or technique	Main countermeasure	Extra countermeasure
Ping sweep (ICMP echo)	Filter inbound ICMP at the edge	IDS alert on many pings
ICMP timestamp or mask ping	Block ICMP types 13 and 17	Allow only needed ICMP
ARP ping scan	VLAN segmentation	Port security, DAI
UDP ping	Drop unneeded UDP	Filter outbound ICMP type 3
TCP SYN or ACK ping	Stateful firewall	Rate limit, IDS rule
TCP connect scan	Close unused ports	Connection-rate alerts
SYN (half-open) scan	Firewall and IDS rules	SYN flood protection
FIN, NULL, Xmas scans	Stateful firewall	IDS signatures
ACK scan	Stateful firewall	Drop stray ACKs
Idle (IPID) scan	Ingress and egress filtering	Random IPID on hosts
UDP scan	Block unneeded UDP	Disable SNMP v1 and v2
SCTP scan	Filter SCTP at the edge	Allow known peers only
SSDP scan	Disable UPnP	Block UDP 1900 inbound
IPv6 scan	Same firewall rules for IPv6	Disable unused IPv6
Service version discovery	Hide banners, patch	WAF or reverse proxy
Banner grabbing	Remove version strings	Custom error pages
OS fingerprinting	Alter TCP stack values	Reverse proxy
Packet fragmentation	Reassemble before inspecting	Drop tiny fragments
Source routing	Disable IP source routing	Drop source-route options
Source port manipulation	Stateful inspection	Do not trust source ports
IP address decoy	Log correlation, path tracing	Ingress and egress filtering
IP spoofing	Ingress and egress filtering	Random ISN, no IP trust
MAC spoofing	802.1X, port security	DAI, DHCP snooping
Bad checksums	Firewall verifies checksums	Update firmware
Randomized host order	Long-window IDS correlation	Alert on source totals

Attack or technique	Main countermeasure	Extra countermeasure
Proxies and anonymizers	Block known proxy and Tor IPs	Egress filtering
Custom crafted packets	Stateful firewall, DPI	Malformed-packet IDS rules

7.2 Look-alike Pairs

Pair	The difference in one line	How to tell in a question
-sn vs -Pn	-sn pings only. -Pn skips the ping	"No port scan" vs "treat as up"
-sT vs -sS	Connect finishes the handshake. SYN does not	"Full open" vs "half-open"
-PS vs -sS	-PS is a ping. -sS is a port scan	Ping asks "alive?" Scan asks "open?"
-PU vs -sU	-PU is host discovery. -sU is a UDP port scan	Same logic
Xmas vs NULL	Xmas sets FIN+PSH+URG. NULL sets nothing	"Christmas tree" vs "no flags"
FIN vs Maimon	FIN sets FIN only. Maimon sets FIN+ACK	Look for ACK
ACK scan vs ACK ping	ACK scan maps firewalls. ACK ping finds hosts	"Filtered or unfiltered" vs "host up"
Decoy vs idle scan	Decoy hides among fakes. Idle hides completely	"Zombie" or "IPID" -> idle
Decoy vs spoofing	Decoy keeps your real IP in the mix	"Several scanners" -> decoy
IP vs MAC spoofing	Layer 3 address vs Layer 2 address	"Hardware address" -> MAC
Source routing vs source port	Path chosen vs port number faked	"Route" vs "port"
-g vs -p	-g source port. -p destination ports	"Appear to come from" vs "scan"
-D vs -d	Capital D is decoy. Lowercase d is debug	Check the case
-f vs --mtu	-f uses 8-byte fragments. --mtu sets your size	A number given -> --mtu
-sV vs -O	Version of a service vs OS guess	"Service version" vs "OS"
Active vs passive banner grab	Active sends packets. Passive only listens or reads	"Error messages", "sniffing" -> passive
Ingress vs egress	In to your network vs out of your network	Direction of the packet

Pair	The difference in one line	How to tell in a question
Port scan vs vulnerability scan	Open ports vs known weaknesses	Module 03 vs Module 05
Scanning vs enumeration	Find hosts and ports vs extract details	Module 03 vs Module 04
Proxy vs VPN	Forwards traffic vs encrypts the tunnel	"Encrypted tunnel" -> VPN
Fragmentation vs segmentation	IP layer pieces vs TCP layer pieces	Layer 3 vs Layer 4
Half-open scan vs SYN flood	A scan vs a DoS attack	Purpose of the traffic

8. Exam Cheat Sheet

8.1 Keyword -> Answer Pairs

If the question says	Think
Identify hosts, ports, and services	Network scanning
Does not complete the three-way handshake	Half-open (SYN) scan, -sS
Completes the handshake, no root rights	TCP connect scan, -sT
FIN, PSH, URG flags set	Xmas scan, -sX
No flags set	NULL scan, -sN
Only FIN flag set	FIN scan, -sF
FIN and ACK flags	Maimon scan, -sM
Open port gives no reply, closed gives RST	Inverse TCP flag scan
Does not work against Windows	FIN, NULL, Xmas
Determine firewall rules, filtered or unfiltered	ACK scan, -sA
TTL and window of RST packets	ACK scan variants (TTL-based, window)
Zombie, IPID, attacker IP hidden	Idle scan, -sI
ICMP port unreachable	UDP scan (closed port)
INIT chunk	SCTP INIT scan, -sY
COOKIE ECHO chunk	SCTP COOKIE ECHO scan, -sZ
UPnP, UDP 1900	SSDP scanning
128-bit addresses	IPv6 scanning, -6
Service version	-sV
ICMP echo (type 8)	-PE
ICMP timestamp (type 13)	-PP

If the question says	Think
ICMP address mask (type 17)	-PM
ARP request, local subnet	-PR
UDP probe for host discovery	-PU
TCP SYN ping	-PS
TCP ACK ping	-PA
IP protocol ping	-PO
Ping scan, no ports	-sn
Skip host discovery	-Pn
TTL 128	Windows
TTL 64	Linux or FreeBSD
TTL 255	Cisco, Solaris, AIX, OpenBSD
Splits the TCP header across packets	Fragmentation, -f
Appears to come from port 80 or 53	Source port manipulation, -g
Several IPs appear to scan	Decoy, -D
Source IP changed	IP spoofing, hping3 -a
Hardware address changed	MAC spoofing, --spoof-mac
Random order of targets	--randomize-hosts
Bogus checksum	--badsum
Sender picks the path	Source routing
Creates custom packets	Colasoft Packet Builder, NetScanTools Pro
Error messages, sniffing, .aspx	Passive banner grabbing
Crafted packets compared to a database	Active banner grabbing
Drops incoming packets with internal source IP	Ingress filtering
Drops outgoing packets with invalid source IP	Egress filtering
Predictable sequence numbers	Use random initial sequence number

8.2 Must-memorize Lists

The six TCP flags: URG, ACK, PSH, RST, SYN, FIN.

The ten evasion techniques (slide 25):

1. Packet fragmentation
2. Source routing
3. Source port manipulation
4. IP address decoy
5. IP address spoofing

6. MAC address spoofing
7. Creating custom packets
8. Randomizing host order and sending bad checksums
9. Proxy servers
10. Anonymizers

The four objectives of scanning: live hosts and open ports, OS and architecture, services, vulnerabilities.

The six host discovery families: ICMP ping, ARP ping, UDP ping, TCP ping (SYN and ACK), IP protocol ping, plus the ping sweep.

The six IP spoofing countermeasures: encrypt traffic (IPsec, TLS, SSH, HTTPS), multiple firewalls, no IP-based authentication, random initial sequence number, ingress filtering, egress filtering.

The eight port scanning countermeasures: firewall and IDS rules, test your own firewall with scanners, no bypass by source port or source routing, update firmware, custom rule set, filter ICMP (inbound and outbound type 3), TCP/UDP/ICMP self-scan, anti-scanning and anti-spoofing rules.

Ping sweep tools: Angry IP Scanner, SolarWinds Engineer's Toolset, NetScanTools Pro, Colasoft Ping Tool, Advanced IP Scanner, OpUtils.

8.3 Numbers and Defaults

Item	Value
Nmap default ports scanned	Top 1000 TCP ports
Sum in a default result	Not shown count + listed ports = 1000
Well-known port range	0 to 1023
Windows TTL	128
Linux and FreeBSD TTL	64
Cisco, Solaris, AIX, OpenBSD TTL	255
Linux window size (slide)	5840
Cisco router window size (slide)	4128
-f fragment size	8 bytes (16 with -f -f)
--mtu rule	Multiple of 8
ICMP echo request type	8
ICMP timestamp, mask request	13 and 17
Idle scan IPID change	+2 open, +1 closed
SSDP	UDP 1900
TCP handshake steps	3 (SYN, SYN/ACK, ACK)

Item	Value
TCP termination steps	4 (FIN, ACK, FIN, ACK)
SCTP handshake steps	4 (INIT, INIT-ACK, COOKIE ECHO, COOKIE ACK)

8.4 Pick-the-BEST-option Rules

1. If two scans both fit, choose the one that matches the exact detail in the question (for example "no root rights" -> connect scan, not SYN).
2. "Best way to find live hosts on the same subnet when ICMP is blocked" -> ARP ping (-PR).
3. "Best way to find live hosts when ICMP echo is blocked but other ICMP may pass" -> timestamp or address mask ping.
4. "Best way to see what a firewall allows" -> ACK scan.
5. "Best way to scan without revealing your IP" -> idle scan (zombie), then proxy chains or Tor.
6. "Best way to hide among many scanners in the logs" -> decoy scan.
7. "Best way to avoid a simple packet filter" -> fragmentation, or FIN, NULL, Xmas against Unix hosts.
8. "Best way to scan a Windows host for open ports" -> SYN or connect scan, not Xmas, FIN, or NULL.
9. "Best way to know which software version runs" -> -sV (not -O).
10. "Best way to identify the OS without sending packets" -> passive: sniff and read TTL and window, or read error messages.
11. "Best defense against spoofed internal addresses from outside" -> ingress filtering.
12. "Best defense against your network being used as a spoofing source" -> egress filtering.
13. "Best first step before a port scan" -> host discovery. "Best first step after open ports are found" -> service version and OS detection, then enumeration.
14. "Best way to test whether your own firewall detects scans" -> run scanning tools against your own hosts.
15. If an answer says a scan is "undetectable", it is wrong. Stealth means lower visibility, not invisibility.

8.5 Last-minute Traps

- -sn is not stealth. -sS is not invisible.
- A RST reply to a ping probe still means the host is up.
- Silence means different things: filtered in SYN scans, open|filtered in FIN, NULL, Xmas, and UDP scans.
- ACK scan results: RST means unfiltered, not open.
- IP spoofing cannot complete a handshake from the attacker's machine.
- A reply to a bad checksum probe came from a firewall or IDS, not the host.

- The slide shows -ttl and -sA -sW. Real Nmap uses --ttl and -sW.
- Capital -D is decoy. Lowercase -d is debug.

9. Practice Questions

These are original practice questions written for this guide. They are not real exam questions. Each question is followed right away by its answer and explanation, as requested, instead of a separate answer key at the end.

Q1. A tester runs a scan and sees that the scan never completes a TCP three-way handshake. Each open port answers with SYN/ACK, and the scanner immediately replies with RST. Which scan is this?

A. TCP connect scan B. Half-open (SYN) scan C. ACK scan D. Idle scan

Answer: B. The half-open (SYN) scan sends SYN, receives SYN/ACK, and replies RST instead of ACK, so the handshake is never finished. A is wrong because connect scan finishes the handshake with ACK. C is wrong because ACK scan sends only ACK packets, with no prior SYN. D is wrong because idle scan uses a zombie host and never shows the attacker's SYN to the target directly.

Q2. Which Nmap switch sends a probe with the FIN, PSH, and URG flags all set?

A. -sN B. -sF C. -sX D. -sM

Answer: C. -sX is the Xmas scan, named because the packet is "lit up" with three flags: FIN, PSH, URG. A is wrong because -sN (NULL) sets no flags. B is wrong because -sF (FIN) sets only FIN. D is wrong because -sM (Maimon) sets FIN and ACK, not PSH and URG.

Q3. A tester scans a Windows Server 2019 host with nmap -sN. Every port in the result shows as closed, even though the admin confirms port 3389 is open. What is the most likely explanation?

A. The firewall is blocking all inbound traffic B. Windows replies with RST to a NULL probe regardless of port state C. The tester forgot to use sudo D. Port 3389 was patched and is no longer listening

Answer: B. Windows does not follow the RFC 793 behavior that FIN, NULL, and Xmas scans rely on. It answers RST for every probe, so every port looks closed. A is wrong because a fully blocking firewall would show filtered, not closed, and other scans (SYN) confirmed the port is open. C would usually cause an error or a silent failure, not a consistent "closed" result on a working raw scan. D contradicts the admin's confirmation.

Q4. Which Nmap option is most useful for mapping which ports a stateful firewall allows through, without confirming whether the service behind them is open?

A. -sS B. -sA C. -sV D. -sU

Answer: B. The ACK scan (-sA) tells you unfiltered (the firewall let the ACK through, host replied RST) versus filtered (no reply). It cannot say a port is open. A finds open TCP ports directly, which is a different goal. C detects the service version on already-open ports. D scans UDP ports, a different protocol.

Q5. An attacker wants to scan a target without the target ever seeing the attacker's real IP address, by bouncing probes off an idle third-party host. Which technique is this?

A. Decoy scan B. Idle (IPID) scan C. Source routing D. Proxy chaining

Answer: B. The idle scan uses a "zombie" host with a predictable IP ID. The attacker's SYN to the target is spoofed as coming from the zombie, and the attacker reads the zombie's IPID changes to learn the result. The target's logs show only the zombie. A is wrong because in a decoy scan the attacker's real IP is still among the scanning addresses. C changes the packet's path, not who appears to send it. D hides the source but usually only supports TCP connect scans through application-level proxies, not the specific IPID side-channel technique described.

Q6. During a UDP scan, a tester sees an ICMP message with type 3, code 3 returned for port 69. What does this tell the tester?

A. Port 69 is open B. Port 69 is closed C. Port 69 is filtered by a firewall D. The host does not support UDP

Answer: B. ICMP type 3 code 3 means "destination unreachable, port unreachable", which a host sends when a UDP packet arrives at a closed port. A is wrong because an open UDP port usually gives no ICMP error (it may give a protocol reply or stay silent). C is wrong because a firewall that blocks the probe typically causes silence or a different ICMP code (such as code 13, administratively prohibited), not code 3. D is incorrect; the host clearly processed the UDP packet enough to generate the ICMP response.

Q7. Which of the following is the correct Nmap switch for the SCTP COOKIE ECHO scan?

A. -sY B. -sZ C. -sO D. -sC

Answer: B. -sZ sends an SCTP COOKIE ECHO chunk directly, skipping the earlier handshake steps, and reads ABORT (closed) versus silence (open or filtered). A is the SCTP INIT scan, a different SCTP technique. C and D are not real Nmap scan-type switches.

Q8. A packet capture shows a reply packet with TTL = 118 and a TCP window size of 65535. What operating system is most likely running on the source of that packet?

A. Linux B. Windows C. Cisco router D. Solaris

Answer: B. A TTL of 118 is just under the standard starting value of 128, which matches Windows after crossing about 10 routers. The window size (65535) also fits the Windows range on the slide's table (65,535 bytes up to 1 gigabyte). A is wrong because Linux starts at TTL 64 with a window around 5840. C and D both start at TTL 255, far from 118 even after many hops.

Q9. Which technique evades a firewall by splitting the TCP header of a probe packet across several tiny IP packets?

A. Source routing B. Packet fragmentation C. IP address decoy D. MAC address spoofing

Answer: B. Packet fragmentation (Nmap -f) splits the TCP header into pieces of 8 bytes or less so a simple packet filter cannot read the whole header to apply its rule. A redirects the path the packet takes, not its structure. C adds fake scanning sources, it does not split packets. D changes the Layer 2 hardware address, unrelated to fragment size.

Q10. An attacker runs nmap -g 53 -sS 10.10.1.11 against a target protected by a simple firewall that trusts replies from DNS servers. What is the attacker exploiting?

A. The firewall does not inspect ICMP traffic B. The firewall allows traffic that appears to originate from a well-known source port C. The target's TCP stack has a weak initial sequence number D. The target allows source-routed packets

Answer: B. -g (or --source-port) sets the source port of the probe to 53, the well-known DNS port, so the firewall's rule that trusts "replies from DNS" lets the scan through. A is unrelated to this scenario. C concerns spoofing and session prediction, not port-based trust. D concerns a different evasion technique (source routing), not source port manipulation.

Q11. Which pair correctly matches the probe type to the host discovery switch?

A. -PE : ARP request B. -PR : ICMP echo request C. -PU : UDP probe D. -PS : IP protocol probe

Answer: C. -PU sends a UDP probe, typically to a port that is probably closed, to trigger an ICMP port-unreachable reply. A is wrong because -PE is the ICMP echo probe, not ARP. B is wrong because -PR is ARP, not ICMP echo. D is wrong because -PS is a TCP SYN probe, not an IP protocol probe (which is -PO).

Q12. During a scan, a tester sees the result line "Not shown: 1000 filtered tcp ports (no-response)" and no replies at all, even on ports known to be open. The tester had used nmap --badsum on the target. What does this result suggest?

A. The target host is down B. No firewall or IDS is present to reply on behalf of the host, and the real host correctly dropped every bad-checksum packet C. The target has blocked all incoming traffic with egress filtering D. The scan should be re-run with -Pn

Answer: B. A --badsum scan sends invalid checksums; real hosts drop them silently. If no device replies at all, there is no firewall or IDS present that fails to verify checksums. A is unlikely since other scans (not shown here) found the host up. C confuses egress filtering (which controls outbound traffic from a network) with what is being tested here (inbound evasion). D would not change this result, since the host already responds to other probes; -Pn only skips the ping stage.

Q13. Which of the following best explains why an attacker cannot complete a normal TCP connection when spoofing the source IP address with Hping3's -a option?

A. Hping3 does not support raw sockets B. The target's reply (SYN/ACK) is sent to the spoofed address, not to the attacker C. Spoofed packets are always dropped by the sender's own router D. The -a option disables the TCP flags

Answer: B. Any reply from the victim goes to whatever source address was in the original packet. Since that address is spoofed, the real attacker never receives the SYN/ACK needed to complete the handshake. A is false; Hping3 relies on raw sockets to craft such packets. C is not a general rule; many networks do not filter outbound spoofed packets. D is unrelated; -a only changes the source address field.

Q14. A company wants to stop attackers from sending packets into its network that falsely claim to originate from an internal IP address. Which control addresses this directly?

A. Egress filtering B. Ingress filtering C. Random initial sequence numbers D. Service version hiding

Answer: B. Ingress filtering inspects traffic entering the network and drops packets whose source address falsely claims to be from inside. A instead controls traffic leaving the network to stop internally spoofed packets from reaching the internet. C protects against sequence-number prediction in session hijacking, not spoofed arriving packets. D is a banner-grabbing countermeasure, unrelated to spoofing.

Q15. Which best next step should a tester take after an Nmap scan returns six open ports on a Windows host, before moving to exploitation?

A. Immediately attempt to exploit port 445 with a known exploit B. Run service version detection (-sV) and OS detection to confirm exact software versions before selecting an exploit C. Rerun the same scan with --badsum to double check D. Move directly to the reporting phase

Answer: B. CEH methodology calls for version and OS discovery before exploitation, so the exploit chosen actually matches the confirmed software version; attacking

blindly risks failure or unintended damage. A skips a necessary verification step. C would not add exploit-relevant information; --badsum is for firewall detection, not confirming services. D skips scanning, enumeration, and vulnerability analysis phases entirely.

Q16. Which scanning technique is specifically designed to make the IDS or firewall see many different IP addresses scanning the target at once, including the attacker's real address among them?

A. IP address decoy B. Idle scan C. Egress filtering D. Source routing

Answer: A. The decoy technique (-D) mixes the attacker's real probes with probes forged from several decoy addresses, so the logs show many apparent scanners. B is wrong because in the idle scan the attacker's real address never reaches the target at all. C is a defensive control, not an attack technique. D changes the path a packet takes, not how many apparent sources appear.

Q17. A tester captures a TCP SYN/ACK packet from an unknown host with Wireshark and sees TTL = 255 and window size = 4128. Which device type does this best match, based on the module's OS table?

A. A Linux web server B. A Windows desktop C. A Cisco router D. A FreeBSD firewall

Answer: C. The notes list Cisco routers with TTL 255 and window size 4128, an exact match. A would show TTL 64 and a different window. B would show TTL 128. D would show TTL 64 and window 65535.

Q18. Which statement about the TCP Connect scan (-sT) is correct?

A. It requires raw socket access and administrator or root privileges B. It completes the full three-way handshake using the operating system's own connect() call C. It is stealthier than the SYN scan because it uses fewer packets D. It works identically whether or not --spoof-mac is specified

Answer: B. -sT uses the OS's normal connect() function, which performs the full handshake, so it needs no special privileges. A is the opposite of the truth; -sT specifically avoids the need for raw sockets. C is false; -sT is generally noisier and more easily logged than -sS, not stealthier. D is false, which is demonstrated directly in the module notes: Nmap explicitly states that --spoof-mac is not honored for TCP Connect scans.

Q19. Which of the following AI-related statements about this module's scanning concepts is most accurate?

A. An AI assistant can guarantee a scan will not be detected by any IDS B. An AI assistant can help translate a plain-English scanning goal into the correct Nmap syntax, but the resulting command must still be verified before running it C. AI tools

replace the need to understand Nmap flags D. ShellGPT automatically obtains authorization to scan a target

Answer: B. This matches how the course presents AI tools such as ShellGPT: they generate commands from natural language, but the operator still reviews ([D]escribe) or confirms ([E]xecute) before running them. A overstates what AI can promise about detection. C is false; understanding the flags is still required to catch AI mistakes. D is false; authorization is a human and legal responsibility, never granted by a tool.

Q20. A tester wants to discover live hosts on the same physical LAN as her laptop, even though the hosts have host-based firewalls blocking ICMP and TCP probes. Which host discovery method is most likely to succeed?

A. -PE B. -PP C. -PR D. -PU

Answer: C. ARP ping (-PR) works at Layer 2 and does not depend on the ICMP or TCP stack being reachable; a host must answer ARP to use the network at all, so it is the most reliable method on a local LAN even when upper-layer probes are blocked. A, B, and D all depend on ICMP or UDP getting through, which the scenario says is blocked.

Q21. Which of the following correctly completes the Nmap decoy command to generate ten random decoy addresses alongside a real scan?

A. nmap -D decoy:10 TARGET B. nmap -D RND:10 TARGET C. nmap --decoy 10 TARGET D. nmap -10D TARGET

Answer: B. The correct syntax uses RND:N to generate N random decoy addresses, exactly as shown in the module notes (nmap -D RND:10 [target]). A, C, and D are not valid Nmap syntax.

Q22. A scan of a target shows port 80 as "unfiltered" using an ACK scan, but a separate SYN scan shows port 80 as "closed." What is the most reasonable combined conclusion?

A. The firewall allows ACK packets to reach the host, and the host itself has no service listening on port 80 B. Port 80 is definitely open and the SYN scan result is wrong C. The target does not exist D. The ACK scan result is invalid because UDP must be used instead

Answer: A. "Unfiltered" from the ACK scan means the packet reached the host and it replied, ruling out a blocking firewall; "closed" from the SYN scan means no service answers connection attempts on that port. Together, this means the port is reachable but nothing is listening. B incorrectly dismisses a valid, more specific result. C is contradicted by both scans returning results. D confuses protocols; ACK and SYN scans are both TCP techniques.

Q23. Which combination of flags is sent by the Maimon scan?

A. SYN only B. FIN and ACK C. FIN, PSH, and URG D. No flags at all

Answer: B. The Maimon scan (-sM) sets FIN and ACK together. A describes a normal connection start, not Maimon. C describes the Xmas scan. D describes the NULL scan.

Q24. An organization wants to stop its own network from being used to launch IP-spoofed attacks against other networks. Which control should it implement at its network edge?

A. Ingress filtering only B. Egress filtering C. Random initial sequence numbers only D. Service version hiding

Answer: B. Egress filtering blocks outbound packets whose source address is not within the organization's own assigned range, preventing spoofed traffic from leaving the network and being used against others. A protects the organization's own network from incoming spoofed traffic, which is a different direction of the same problem. C defends against session hijacking, not outbound spoofing. D is unrelated to spoofing.

Q25. Which tool from the module is specifically described as letting an attacker build and edit raw packets field by field, including a hex editor and a decode editor, to scan beyond a firewall?

A. Angry IP Scanner B. Colasoft Packet Builder C. Wireshark D. OpUtils

Answer: B. Colasoft Packet Builder is the packet crafting tool named in the module with a decode editor and hex editor for building custom TCP packets. A and D are host discovery or management tools, not packet builders. C captures and reads packets; it does not create and send custom ones.

Q26. A tester runs nmap -sU -p 161 10.10.1.30 and receives no response at all after several retries. What is the most accurate conclusion Nmap will report?

A. Port 161 is definitely closed B. Port 161 is open C. Port 161 is reported as open or filtered, because UDP gives no reply for either open ports or firewall-blocked ports D. Port 161 does not exist in the UDP protocol

Answer: C. Nmap cannot distinguish an open UDP port (which often does not reply unless given a protocol-specific request) from a filtered one (where the firewall silently drops the packet), so it reports "open|filtered". A and B overstate certainty the scan cannot provide. D is incorrect; port 161 is the standard SNMP port over UDP.

Q27. Which statement correctly distinguishes source routing from source port manipulation?

A. Source routing changes the destination port; source port manipulation changes the path a packet takes B. Source routing lets the sender specify some or all of the path a packet takes through the network; source port manipulation changes the originating

port number to one a firewall trusts C. They are two names for the same technique D. Source routing only works over UDP; source port manipulation only works over TCP

Answer: B. This is the precise distinction given in the module: source routing controls the route (which routers the packet passes through), while source port manipulation controls the port number the packet appears to come from. A reverses the definitions. C is false, they target different firewall weaknesses. D is an invented restriction not supported by the notes.

Q28. During OS fingerprinting, a tester notes a web application error footer reading "Apache/2.4.41 (Ubuntu) Server at example.com Port 80." Which category of banner grabbing does this represent?

A. Active banner grabbing, because packets were specially crafted B. Passive banner grabbing, because the information came from an error message without extra crafted probes C. This is not banner grabbing at all D. This is a form of IP spoofing

Answer: B. Reading information from a normal error page (something the server shows on its own without a specially crafted probe) is passive banner grabbing, specifically "banner grabbing from error messages" as described in the module. A would require active, crafted packets sent for the explicit purpose of OS fingerprinting. C is incorrect, this is exactly a banner grabbing example. D is unrelated; nothing about source addresses is involved here.

Q29. Why would an attacker prefer the half-open (SYN) scan over the TCP connect scan when scanning a large network, apart from stealth?

A. It is generally faster and requires fewer completed connections, since it never finishes the handshake B. It is the only scan type that works on UDP ports C. It works without needing raw socket privileges D. It always returns more accurate results than a connect scan

Answer: A. Because a SYN scan sends RST instead of completing the handshake, the kernel and the target do not need to manage a fully established connection for each probe, so in practice it is lighter and generally faster across many hosts and ports. B is false; both are TCP-only scans, UDP requires -sU. C is backwards; SYN scan needs raw sockets and elevated privileges, while connect scan does not. D is an overgeneralization; neither method is inherently more "accurate" in every situation, they simply behave differently against filtering devices.

Q30. Which of the following is NOT one of the eight port scanning countermeasures listed in this module?

A. Filter all ICMP messages at firewalls and routers, especially inbound types and outbound type 3 unreachable messages B. Keep router, IDS, and firewall firmware updated to the latest versions C. Allow all source-routed packets so legitimate

diagnostic tools continue to work D. Ensure anti-scanning and anti-spoofing rules are properly configured

Answer: C. The module's countermeasures explicitly call for ensuring that routing and filtering mechanisms "cannot be bypassed using a particular source port or source routing methods," which means source-routed packets should be restricted, not broadly allowed. A, B, and D are all directly listed among the eight countermeasures.

10. Flashcards

Q: What is network scanning? | A: Phase 2 of hacking. Identifies live hosts, open ports, services, OS, and vulnerabilities. Q: What are the six TCP flags? | A: URG, ACK, PSH, RST, SYN, FIN. Q: What is the three-way handshake? | A: SYN, then SYN/ACK, then ACK. Q: What ends a TCP session? | A: FIN, ACK, FIN, ACK (four steps). Q: What does nmap -sn do? | A: Host discovery (ping scan) only, no port scan. Q: What does -PE do? | A: Sends an ICMP echo request to find live hosts. Q: What does -PR do? | A: Sends an ARP request; works only on the local LAN. Q: What does -PU do? | A: Sends a UDP probe for host discovery. Q: What does -PS do? | A: Sends a TCP SYN probe for host discovery. Q: What does -PA do? | A: Sends a TCP ACK probe for host discovery. Q: What does -PO do? | A: Sends an IP protocol probe for host discovery. Q: What does -sT do? | A: TCP connect scan; completes the full handshake, no root needed. Q: What does -sS do? | A: Half-open SYN scan; stops after SYN/ACK with RST, needs root. Q: What does -sX do? | A: Xmas scan; sets FIN, PSH, URG. Q: What does -sF do? | A: FIN scan; sets only the FIN flag. Q: What does -sN do? | A: NULL scan; sets no flags at all. Q: What does -sM do? | A: Maimon scan; sets FIN and ACK. Q: What does -sA do? | A: ACK scan; maps filtered versus unfiltered ports, not open versus closed. Q: What does -sW do? | A: Window scan; reads the TCP window of RST replies. Q: What does -sI do? | A: Idle scan; scans through a zombie host using IPID changes. Q: What does -sU do? | A: UDP port scan. Q: What does -sY do? | A: SCTP INIT scan. Q: What does -sZ do? | A: SCTP COOKIE ECHO scan. Q: What does -6 do? | A: Scans IPv6 targets. Q: What does -sV do? | A: Detects service name and version on open ports. Q: What does -O do? | A: Guesses the target's operating system. Q: Why do FIN, NULL, and Xmas scans fail on Windows? | A: Windows replies RST to every probe instead of following RFC 793. Q: What TTL suggests Windows? | A: 128. Q: What TTL suggests Linux or FreeBSD? | A: 64. Q: What TTL suggests Cisco, Solaris, AIX, or OpenBSD? | A: 255. Q: What does nmap -f do? | A: Fragments probe packets into 8-byte pieces to evade simple filters. Q: What does nmap -g (or --source-port) do? | A: Sets the source port to one a firewall trusts, such as 80 or 53. Q: What does nmap -D RND:10 do? | A: Adds 10 random decoy addresses to hide the real scanner. Q: What does --spoof-mac do? | A: Sends raw packets with a fake MAC address. Q: What does --randomize-hosts do? | A: Scans target hosts in random order to avoid pattern detection. Q: What does --badsum do? | A: Sends packets with an invalid checksum to detect firewalls or IDS that reply anyway. Q: What does hping3 -a do? | A: Spoofs the source IP address of crafted packets. Q: Why can't a spoofed IP complete a TCP handshake? | A: The reply goes to the spoofed address, not to the

attacker. Q: What is ingress filtering? | A: Dropping incoming packets that falsely claim an internal source address. Q: What is egress filtering? | A: Dropping outgoing packets whose source address is not valid for your network. Q: What is active banner grabbing? | A: Sending crafted packets and comparing the response to a known database. Q: What is passive banner grabbing? | A: Reading error messages, sniffed traffic, or page extensions without sending probes. Q: What tool builds custom packets with a hex and decode editor? | A: Colasoft Packet Builder. Q: What are the ten IDS and firewall evasion techniques? | A: Fragmentation, source routing, source port manipulation, decoy, IP spoofing, MAC spoofing, custom packets, random host order and bad checksums, proxies, anonymizers. Q: What ports does the demo Windows host show open? | A: 21, 80, 135, 139, 445, 3389.

11. Glossary

ACK (Acknowledgement): TCP flag that confirms receipt of data.

Active banner grabbing: Sending crafted packets to a target and comparing replies to a known database to guess the OS.

Address mask ping (-PM): Host discovery using an ICMP address mask request.

Anonymizer: A tool or network that hides the identity and location of the user, such as Tor.

ARP (Address Resolution Protocol): Protocol that maps an IP address to a MAC address on a local network.

Banner grabbing: Method of finding the OS or software version a target runs, through its responses or error text.

CIDR (Classless Inter-Domain Routing): Notation such as /24 used to describe a range of IP addresses.

Connect scan (-sT): A TCP scan that completes the full three-way handshake.

CPE (Common Platform Enumeration): A standard naming scheme for operating systems, software, and hardware.

Decoy scan (-D): A scan where fake source addresses are mixed with the real one to confuse logs.

Egress filtering: Blocking outgoing packets whose source address does not belong to the local network.

FIN (Finish): TCP flag meaning there is no more data to send.

Fragmentation: Splitting a packet into smaller pieces to avoid detection by simple filters.

Half-open scan (-sS): A SYN scan that never completes the handshake.

Hping3: A command-line tool for crafting custom TCP, UDP, and ICMP packets.

ICMP (Internet Control Message Protocol): Protocol for network errors and diagnostics, used by ping.

Idle scan (-sI): A scan that hides the attacker's IP by bouncing probes off a zombie host and reading its IPID.

Ingress filtering: Blocking incoming packets that falsely claim an internal source address.

IPID (IP Identification): A field in the IP header that many systems increase by one for every packet sent.

ISN (Initial Sequence Number): The starting sequence number of a TCP connection.

Maimon scan (-sM): A scan that sets the FIN and ACK flags together.

MAC (Media Access Control) address: The hardware address of a network interface.

MAC spoofing: Sending packets with a fake MAC address.

MTU (Maximum Transmission Unit): The largest packet size a network link allows.

NetBIOS: An old Windows protocol for names and file sharing, seen on ports 137 to 139.

NULL scan (-sN): A scan that sends a TCP packet with no flags set.

OS fingerprinting: Identifying a target's operating system from its network behavior.

Ping sweep: Sending ping probes to a range of addresses to find live hosts.

Port: A numbered communication endpoint (0 to 65535) used by a service on a host.

Port scanning: The process of finding open, closed, and filtered ports on a host.

Proxy server: A computer that forwards traffic on behalf of another, hiding the original source.

Passive banner grabbing: Learning OS or software details from error messages, sniffed traffic, or URL extensions, without sending crafted probes.

RST (Reset): TCP flag that aborts a connection.

SCTP (Stream Control Transmission Protocol): A transport protocol with a four-way handshake, used in telecom signaling.

Service version detection (-sV): Identifying the exact software and version behind an open port.

Source port manipulation: Setting the source port of a probe to one a firewall trusts, such as 80 or 53.

Source routing: Specifying part or all of the path a packet takes through the network.

SSDP (Simple Service Discovery Protocol): Protocol used by UPnP devices to announce themselves, on UDP port 1900.

SYN (Synchronize): TCP flag that starts a new connection.

Target of evaluation: The system, network, or organization being scanned or assessed.

TCP (Transmission Control Protocol): A reliable, connection-based transport protocol.

Three-way handshake: The SYN, SYN/ACK, ACK sequence that starts a TCP connection.

TTL (Time To Live): A counter in the IP header that drops by one at each router hop, used to guess the OS.

UDP (User Datagram Protocol): A connectionless transport protocol with no handshake.

URG (Urgent): TCP flag marking data that should be processed immediately.

Window size: The amount of data a TCP receiver says it can accept, also used as an OS clue.

Xmas scan (-sX): A scan that sets the FIN, PSH, and URG flags together.

Zombie: An idle host with a predictable IPID used as a blind relay in an idle scan.

12. Coverage Report

12.1 Page to Section Map

PDF page	Slides (topics)	Guide sections
1	s2 objectives; s4 overview of scanning; s5 TCP flags and header	3.1, 3.2, 3.3
2	s6 TCP/IP handshake, termination; s9 host discovery tree	3.4, 3.5 (3.5.1-3.5.7)
3	s11 port scanning technique tree; s15 service version	3.6-3.15, 3.16
4	s19 OS ID by TTL and window; s26 packet fragmentation	3.17, 3.18
5	s28 source port manipulation; s30 IP address spoofing	3.19, 3.20
6	s32 creating custom packets; s18 OS and banner grabbing	3.21, 3.22
7	s25 scanning beyond IDS and firewall; s27 source routing	3.23, 3.24
8	s29 IP address decoy; MAC spoofing (title cropped)	3.25, 3.26
9	s33 random host order, bad checksums; s37 countermeasures	3.27, 3.29
10	s42 IP spoofing countermeasures	3.30

All tools, commands, ports, and terms from every page also appear in sections 4, 5, 6, 7, and 8.

12.2 [UNCLEAR] Items

1. Page 2: the exact sequence and acknowledgement numbers in the TCP/IP handshake and termination diagram (slide 6). Best reading given in 3.4, following the "+1" rule of TCP.
2. Page 2: the exact range, live host count, and timing in the ICMP ECHO ping sweep screenshot (slide 9). A representative sample is given in 5.2.
3. Page 3: the exact Service Info host name, OS CPE text, and scan timing in the service version discovery screenshot (slide 15).
4. Page 3: the precise switch syntax EC-Council intends for the TTL-based scan and the window scan (slide 11 shows "-ttl 100" and "-sA -sW" together). The guide

explains both the slide wording and the real Nmap syntax (--ttl, -sW) in 3.10 and 5.5.

5. Page 4: the exact Nmap command used in the SYN/FIN fragmentation screenshot (slide 26). Best reading: nmap -f against 10.10.1.11.
6. Page 5: the exact latency value in the source port manipulation screenshot (slide 28).
7. Page 6: field values inside the Colasoft Packet Builder decode editor and hex editor (slide 32). Not needed for exam content.
8. Page 8: the title of the MAC address spoofing slide is cropped in the screenshot. Content (the --spoof-mac Dell command and its output) is fully readable and placed in 3.26.
9. Page 8: the exact latency and the status of port 21 in the IP address decoy output (slide 29).
10. Page 9: the exact target address and timestamp in the --badsum output (slide 33).

12.3 Items to Double Check (marked "verify" in the text)

- Default ports and protocols Nmap uses for -PU (40125), -PS and -PA (80), and -PO (1, 2, 4) can change between Nmap versions.
- The EC-Council heuristic that TTL under 64 or a non-zero window in an ACK-scan RST means "open" is a rule of thumb, not a guaranteed result; confirm the exact wording in your official courseware.
- Whether the Maimon scan (-sM) still produces a usable result against any current operating system.
- hping3 exact flag letters for fragmentation and bad checksum, and the --rand-source behavior, across versions.
- RFC numbers cited for TCP (793), ICMP (792), IP (791), SCTP (4960), and ingress/egress filtering (BCP 38 / RFC 2827).
- Exact Metasploit module names for IPID sequence scanning and SSDP discovery (auxiliary/scanner/ip/ipidseq and auxiliary/scanner/upnp/ssdp_msearch).
- Current default TTL and TCP window values for the latest releases of Linux and Windows, since OS defaults can shift over time.

12.4 Confirmation

Every line of the working inventory (10 PDF pages, 22 screenshots, slides 2 through 42) is mapped to a section in the table in 12.1. Every tool, command, flag, port, protocol, and countermeasure named in the screenshots appears in the Topic-by-Topic Guide (Section 3), the Tool Encyclopedia (Section 4), the Command Sheet (Section 5), or the Ports and Protocols tables (Section 6). Items that could not be read with full certainty are listed in 12.2 with a best reading. Facts added from outside the screenshots are labeled ADDED CONTEXT throughout, and uncertain values are labeled "verify".